



SWIFT Customer Security Controls Framework

VMware Cloud Foundation 9.1

June 23, 2026

Table of Contents

Disclaimer.....3

Version.....4

Introduction.....4

Additional Resources4

Third Party Identifiers and Mappings4

Coverage Levels4

Controls..... 6

Disclaimer

This document is intended to provide general guidance for organizations that are considering Broadcom solutions. The information contained in this document is for educational and informational purposes only. This document is not intended to provide advice and is provided “AS IS.” Broadcom makes no claims, promises, or guarantees about the accuracy, completeness, or adequacy of the information contained herein. Organizations should engage appropriate legal, business, technical, and audit expertise within their specific organization for review of requirements and effectiveness of implementations.

Version

910-20260623-01

Introduction

This document describes how VMware Cloud Foundation (VCF) 9.1 and the separately licensed advanced services assessed alongside it, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, and VMware Avi Load Balancer, can support organizations working toward compliance with the SWIFT Customer Security Controls Framework (CSCF). The CSCF defines mandatory and advisory security controls for SWIFT users, organized around three objectives: secure your environment, know and limit access, and detect and respond. The SCF 2026.1 crosswalk maps to the 2025 release of the CSCF. Each assessed product is reported separately for every control, with VCF covering the full platform, including its consumption services and Private AI Services capabilities. The responsibility for attesting compliance with the CSCF remains with the SWIFT user.

<https://www.swift.com/myswift/customer-security-programme-csp>

This guidance evolves. Please check the current revision at: <https://brcm.tech/vcf-compliance>

Additional Resources

This is one of a library of companion guides that map VMware Cloud Foundation and its advanced services to security and compliance frameworks. For each framework, the guide is published as a spreadsheet, a CSV data file, a Markdown document, and a PDF, together with a Security Configuration Guide crosswalk that identifies the VCF technical hardening settings relevant to that framework. The companion guide library, the VMware Cloud Foundation Security Configuration Guide, and related security documentation, sample scripts, and Q&A are available at <https://brcm.tech/vcf-security>.

Third Party Identifiers and Mappings

This document includes regulatory compliance and security control identifiers from external sources as a convenience to end users. This does not constitute endorsement, in either direction.

There is not a one-to-one mapping of product capabilities to third-party controls. A product capability, or set of capabilities, may be applicable to multiple controls. Conversely, a control may be satisfied with the use of multiple capabilities.

Control identifier numbers have been included from the Secure Controls Framework, version 2026.1, under the terms of the Creative Commons Attribution-NoDerivatives 4.0 International Public License. No modifications have been made to the control identifier numbers under the terms of the license.

<https://securecontrolsframework.com/>

Coverage Levels

Each control entry below carries the framework control text, the SCF control or controls it maps to, and an Aggregate Coverage line showing the strongest position any one of the assessed products holds for that control. Products that meet or contribute to the control follow as subsections, each with its own coverage level and response. Products the control does not apply to are listed together at the end of the entry, with a brief explanation. The coverage levels are:

- **Meets** -- the product directly provides the capability described in the control. No additional organizational process, external product, or human activity is needed beyond configuring the product itself.
- **Contributes** -- the product provides technical capabilities that help satisfy the control, but the control also requires something outside the product to be fully met, such as an organizational process, human activity, or an additional tool.
- **Not Applicable** -- the control does not apply to the product. Physical facility controls, staffing decisions, organizational governance processes, and domains the product does not operate in fall here.

- **Not Supported** -- the control is relevant to the product's domain (infrastructure, networking, security), but the product lacks the specific capability the control requires.
- **Not Assessed** -- the control has not yet been evaluated against the product.

Controls

Control 1.1

| SWIFT Environment Protection

SCF Controls: NET-01, NET-02, NET-04, NET-04.1, NET-06, NET-06.1, NET-06.3, NET-06.4, WEB-02

Aggregate Coverage: Meets

VCF (Meets)

VCF provides built-in mechanisms for implementing and governing network security controls across the infrastructure stack, spanning virtual switching, network segmentation, policy management, role-based access control, audit logging, and documented hardening procedures.

NSX, the networking component of VCF, delivers a hierarchical security policy framework organized around domains, security policies, and individual rules. Each rule can be configured with action, direction, IP protocol, source groups, destination groups, services, and scope, providing administrators a structured and repeatable model for defining network security posture. Security policies are organized into categories (Emergency, Infrastructure, Environment, Application) so that multiple administrators can create and manage policies without conflicts or overrides. Firewall rules within each category are organized into sections, supporting logical grouping and ordered evaluation. This hierarchical structure supports both centralized governance and delegated administration, allowing organizations to maintain consistent security standards while enabling application teams to manage policies within their assigned boundaries.

VCF's network security governance model is built on role-based access control (RBAC) that spans networking and security functions. NSX Projects and VPCs support scoped role assignments including VPC Admin, Security Admin, Network Admin, Security Operator, and Network Operator roles. These roles can be assigned at the project or VPC level, enabling least-privilege access to network security configuration. A VPC Admin has full access to networking and security objects within their assigned VPC, while Enterprise Admins retain overarching control. NSX Advanced Network Management extends RBAC to specific networking components including static routes, locale services, segments, segment profiles, IP address pools, forwarding policies, DNS, DHCP, load balancing, and NAT. This separation of duties allows organizations to delegate day-to-day network security operations while retaining centralized oversight.

The NSX VPC workflow provides a structured mechanism for implementing network security controls at the application level. Application owners can add subnets inside their assigned VPC and configure security policies to meet workload requirements without dependency on the Enterprise Admin. VPC Admins and Security Admins add security policies within the VPC to address the security requirements of connected workloads. Default East-West firewall rules are activated automatically when an appropriate security license is applied and can be adjusted as needed. This self-service model, bounded by RBAC, allows security policy implementation to scale across the organization while maintaining governance guardrails.

VCF includes multiple layers of network security controls. VMware vDefend, a separately licensed product that extends NSX, provides Distributed Firewall enforcement across deployment and operational scenarios, while its Gateway Firewall provides perimeter security. Context profiles and Layer 7 access profiles enable firewall rules with application-level and domain-based attributes for both distributed and gateway firewall enforcement. For containerized workloads, the Antrea Container Network Interface (CNI) plugin in VMware Kubernetes Service (VKS) enforces Kubernetes NetworkPolicy at the namespace and pod level. The AntreaPolicy feature gate enables AntreaNetworkPolicy and ClusterNetworkPolicy objects that extend standard NetworkPolicy with richer Layer 4 rule sets; traffic not explicitly permitted is blocked by default when a policy applies to a pod. The Antrea NetworkPolicyStats feature gate collects enforcement statistics, giving operators visibility into which policies are matching traffic and at what volume to support operational monitoring and periodic policy review. A Kubernetes cluster must provide and enforce NetworkPolicy for network security controls to be effective.

The VKS networking layer within VCF integrates directly with the broader NSX security framework. Supervisors using NSX VPC networking operate in the system VPC while VKS clusters reside in vSphere Namespace VPCs, providing topology-level isolation between the management plane and workload clusters. NSX VPC pod IP pools are configured as Private, restricting

direct external accessibility of pod addresses. Antrea EgressSeparateSubnet allows egress traffic from specific workloads to originate from a subnet distinct from the default node subnet, supporting more granular traffic segmentation. The Network Control Plane (NCP) component bridges Kubernetes networking objects with NSX, realizing VirtualNetwork, VirtualNetworkInterface, and LoadBalancer resources for the VKS control plane; communication between Supervisor and NSX is secured using TLS. Kubernetes control plane services communicate using certificates by default, and connections from nodes and pods to the control plane are secured by default and can run over untrusted networks. Supervisor networking architecture requires a deliberate deployment-time choice: NSX with embedded load balancer, or vSphere Distributed Switch with external load balancer. This choice determines which network security mechanisms are available downstream, and organizational procedures should reflect which path is in use. VKS Cluster Management Custom Policies provide a governance mechanism that should be reviewed and updated to ensure policy logic reflects current security and operational requirements. The Argo CD Supervisor Service deployment implements network segmentation and firewall rules to secure communication between its components. Organizations operating service meshes alongside VKS gain OSI Layer 7 network policies based on workload identity and mutual TLS encryption for pod-to-pod traffic, providing an additional isolation layer beyond namespace boundaries.

At the virtual infrastructure layer, vSphere Distributed Switches provide centralized management of virtual networking, handling traffic for all associated hosts in a data center. Distributed switches support network segmentation using Private VLAN (PVLAN) and VLAN-based SPAN for distributed port mirroring. Network segmentation is built into the VCF architecture: management traffic, vMotion, and storage traffic are isolated on separate networks. Network I/O Control allocates bandwidth to traffic types based on share values, and the Storage Traffic Separation network profile creates dedicated vSphere Distributed Switches with separate physical NICs for storage traffic isolation. NSX distributed port groups and uplink port groups support Traffic Filtering and Marking policies configurable at the port level, providing additional granularity for layer 2 security controls. ESX hosts also support IPsec for VMkernel network communication, with security associations and policies configurable via `esxcli network ip ipsec` commands, supporting both transport and tunnel mode with upper layer protocol filtering for tcp, udp, icmp6, or any traffic.

vSphere Lifecycle Manager enforces desired-state configuration for hosts and clusters, applying and remediating configuration to match the defined software specification. This helps detect and address configuration drift that could weaken network security posture, and the remediation process can be managed programmatically through the vSphere Automation API.

VCF publishes security baselines through the Security Configuration Guide and DISA STIGs. The NSX Security Configuration Guide provides documented procedures for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes. Recommendations cover configuring strong authentication, implementing RBAC, and securing administrative access. NSX security best practices address creating and managing security groups, implementing distributed firewalling, configuring security policies, and enforcing microsegmentation to control network traffic. Security Technical Implementation Guides for Supervisor and VMware Kubernetes Release (VKr) components are available to provide hardening guidance for VKS deployments, extending the documented security baseline to the containerized workload layer. These documented hardening procedures, aligned with industry-standard best practices, give organizations a baseline for developing and updating their network security control procedures.

Audit logging supports ongoing governance by recording security policy changes with full traceability. NSX firewall audit logs capture the user performing the operation, the module name, operation type, operation status, and modified resource details including the security policy display name, identifier, path, and rule configurations. This audit trail enables organizations to track who changed network security policies, what was changed, and when, supporting both compliance review and change management processes.

Programmatic management capabilities, including PowerCLI cmdlets such as `InvokePatchSecurityPolicyForDomain` for creating distributed firewall policies, support infrastructure-as-code approaches to network security governance, enabling version-controlled and repeatable policy deployment.

VMware vDefend (Meets)

VMware vDefend provides the technical enforcement layer that underlies Network Security Control (NSC) implementation, though the procedural and governance aspects of developing and updating NSC procedures remain organizational responsibilities.

Security Services Platform enables monitoring of traffic after publishing assets and security policies to NSX Manager, allowing administrators to refine policies and adjust security posture based on observed traffic behavior. Security Intelligence Policy Recommendations correlate observed traffic patterns within the NSX environment to assist with enforcing more dynamic security policies; these recommendations can be reviewed and published directly to the Distributed Firewall (DFW) rule set. The Security Intelligence infrastructure classification feature identifies compute entities providing network infrastructure services in the NSX environment, supporting structured policy development around infrastructure traffic categories.

Dynamic NSGroups enable DFW and Gateway Firewall (GFW) rules to update automatically as workloads are deployed or modified in the environment. Security Services Platform provides a workflow to import data center hierarchy from CSV, which translates IP addresses to virtual machines, tags those VMs, and creates NSX groups necessary for segmentation planning. This supports the initial development of network security control structures from existing IP-based inventories.

vDefend DFW security posture is applied to VPCs through system-defined Security Profiles accessible in NSX Manager. When a Security Profile is applied to a VPC in VCF Automation, the system automatically generates and realizes system-managed DFW rules within the NSX Project space. DFW policies extend to Bare Metal servers, with Bare Metal server groups, vDefend DFW policies, and rules defined in NSX Manager and managed through Security Services Platform. Malware Prevention Service is configured through the IDS/IPS & Malware Prevention Setup wizard, which provides a guided sequence of steps to prepare the data center.

NSX Federation Security provides centralized management of security policies across multiple sites through a Global Manager, supporting consistent policy enforcement in distributed and multi-site environments. The Security Overview dashboard in NSX Manager displays threat detection and response features, a visual summary of the overall security configuration, and the capacity of NSX objects, giving administrators visibility into the state of deployed network security controls.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to Network Security Controls implementation through its infrastructure policy framework, which governs how databases are placed on the network and which network resources they may access.

DSM's architecture requires that network connectivity be provided through vSphere Distributed Switches (VDS) or NSX Virtual Distributed Switches (N-VDS). During initial setup, administrators configure IP pools that define the address space available for database deployment. IP pools may be created either during infrastructure policy definition or in advance, with each pool specified using a Subnet Prefix in CIDR notation that controls network vs. host address allocation. The vSphere administrator is responsible for regulating database IP assignment through this mechanism, tying database network placement to explicitly defined, administrator-controlled address ranges rather than allowing ad-hoc assignment.

Infrastructure policies aggregate network configuration choices alongside compute and storage settings into named policies that govern how databases are provisioned. The DSM administrator UI provides an Infrastructure Policies view that displays all configured policies and their associated resources, including IP pools, VM classes, CPU, memory, and storage policies, giving administrators continuous visibility into how network resources are allocated across the environment. Defining infrastructure policies is advised to provide full visibility into infrastructure usage by DSM users.

DSM actively detects conflicting network configurations. When it detects overlap between Supervisor infrastructure policy IP ranges and system configuration networks, it generates a NetworkOverlapFound alert and requires resolution before provisioning operations can proceed. Infrastructure policies should be updated to remove overlapping networks that may cause provisioning failures.

DSM supports custom certificate management for the Provider VM, including an IP-inclusive certificate style where the Subject Alternative Name can list one or more IP addresses and optionally FQDNs, aligning certificate identity with the addresses assigned through IP pool management. For SQL Server databases, administrators can specify the allowed TLS versions for client connections using the network.tlsProtocols custom engine setting in the data service policy.

DSM is a database-as-a-service platform rather than a dedicated network security tool. It does not provide firewalls, intrusion detection, or network traffic inspection; those capabilities are provided by VMware vDefend, which is a separate product. Developing and updating organizational procedures for network security controls is an organizational responsibility that DSM does not fulfill. The network isolation and address management controls DSM exposes are implemented through the underlying VCF platform infrastructure, and the broader NSC governance framework must be established by the organization.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer network security policy mechanisms that help organizations implement network access controls at the application delivery boundary. These Avi-native capabilities operate at the Virtual Service level and give administrators structured objects for defining, governing, and updating access rules as requirements change.

Avi's Network Security Policy evaluates incoming client traffic based on network-level parameters and determines whether a connection should be accepted, discarded, or rate-limited. IP Group-based access control lists applied per Virtual Service are the most scalable method for implementing network-layer ACLs, allowing administrators to specify which source addresses may reach individual application services. Policies can be created and modified through the Avi Controller CLI using the `configure networksecuritypolicy` command, and updated programmatically through the REST API using the Modify Network Security ACL endpoint and IP Group UUID references.

Starting with Avi Load Balancer version 32.1, NSX security groups can be used directly in both HTTP Policies and Network policies. Security groups defined once in NSX are reused across Avi Virtual Service security policies, removing the need to manually maintain IP address lists in Avi. When an IP address changes in NSX, the update propagates automatically to Avi Load Balancer, keeping Virtual Service security policies current without manual intervention. This integration provides a unified governance model where network security group membership is managed centrally in NSX and reflected automatically in Avi policy enforcement.

Avi's DDoS Policy detects and mitigates Layer 4 through Layer 7 network attacks through the Network Security policy framework, providing additional network security control at the application delivery layer.

Within the broader VCF platform, NSX provides underlay routing and network infrastructure for Avi Service Engines. East-west firewall enforcement between application tiers is provided by VMware vDefend, a separate product that extends the platform's network security posture beyond what Avi provides at the application proxy boundary.

Satisfying this control fully requires the organization to document procedures for governing and updating network security controls across the Avi tier and the broader platform, assign ownership of Avi policy objects, and establish change management processes covering both Avi Network Security Policies and VCF-layer controls.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 1.2

Operating System Privileged Account Control

SCF Controls: IAC-08, IAC-16, IAC-21, IAC-21.2, IAC-21.3

Aggregate Coverage: Meets

VCF (Meets)

VCF provides layered role-based access control (RBAC) across its component products, giving organizations granular mechanisms to restrict and control privileged access rights. These technical controls form a strong foundation for a privileged account management program, though full PAM implementation requires additional organizational processes and tooling beyond what VCF provides natively.

VMware vCenter implements fine-grained privilege-based access control where individual privileges can be grouped into roles and mapped to users or groups on specific inventory objects. Administrators can create custom roles with granular privilege assignment and configure permission propagation across the vSphere object hierarchy. For example, a custom role can allow a user to encrypt virtual machines but not decrypt them by selectively granting Cryptographic Operations privileges. Only a System Administrator can modify the rights in a predefined role. These privilege requirements apply uniformly regardless of how a client application accesses server content, whether through the vSphere Client, CLI, or SDK. The vSphere Web Services API Permission object enforces this model programmatically, enabling automated governance of role assignments. The Administrator role is required for full vCenter interface access, and the platform guidance recommends restricting this role to only those users who require access to all objects and actions in the environment. At the appliance management layer, access to the vCenter Appliance Management Interface and the vCenter appliance shell is restricted to root or a user with super administrator role, where root is the default super administrator user. Bash shell access for non-root users holding the super administrator role can be enabled by running ``shell.set --enabled true`` from the appliance shell.

Authentication is centralized through VCF SSO, which provides token-based authentication across VCF components. VCF SSO supports identity federation with external identity providers through SAML 2.0 and OIDC protocols, enabling integration with enterprise authentication systems and multi-factor authentication. When using an external identity provider, users first obtain a JSON Web Token (JWT) from the provider, which is then exchanged for a SAML token. VCF SSO integrates with a VCF Identity Broker to manage authentication for VCF Instance components. Solution users (service accounts used for component-to-component communication) authenticate using certificates rather than passwords, and VCF SSO supports multiple authentication methods including username token, X.509 certificate, and holder-of-key token authentication. This centralized authentication model removes the need for direct access to VMware ESX hosts for routine administrative tasks.

VCF Operations enforces its own RBAC model where users can only perform the actions that their assigned permissions allow. A vCenter user must hold either the vCenter Admin role or a specific VCF Operations privilege such as PowerUser, assigned at the root level in vCenter, to log in to VCF Operations. Administrators in vCenter receive mapped roles in VCF Operations during registration, but these accounts only receive a specific role on the root folder if it is explicitly assigned. The administrators role should be reserved for users who need access to objects and actions across the entire environment.

VCF Automation extends access control through entitlements and access control lists (ACLs). Organization users can use only those rights from their roles that are published to their organizations, restricting lateral privilege expansion. System administrators with the Manage General ACL right can create, modify, and remove specific ACLs through the accessControls API. Entity-type access can be granted to specific users and organizations, and system administrators must create entitlements using user criteria to manage access to projects and catalog items in the Service Catalog. VCF Automation project access is governed by pre-defined roles that scope what operations each user can perform within a project.

NSX provides RBAC through user role assignments that can be configured for local user accounts and users authenticated from identity management providers such as Active Directory over LDAP. NSX VPC user role assignments are managed from the User Management page. NSX Manager also supports local authentication where users authenticate using the PAM stack on the Unified Appliance, and local user passwords are secured using default Linux/PAM libraries with hashed and salted

storage. The admin user can manage account creation, deletion, and deactivation through the CLI or UI. vSAN similarly supports RBAC and permissions management for authentication and authorization.

VCF Operations uses a CloudAdmin role model that restricts access to platform-level operations. It supports ADMIN role accounts authenticated with username and password, and its System Administrator rights include granular controls over approvals, audits, certificates, and other administrative functions. VCF Operations provides a password management interface accessible through the Security menu, where administrators assigned the Administrator role can rotate account passwords and remediate service account passwords for integrated components. VCF Operations maintains a root user account and a super user (vcf) account that require ongoing password management. The VCF Operations API exposes a credentials endpoint at /v1/credentials that can be queried to retrieve vCenter root credentials, and if VCF Operations is not operational, these credentials can be recovered from the file-based backup. Default password complexity rules enforced through the Linux PAM module require at least 12 characters with mixed case, digits, special characters, and at least five different characters.

The VCF consumption layer, which encompasses VMware Kubernetes Service (VKS), vSphere Supervisor, and vSphere Namespaces, extends privileged access management across both the platform management plane and the Kubernetes workload layer. At the vSphere Namespace level, permissions are assigned to VCF SSO users and groups through three roles: Can View (read-only), Can Edit (provisioning and operating workloads), and Owner (full control including namespace deletion). The Owner role is available only with VCF SSO authentication. A VCF SSO user granted the Edit permission on a vSphere Namespace is automatically assigned the cluster-admin role for any VKS cluster deployed in that namespace, meaning namespace-level permission decisions directly determine cluster-level administrative rights. The VCF CLI enforces these role boundaries and returns a Forbidden error when a user lacks sufficient permissions on the vSphere Namespace for Supervisor or VKS cluster access. Administrative operations such as activating Supervisor Services or deleting a service registration require the Manage Supervisor Services privilege on the VMware vCenter system. Access assignments can be managed programmatically through the vSphere Automation REST API, and authentication for Kubernetes contexts can use either VCF SSO or external OpenID Connect providers.

Within VKS clusters, Kubernetes RBAC controls API server authorization through Role, ClusterRole, RoleBinding, and ClusterRoleBinding objects. RBAC rules specify fine-grained permissions by defining apiGroups, resources, and verbs (get, list, watch, create, update, patch, delete), and Role objects can further restrict access to specific named resources using the resourceNames field. ServiceAccounts can be bound to Roles or ClusterRoles via RoleBindings, enabling workloads to receive only the minimum permissions required to function. Granting cluster-admin to all ServiceAccounts cluster-wide is strongly discouraged because it allows any application full cluster access and grants any user with read access to Secrets the ability to create privileged pods; per-namespace permission management is the recommended approach. Cluster operators should restrict permissions that allow users or ServiceAccounts to escalate privileges through workload creation, and should carefully control authorization for CustomResourceDefinitions that govern ServiceAccount usage, ConfigMap mounting, or volume mounting. Kubernetes guidance recommends creating least-privilege access even for administrators, with broader access such as cluster-admin reserved for break-glass scenarios. For VKS clusters using a versioned ClusterClass, IAM role trust policies can be scoped to specific service accounts and namespaces to enforce least privilege at the identity layer. Dynamic Resource Allocation APIs should be controlled via RBAC to restrict access based on user persona.

Pod-level privilege control is available through Pod Security Admission (PSA) profiles enforced per namespace. The Privileged PSA level provides unrestricted permissions and allows known privilege escalations, making it appropriate only for trusted system workloads in controlled namespaces; the Baseline and Restricted profiles apply progressively tighter constraints. Security contexts within pod and container specifications allow configuration of runAsUser, Linux capabilities, and seccomp profiles to restrict the runtime permissions of individual containers. Kubernetes AppArmor profiles can further restrict per-program access privileges on Linux nodes. When requirePasswordOnSudo is configured on a VKS cluster, administrative sudo operations require explicit password entry. Namespaces that host privileged workloads should establish and enforce appropriate access controls to maintain least-privilege principles. The vmware-system-restricted Pod Security Policy, applied through RoleBindings, restricts which workloads service accounts within a namespace can run.

The consumption layer includes additional access control mechanisms for specific service types. The Secret Store Supervisor Service enforces RBAC across administrator, DevOps engineer, and application tenant roles for managing and distributing

sensitive data within VKS clusters, and Kubernetes recommends configuring least-privilege access to Secret objects through RBAC policies. Argo CD, which can be deployed as a Supervisor Service for GitOps-based workload management, supports local account authentication with global RBAC policies that define role-based access through policy rules and group mappings. For Windows workloads on VKS, Group Managed Service Accounts (GMSA) provide automatic password management, simplified service principal name management, and the ability to delegate management to other administrators; a service account must be bound to a cluster role via RoleBinding to authorize pods to use a specific GMSA credential specification. Access to Supervisor control plane nodes via SSH requires root user credentials through vCenter, which organizations should track and manage as a privileged access path reserved for troubleshooting operations.

To build a complete privileged account management program around VCF, organizations need to layer additional processes and tools on top of these platform capabilities. VCF does not natively provide session recording for privileged access, just-in-time privilege elevation, or automated access reviews. Organizations should implement policies governing who receives privileged roles, periodic recertification of privileged accounts, monitoring of privileged session activity, and integration with a dedicated PAM solution for credential vaulting and checkout workflows where required.

VMware Private AI Services (PAIS) provides AI-workload-specific mechanisms to restrict and control privileged access to its services, model artifacts, and AI resources. These operate on top of the foundational identity and access management that VCF supplies through VCF SSO and the VCF Automation role framework.

Access to Private AI Services is gated through OIDC group-based authorization. Administrators specify allowed groups in the `authorizedGroups` field of the `PAISConfiguration` custom resource when activating Private AI Services in an organization namespace through `kubectl`, or through the `oidc-authorized-groups` setting when activating through the VCF Automation UI. Only user accounts that are members of the specified groups, such as `group-for-pais-access-01` or `group-for-pais-access-02`, can access the service. The OIDC configuration includes a groups claim in the access token and a groups scope, so group membership is enforced as part of the authenticated session.

The Grafana observability interface for Private AI Services applies role differentiation through OIDC group membership. Administrators configure the `grafana-oidc-role-mapping` property to assign the Admin role to users that match a specified group attribute and the Viewer role to all other authenticated users. This separates operators who can modify dashboards from those who can only view metrics.

Access to AI catalog items in VCF Automation is scoped by project-based permissions. PAIS catalog items are shared only with selected project members, and DevOps engineers must receive explicit permissions from organization administrators before they can request GPU-accelerated VMware Kubernetes Service (VKS) clusters, deep learning VMs, or other AI resources. The Private AI Services Quickstart setup itself requires organization administrator credentials to access the VCF Automation organization UI, and VI administrators need vCenter privileges to deploy deep learning VM templates on a vSphere cluster. Programmatic access to VCF Automation uses provider administrator and tenant administrator access tokens obtained from the Provider Management UI, with API tokens that must be saved locally for subsequent calls.

The PAIS Model Gallery uses Harbor project access controls to restrict which users can read or write the ML models and training data stored in the registry. Harbor project membership and role assignments determine who can read or write model artifacts, and Harbor registry read-write permissions on a project are required to store models. PAIS model endpoints support authentication through the `harbor-pull-secret-readonly` mechanism to control access to container images stored in private registries, and the `oras login` command authenticates to a private Harbor registry using user name and password credentials for resource push and pull operations.

PAIS Knowledge Bases extend privileged access controls to the retrieval data sources that ground model responses. Confluence data sources use either a user name and password or a personal access token configured under the Confluence administrator's settings, Google Drive folders that act as data sources must be shared with the PAIS service account using view-only permissions, and personal access tokens generated from user account settings are used for programmatic access to Knowledge Bases and data sources. Remote MCP servers integrated with Private AI Services can optionally use static authentication tokens to control access to specialized data and capabilities.

VMware vDefend (Contributes)

VMware vDefend implements role-based access control across its management plane through the Security Services Platform (SSP). SSP defines five built-in roles with differentiated permissions: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. Permission levels range from Full Access (Create, Read, Update, and Delete) to Read-only or no access, depending on the role and operation. The Enterprise Admin role grants full authority over deployment, configuration, authentication and authorization settings, and backup operations. Modifying role assignments requires Admin privileges, and editing remote user or group role assignments requires LDAP to be configured as an authentication provider.

The two predefined local accounts, admin and audit, map to the Enterprise Admin and Auditor roles respectively, limiting each account to its designated functional scope. LDAP user account passwords are managed remotely by administrators, keeping credential management under organizational control.

Beyond its management plane, vDefend's Distributed Firewall (DFW) supports an Identity Firewall (IDFW) feature that enforces network access controls based on Active Directory user identity. Administrators create security groups in Active Directory and configure DFW rules that allow or deny user access to application servers based on group membership, applying role-based access controls at the network layer.

vDefend's Malware Prevention Service applies additional access restrictions to its service VMs: SSH access is disabled by default on the Malware Prevention Service virtual machine and must be explicitly activated by a vCenter administrator when needed for troubleshooting, then deactivated after use. The Malware Prevention Service VM ships with a default root password that must be changed on first login.

vDefend's contribution to this control is scoped to its own management interfaces and network-layer access enforcement. Controlling privileged access across the broader IT environment, identity lifecycle governance, and access controls for systems outside vDefend's domain require organizational processes and tooling beyond what vDefend provides.

VCF Protection and Recovery (Contributes)

Protection and Recovery (PNR) implements role-based access control through purpose-built roles registered in VMware vCenter and through a multi-tenant administrative model for Protection and Recovery for VCF Automation. The SRM Administrator role allows users or user groups to perform all PNR configuration and administration operations. The Protection and Recovery Administrator role can be assigned to user groups to manage permissions. Default roles provide the privileges users require to manage protection groups and perform recoveries, while restricting access to resources belonging to other users.

For automatic protection of virtual machines within a protection group, administrators assign either the SrmAdministrator or SrmProtectionGroupsAdministrator role to the automatic protection user or user group. This scopes the protection actions performed on the user's behalf to the privileges of the assigned role.

Each role is a collection of privileges that defines the actions a user can perform on the protection and recovery site. A user can have at most one role on an object, but roles combine when the user belongs to multiple groups that all have roles on the object. PNR supports propagating roles to child objects in the inventory hierarchy, so administrators can extend privileges from parent objects such as folders to all virtual machines within them.

Protection and Recovery for VCF Automation introduces a multi-tenant role model with Provider Administrator, Organization Administrator, Project Administrator, and Project Advanced User. Each role has specific authorization levels for disaster recovery operations. Provider Administrators select which replication classes each Organization can use, restricting organizational access to specific recovery configurations. Organization Administrators manage the pairing of namespaces and assignment of replication classes within their tenancy.

Underlying directory services, authentication, and enterprise identity governance are provided by VCF SSO and the broader VCF platform. PNR consumes those identities and layers its protection and recovery roles on top of them.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) provides role-based access control that restricts privileged access to database platform resources. The platform defines two built-in roles: DSM Admin and DSM User. The DSM Admin role is a super user role with full access to all data services in the environment, while the DSM User role restricts users to viewing and managing only the objects they own. This separation means that standard database consumers cannot affect or view resources belonging to other users or managed by administrators. The DSM console enforces this separation by restricting the views and actions available to each user based on their assigned role.

Privileged access within DSM is further scoped through namespaces. DSM User role assignments can be restricted to one or more specific namespaces, limiting access to only those assigned workspaces. This namespace-level scoping provides a granular mechanism for controlling who can access which database workloads. Namespace RBAC is enforced at the platform level, preventing users within a shared namespace from accessing resources in other namespaces.

Role and user management is performed through the vSphere Client Permissions interface under the DSM Configure tab, and through the DSM administrator UI Permissions view, where administrators can create, monitor, and manage configured users. DSM supports both local users and LDAPS-authenticated directory service groups, enabling organizations to align DSM role assignments with their existing enterprise identity management systems. Directory Service Groups can be assigned either the DSM Admin or DSM User role. When local and LDAPS users share the same username, login precedence must be considered to avoid authentication conflicts.

At the platform infrastructure level, DSM uses a dedicated VMware vCenter service account rather than persisting administrator credentials. During initial setup, the deploying user must provide local vCenter administrator credentials. DSM uses those credentials to create a dedicated vCenter service account and then discards the original credentials after successful registration. Ongoing operations use only the service account, which is configured with the minimum permissions required for service account creation, plug-in registration, and resource management. The service account credentials for the target vCenter can be verified and updated in Settings > System Settings under Target vCenter.

For SQL Server databases, DSM applies additional engine-level privileged access controls. DSM deactivates the default sa account and uses a reserved internal account, `dsm_mgmt`, with sysadmin privileges for management operations. The cluster administrator login is granted restricted read-only privileges and specific ALTER privileges for server management and auditing rather than full system privileges. When Windows Authentication is configured for SQL Server, DSM requires a Privileged Account configured in Active Directory to automate management of service principal names (SPNs) and DNS records.

Because DSM relies on vCenter for underlying infrastructure privilege management, achieving full coverage of this control requires organizational processes that are outside DSM's scope: maintaining an inventory of privileged accounts, conducting periodic access reviews, and managing approval workflows for new privileged account requests. DSM provides the technical enforcement mechanisms for restricting privileged platform access; the organization is responsible for the operational privileged access management procedures required to fully satisfy this control.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer provides role-based access control mechanisms on the Avi Controller that restrict which accounts hold privileged access. The Controller enforces Tenant and Role assignment during account creation, scoping each user's access to specific areas of the system based on their assigned role and tenant membership. Roles can be predefined or custom; administrators can create custom roles tailored to specific access requirements when predefined roles do not meet the needs of a given account. Role assignment is available at account creation or at any time thereafter through the Role drop-down menu in user account configuration.

The admin user account is the standard administrative account for Avi Load Balancer and is authorized to perform the highest-level operations, including user creation and authorization, tenant creation, and all infrastructure operations associated with the admin tenant. The admin account is maintained as a locally authenticated account even on systems configured for remote authentication. Once a user is assigned Super User privileges, the Super User Rule takes effect: no subsequent tenant or role mapping assignments can override that access level, making superuser designation a high-consequence privilege that requires an explicit administrative action to grant or revoke.

Within each user account, the assigned role is mapped to a tenant, so users can access resources only to the extent permitted by their role within that tenant. Privileged access in one tenant does not carry over to other tenants. This tenant-scoped role assignment allows organizations to enforce fine-grained access boundaries across multi-tenant deployments.

In global server load balancing (GSLB) deployments, Avi Load Balancer supports creation of non-admin users with assigned roles for granular access control. Dedicated role accounts can be assigned specific GSLB roles, such as the `gslbsitemembadmin` account assigned the `Gslb_Group_Member_Enabled` role, restricting each account's capabilities to its designated function. The Avi Kubernetes Operator (AKO) extends role-based access control to Kubernetes workloads through Custom Resource Definitions (CRDs) that can be governed by Kubernetes RBAC policies, allowing stricter access control over which users can configure routing rules and related resources.

The License Hub component within Avi Load Balancer enforces role-based access through two distinct local user accounts: an Admin account with the `enterprise_admin` role for full system management, and an Audit account with the `auditor` role scoped to system auditing purposes. This separation keeps high-privilege management access distinct from read-oriented audit access.

Control 1.3

Virtualisation Platform Protection

SCF Controls: CFG-01, CFG-02, SEA-01, SEA-02, SEA-13.1

Aggregate Coverage: Meets

VCF (Meets)

VCF is built on VMware vSphere, a hypervisor-based virtualization platform where virtual machines encapsulate complete computing environments and run independently of the underlying physical hardware. Each virtual machine is a software-defined computer that runs its own operating system and applications, backed by the physical resources of a host but fully abstracted from the specific hardware configuration. This architectural approach directly supports the deployment of a diversity of operating systems and applications on shared infrastructure.

VCF supports a broad range of guest operating systems within virtual machines. Guest customization is available for both Linux and Windows operating systems, and the guest operating system specified for a virtual machine determines the supported virtual devices and the available number of virtual CPUs. Applications that require a custom kernel or custom operating system can run in virtual machines, making VCF suitable for workloads that cannot be containerized or that depend on specific OS environments. VMware Hardware Assisted Virtualization can be exposed to guest virtual machines, enabling applications and nested hypervisors that require hardware virtualization support to run without binary translation or paravirtualization. For Windows guests, vSphere supports Windows Virtualization Based Security (VBS), which makes hardware virtualization, IOMMU, EFI, and secure boot available to the guest operating system, allowing Windows workloads to leverage VBS-dependent security features such as Credential Guard.

VCF provides several mechanisms for standardized and repeatable deployment of diverse workloads. Virtual machines can be created by converting an existing virtual machine to a template and producing multiple clones from that template, enabling consistent provisioning of different operating system and application configurations. Virtual machines use virtual disks to store their operating system, program files, and data, and support migration between hosts, snapshots, and linked clones. Virtual applications (vApps) allow one or more virtual machines to be deployed, managed, and maintained as a single unit, encapsulating multi-tier application stacks with their operational policies and service-level definitions. vApps can be customized at the application level using the OVF environment, supporting portable packaging of complex application topologies.

VMware Kubernetes Service (VKS) extends these virtualization capabilities into the Consumption layer by providing a unified platform for running both containerized applications and virtual machines under a single control plane embedded in the VCF platform. vSphere Supervisor embeds a Kubernetes control plane directly into VMware ESX hosts, exposing a declarative API surface that allows organizations to operate VM-based and container-based workloads with consistent infrastructure management and security policies across diverse application architectures.

Within vSphere Supervisor, virtual machine classes are represented by the VirtualMachineClass resource, which defines the virtual hardware profile including CPU and memory for each VM in a Supervisor namespace. Platform teams can define standardized compute profiles for different workload types using these classes. VM Operator enables management of virtual machines with a Kubernetes-style, declarative API expressed through YAML files that specify the VM image, VM class, and storage class. VM images are templates that bundle an operating system, applications, and data into a reusable definition. VM Service manages the lifecycle of both standalone VMs and the VMs that make up VKS clusters within a namespace, converting the desired state specified by operations teams into the realized state against backing infrastructure resources. The VM Service guidance identifies virtual machines as the appropriate model for applications that have specific hardware requirements, depend on a custom kernel, or are better suited to running in a VM than as containers.

VKS clusters support multiple operating systems for cluster nodes. Within a single Kubernetes release, node OS images are available for PhotonOS, Ubuntu 22.04, Ubuntu 24.04, Red Hat Enterprise Linux 9, and Microsoft Windows Server 2022, with PhotonOS as the default and alternative operating systems selectable through annotations in the cluster specification. This allows a single cluster infrastructure to serve applications packaged for different Linux distributions or for Windows without

requiring separate cluster topologies. VKS clusters also support heterogeneous node pools where Linux and Windows worker nodes coexist in the same cluster, enabling containerized Windows applications and Linux applications to run together managed through the same Kubernetes API.

For containerized workloads with stricter isolation requirements, vSphere Pods provide an additional option: each vSphere Pod is backed by a lightweight virtual machine that provides hardware-level isolation consistent with enterprise security policies, rather than the OS-level isolation of standard container runtimes. vSphere Supervisor therefore supports the full range of isolation approaches within a single environment: hardware-level VM isolation for workloads that require separate OS instances per workload, OS-level container isolation for lighter-weight workloads, and hardware-backed vSphere Pods for containerized applications that need stronger isolation boundaries.

VCF Operations HCX extends workload diversity by supporting OS-assisted migration for virtual machines running non-vSphere guest operating systems in both Linux and Windows environments. HCX validates KVM and Hyper-V hypervisors for guest operating system migration, allowing organizations to consolidate heterogeneous workloads from other virtualization platforms onto VCF.

VCF Operations provides OS and application monitoring capabilities that discover operating systems and applications running within provisioned guest operating systems and collect runtime metrics for monitoring and troubleshooting. This visibility spans the diverse set of workloads running on the platform, giving administrators insight into the health and performance of different operating systems and applications without requiring agents specific to each guest OS type.

VMware vDefend (Contributes)

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform,

providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs, and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the va-configurator.xml file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use scram-sha-256 as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support scram-sha-256, reject, and cert authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the `postgrescluster-allow-non-ssl-system-users` setting in the advanced-system-config ConfigMap within the `dsm-system` namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

Control 1.4

Restriction of Internet Access

SCF Controls: NET-01, NET-06, NET-06.3, NET-06.5, NET-18, NET-18.1

Aggregate Coverage: Meets

VCF (Meets)

VCF provides network architecture, routing topology, segmentation, and proxy capabilities that help organizations restrict or control internet access from sensitive data enclaves. Firewall enforcement at zone boundaries is delivered by VMware vDefend, a separate product layered on top of base VCF networking. Full enforcement of internet access policies also requires organizational controls beyond what VCF delivers natively.

NSX, the networking component of VCF, implements a tiered gateway architecture that controls north-south traffic flow between internal segments and external networks. A tier-0 gateway connects to tier-1 gateways via downlinks and to physical infrastructure via external interfaces, providing the boundary between the software-defined network and the outside world. Tier-1 gateways connect to segments in the southbound direction and to a tier-0 gateway in the northbound direction. In a single-tier routing topology, the tier-0 gateway handles both east-west routing between segments and north-south connectivity to the physical network. This architecture gives administrators explicit control over which internal segments have a path to external networks. NAT rules on tier-0 and tier-1 gateways allow administrators to control how internal addresses are translated for external communication; SNAT is supported on both tier-0 and tier-1 gateways running in active-standby mode.

The vDefend gateway firewall provides perimeter security control at the boundary between internal network segments and external networks. Administrators can create gateway firewall policies and apply them to tier-1 gateway service interfaces, defining rules that restrict or deny outbound connectivity from specific segments. Enterprise Admins and Project Admins can manage gateway firewall rules on tier-1 gateways within the context of an NSX project, giving per-tenant control over what traffic is permitted to leave the enclave. IP addresses and IP ranges can be specified in vDefend firewall rules to define which traffic is permitted to traverse network boundaries. For domain-based control, the vDefend distributed firewall supports FQDN-based rules that allow or reject traffic going to specific domains, with both a predefined list of FQDNs and custom FQDNs available for FQDN filtering policies. Gateway firewall rules do not support FQDN attributes in context profiles, so domain-based filtering is enforced through the Distributed Firewall rather than the gateway firewall. Organizations requiring stateful perimeter enforcement, microsegmentation, IDS/IPS, or traffic inspection at zone boundaries will need a vDefend license in addition to the base VCF networking capabilities.

NSX projects enable isolation of security and networking objects across tenants within a single NSX deployment, supporting multi-tenant architectures where different security zones maintain distinct internet access policies.

VCF Automation extends these controls through network profiles and security groups. On-demand private networks support VLAN-based isolation where segments are not connected to a tier-1 router, leaving no outbound routing path by design. For workloads that need controlled outbound connectivity, network profiles with isolation enabled by subnet or security group restrict which upstream networks are reachable. Outbound networks provide one-way access to upstream networks. A security group can define isolation settings for on-demand private or outbound networks, giving administrators granular control over which network segments have outbound access and which remain fully isolated. Two types of security groups are available: existing security groups selected from a predefined list, and on-demand security groups created through isolation policies on the Network Policies tab. An on-demand network with outbound access explicitly requires an external subnet configured with outbound access, meaning that networks without such a subnet assignment remain isolated by default.

For environments where security policies require systems to be disconnected from internet access, VCF supports air-gapped deployments. VCF Operations HCX, for example, detects air-gap mode during installation and establishes no internet connections when that mode is selected. When limited external connectivity is needed in otherwise restricted environments, administrators can configure an internet server proxy to channel and control outbound requests rather than allowing direct internet access. VCF Automation supports HTTP proxy configuration for environments without external internet access, and the proxy must be configured for IPv4.

At the platform level, the distributed switch includes built-in security controls that help protect traffic between workloads, and VCF Operations supports firewall hardening that restricts network access to internal services, reducing the attack surface of management components. The vSphere Distributed Switch also supports Traffic Filtering and Marking Policy, which allows administrators to configure traffic rules that allow or drop traffic on distributed port groups and uplink port groups, and Port Blocking Policies, which can selectively block specific ports from sending or receiving data on a distributed port group.

These controls provide the infrastructure mechanisms to strictly control or prohibit internet access from secure zones. Defining and enforcing the specific access policies for each enclave, including which zones require complete isolation versus controlled outbound access, requires organizational security policy decisions and configuration of the appropriate gateway firewall rules and network profiles.

VMware vDefend (Meets)

VMware vDefend provides network security controls that contribute to prohibiting or strictly controlling internet access from sensitive data enclaves.

The vDefend gateway firewall operates at the tier-0 and tier-1 gateway boundaries where north-south traffic flows between internal segments and external networks. Gateway Firewall policies can restrict or deny outbound connectivity from specific segments using Allow, Drop, or Reject actions. In VCF multi-tenant deployments, Enterprise Administrators can enforce project-level internet isolation using two Gateway Firewall strategies: VPC Isolation with Essential Services, which denies all general internet egress while permitting only essential infrastructure protocols such as DHCP, DNS, NTP, and ICMP; and Enterprise Gateway Isolation, which denies all communication between distinct projects. These strategies provide enforcement points where internet access from sensitive enclaves can be strictly controlled or prohibited entirely.

The Gateway Firewall URL filtering capability enforces access control policies using L7 access profiles. When a URL filtering rule is configured, the L7 access profile actions determine how matched traffic is processed, allowing administrators to restrict which internet destinations workloads in a given enclave can reach.

The vDefend distributed firewall enforces microsegmentation policies at the vNIC level within the data center. The Application Connectivity Strategy provides structured postures for egress control: the "Allow Intra, Deny Other Traffic" posture generates a default ANY/ANY/DROP rule that isolates workload groups from external communication by default. ALLOW EGRESS rules can be configured with Allow or Drop actions to control whether application entities can initiate outbound connections. Combining the Distributed Firewall for internal segmentation with the Gateway Firewall for perimeter control provides defense in depth for isolating sensitive enclaves.

Security Intelligence in the Security Services Platform defines private IP ranges that establish the boundary between internal workloads and external traffic. Traffic that crosses this boundary is treated as external, supporting visibility into which workloads are communicating outside the data center perimeter.

For environments where internet access from sensitive enclaves is prohibited by policy, vDefend components are designed to operate in air-gap and restricted-access configurations. The vDefend Distributed IDS/IPS can be configured for airgapped deployments where internet access is restricted or unavailable. Network Detection and Response can be configured for air-gap environments where internet connectivity to the vDefend Advanced Threat Prevention Cloud Service is not permitted. The Security Services Platform Private Mode supports highly secure, classified, or operationally sensitive environments where even manual internet access for licensing is restricted, and is commonly used in government, defense, and regulated industries where systems must operate without external connectivity.

Administrators should note that the Malware Prevention Service requires internet access from the Security Services Platform even when files are not sent to the cloud for detailed analysis; this connectivity requirement should be factored into enclave internet restriction policies.

Full prohibition of internet access from an enclave requires organizational policy decisions and configuration of the appropriate Gateway Firewall and Distributed Firewall rules. vDefend provides the enforcement mechanisms but does not itself define which enclaves are sensitive or what access policies should apply.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to Network Security Controls implementation through its infrastructure policy framework, which governs how databases are placed on the network and which network resources they may access.

DSM's architecture requires that network connectivity be provided through vSphere Distributed Switches (VDS) or NSX Virtual Distributed Switches (N-VDS). During initial setup, administrators configure IP pools that define the address space available for database deployment. IP pools may be created either during infrastructure policy definition or in advance, with each pool specified using a Subnet Prefix in CIDR notation that controls network vs. host address allocation. The vSphere administrator is responsible for regulating database IP assignment through this mechanism, tying database network placement to explicitly defined, administrator-controlled address ranges rather than allowing ad-hoc assignment.

Infrastructure policies aggregate network configuration choices alongside compute and storage settings into named policies that govern how databases are provisioned. The DSM administrator UI provides an Infrastructure Policies view that displays all configured policies and their associated resources, including IP pools, VM classes, CPU, memory, and storage policies, giving administrators continuous visibility into how network resources are allocated across the environment. Defining infrastructure policies is advised to provide full visibility into infrastructure usage by DSM users.

DSM actively detects conflicting network configurations. When it detects overlap between Supervisor infrastructure policy IP ranges and system configuration networks, it generates a NetworkOverlapFound alert and requires resolution before provisioning operations can proceed. Infrastructure policies should be updated to remove overlapping networks that may cause provisioning failures.

DSM supports custom certificate management for the Provider VM, including an IP-inclusive certificate style where the Subject Alternative Name can list one or more IP addresses and optionally FQDNs, aligning certificate identity with the addresses assigned through IP pool management. For SQL Server databases, administrators can specify the allowed TLS versions for client connections using the network.tlsProtocols custom engine setting in the data service policy.

DSM is a database-as-a-service platform rather than a dedicated network security tool. It does not provide firewalls, intrusion detection, or network traffic inspection; those capabilities are provided by VMware vDefend, which is a separate product. Developing and updating organizational procedures for network security controls is an organizational responsibility that DSM does not fulfill. The network isolation and address management controls DSM exposes are implemented through the underlying VCF platform infrastructure, and the broader NSC governance framework must be established by the organization.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer network security policy mechanisms that help organizations implement network access controls at the application delivery boundary. These Avi-native capabilities operate at the Virtual Service level and give administrators structured objects for defining, governing, and updating access rules as requirements change.

Avi's Network Security Policy evaluates incoming client traffic based on network-level parameters and determines whether a connection should be accepted, discarded, or rate-limited. IP Group-based access control lists applied per Virtual Service are the most scalable method for implementing network-layer ACLs, allowing administrators to specify which source addresses may reach individual application services. Policies can be created and modified through the Avi Controller CLI using the `configure networksecuritypolicy` command, and updated programmatically through the REST API using the Modify Network Security ACL endpoint and IP Group UUID references.

Starting with Avi Load Balancer version 32.1, NSX security groups can be used directly in both HTTP Policies and Network policies. Security groups defined once in NSX are reused across Avi Virtual Service security policies, removing the need to manually maintain IP address lists in Avi. When an IP address changes in NSX, the update propagates automatically to Avi Load Balancer, keeping Virtual Service security policies current without manual intervention. This integration provides a unified governance model where network security group membership is managed centrally in NSX and reflected automatically in Avi policy enforcement.

Avi's DDoS Policy detects and mitigates Layer 4 through Layer 7 network attacks through the Network Security policy framework, providing additional network security control at the application delivery layer.

Within the broader VCF platform, NSX provides underlay routing and network infrastructure for Avi Service Engines. East-west firewall enforcement between application tiers is provided by VMware vDefend, a separate product that extends the platform's network security posture beyond what Avi provides at the application proxy boundary.

Satisfying this control fully requires the organization to document procedures for governing and updating network security controls across the Avi tier and the broader platform, assign ownership of Avi policy objects, and establish change management processes covering both Avi Network Security Policies and VCF-layer controls.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 1.5

Customer Environment Protection

SCF Controls: AST-27, IAC-20.4, NET-03, NET-04, NET-04.1, NET-06, NET-06.3, NET-14, WEB-02

Aggregate Coverage: Meets

VCF (Meets)

VCF provides networking infrastructure and monitoring capabilities that support boundary protection at both external network boundaries and key internal boundaries within the virtual environment.

At the external boundary, NSX Edge nodes serve as the communication gateway for inter-location and northbound traffic, establishing a defined perimeter through which external communications traverse. NSX Edge supports policy-based and route-based IPsec VPN services on Tier-0, Tier-0 VRF, and Tier-1 gateways, enabling secure connectivity between sites and to external networks. NAT rules can be configured at the VPC level to perform IP translation between internal and external networks, controlling which workloads are reachable from outside the environment. External IP configurations allow outside connectivity for virtual machines on private networks by performing address translation through 1:1 NAT, granting access to specific workloads rather than exposing entire network segments.

For internal boundary control, VCF provides several layers of network segmentation. NSX segments, VLANs, and Private VLANs (PVLANS) allow administrators to create logical network boundaries that separate traffic at Layer 2. VMware distributed virtual switches support Private VLAN and VLAN-based SPAN for virtual distributed port mirroring. ESX port groups function as communication boundaries and can be configured with security policies to segment traffic between different groups of virtual machines. vSphere Distributed Switch port groups also support a Traffic Filtering and Marking Policy, which can permit or stop traffic on a per-port-group or per-port basis; port blocking policies provide a complementary mechanism to selectively prevent individual distributed ports from sending or receiving data. vSphere Distributed Switches provide centralized management of these boundaries across all hosts in a workload domain, applying consistent VLAN configurations and traffic shaping rules.

VCF supports multiple distributed switch models that isolate traffic at the physical layer. The Storage Separation Distributed Switch model isolates storage traffic onto a separate vSphere Distributed Switch from management and virtual networking traffic. The Workload Separation Distributed Switch model isolates VM Management traffic onto a separate switch from ESX Management, vMotion, Storage, and Virtual Networking traffic. In secure environments, these separation models can provide physical air-gapped separation of network traffic.

NSX Virtual Private Clouds (VPCs) provide isolated network environments within a shared infrastructure. VPCs support on-demand logical networks that can be advertised as public subnets or exposed through networking services like External IPs or NAT, providing project-level boundary isolation with their own topology, IP address management, and permission models. VCF Automation maintains secure organizational boundaries that isolate tenants from one another, providing additional logical separation within the environment.

Network I/O Control (NIOC) determines the bandwidth that different network traffic types are given on a vSphere distributed switch. When NIOC is enabled, distributed switch traffic is divided into predefined network resource pools covering Fault Tolerance, iSCSI, vMotion, management, vSphere Replication, NFS, and virtual machine traffic. Bandwidth reservation and shares allocation enforce performance boundaries between traffic types under contention. Avi Load Balancer provides Layer 4 load balancing for services, distributing traffic across server pools with configurable load balancing algorithms and health monitoring.

VCF provides network monitoring through multiple components. NSX supports IPFIX profile configuration on segments to enable flow-based network monitoring, giving administrators visibility into traffic traversing the network. At the vSphere layer, NetFlow can be enabled on individual distributed port groups or ports through the vSphere Distributed Switch monitoring policy, providing IP packet flow data independent of NSX. The pktcap-uw command-line utility on ESX hosts supports packet capture at specific points in the network stack, including at physical adapters and at the boundary between the distributed

switch and physical adapters, enabling packet-level traffic inspection without additional tools. NSX Manager monitors control plane connections between transport nodes and manager nodes, providing awareness of the network infrastructure state.

VCF Operations extends monitoring capabilities with network metrics including inbound and outbound connection tracking (net|allInboundTotal and net|allOutboundTotal). The Management Pack for Network Devices provides alerts and notifications for key network events including throughput totals and packet counts, and monitors outgoing errors on network interfaces. VCF Operations can detect protected flows, identifying traffic that has a specific firewall rule associated with it beyond a default allow-all policy, which helps administrators understand which communications are governed by explicit security policies. Outbound flow limits serve as a protection mechanism, with TCP flows limited to 1,000 allowed and 50 denied outbound, and UDP flows limited to 500 allowed and 50 denied outbound. VCF Operations also supports firewall hardening that restricts network access to its own internal services, demonstrating boundary protection for management interfaces.

VCF Operations for Networks adds flow analysis and troubleshooting capabilities, including application discovery based on flows, network topology visualization through the Topology Graph Widget, and traffic flow visualization between applications, application tiers, shared services, and the Internet. VCF Operations for Networks provides intents for network design and verification, helping validate that the network configuration matches the intended design. Distributed virtual switches support health check operations for NIC teaming and VLAN/MTU verification, while vSAN network partition health checks detect VLAN misconfigurations and uplink losses. VCF Operations for Networks also provides visibility into vDefend distributed firewall rule activity, including identification of inactive rules that have had no matching flows.

VMware Kubernetes Service (VKS) clusters and the vSphere Supervisor control plane extend boundary protection to the workload consumption layer. Within VKS clusters, Kubernetes NetworkPolicy objects provide declarative packet-filtering rules at OSI Layer 3 and Layer 4, defining permitted ingress and egress traffic based on pod label selectors, namespace selectors, and CIDR blocks. By default, pods accept all traffic; NetworkPolicy objects restrict communication to only the flows required for each workload or namespace, establishing internal boundaries between application tiers. Antrea, the CNI plugin integrated with Supervisor in NSX VPC deployments, enforces these NetworkPolicy rules and exposes NetworkPolicyStats, giving administrators measurable visibility into how boundary controls are applied across cluster-internal traffic. At the cluster perimeter, distributed firewall isolation rules on cluster nodes block external networks from reaching VKS cluster pods by default; Supervisor control plane nodes can reach cluster pods, but traffic originating outside the Supervisor control plane is dropped. Connections from worker nodes and pods to the Kubernetes API server use the API server's secure port by default, and SSH tunnels restrict control plane-to-node communications from exposure outside the cluster network. Kubernetes Ingress resources backed by ingress controllers perform TLS termination and route external requests to backend services, establishing a defined and controlled entry point at each cluster's external-facing edge. Network segmentation and firewall rules are applied to secure inter-component communication within Supervisor Service deployments such as Argo CD.

For stateful firewall inspection, microsegmentation, IDS/IPS, and deep packet inspection at network boundaries, organizations can deploy VMware vDefend, which extends VCF's networking foundation with Layer 2 through Layer 7 firewall capabilities and advanced threat prevention. VCF's networking layer provides the segmentation, routing, and monitoring infrastructure on which boundary enforcement policies operate, but the active enforcement of traffic at those boundaries requires either vDefend or integration with external security tools. Organizational processes for defining boundary policies, reviewing traffic logs, managing firewall rule sets, and maintaining network diagrams are also required.

VMware Private AI Services (PAIS) contributes to boundary protection through AI-infrastructure-specific network isolation patterns for both connected and air-gapped deployments. The core boundary enforcement capabilities, including distributed firewall rules, IDS/IPS inspection, and traffic analysis, are provided by VCF and VMware vDefend.

PAIS setup is configured according to environment Internet connectivity, supporting either connected or disconnected air-gapped deployment models. In a disconnected air-gapped environment, files are downloaded from the Internet to a bastion host VM and then transferred to an admin host VM that has no Internet access, from which VI administrators interact with the environment. This pattern removes direct Internet exposure from the AI infrastructure components and constrains the path by which external content enters the trusted enclave.

In air-gapped deployments, PAIS configures components to pull container images from a local internal registry rather than from public sources. The NVIDIA GPU Operator deploys validator, operator, driver, manager, toolkit, and devicePlugin components as separate container images pulled from the local registry. PAIS model endpoints authenticate to private registries through harbor-pull-secret-readonly to control access to container images.

PAIS integrates with Harbor registries as a model storage backend, requiring authentication and certificate-based trust for model retrieval. The Model Gallery uses Harbor project access capabilities to restrict access to sensitive data used to train and tune models, providing an internal boundary between AI workload data stores and other platform consumers. PAIS uses a CA trust bundle for secure communication with external services and databases.

The NSX Edge cluster or Virtual Network Appliance (VNA) cluster provides two-tier north-south routing for the Supervisor instance and the workloads it runs, while the Workload Domain NSX Manager provides VPC networking services to private AI workloads. VPC networking for the VCF Automation organization is configured with a Public IP range, a transit gateway IP range, and a VPC private IP range to delineate external, transit, and internal address space for AI tenants.

Organizations should refer to the VCF and vDefend Coverages for the underlying boundary monitoring and enforcement infrastructure.

VMware vDefend (Meets)

VMware vDefend provides monitoring and control of communications at both external and internal network boundaries within the virtual infrastructure through stateful firewall inspection, microsegmentation, and behavioral traffic analysis.

At the external boundary, vDefend enforces zone boundaries and provides stateful North-South traffic inspection at the network perimeter. Gateway Firewall policies apply to traffic entering and leaving edge gateways, and Gateway Firewall IDS/IPS events can be monitored on nodes, providing inspection-layer visibility at the external boundary.

At internal boundaries, vDefend enforces East-West traffic policies between virtual machines, containers, and workloads regardless of their physical location. Distributed Firewall rules operate at the vNIC level, creating per-workload enforcement points that function as internal boundary controls. Distributed Firewall manages East-West traffic control for both inter-VPC and intra-VPC communication within Organizations, and Distributed Firewall rules protect traffic between objects within a VPC, enforcing boundaries within project-scoped network environments. This microsegmentation approach allows organizations to define fine-grained internal boundaries beyond traditional VLAN-based segmentation. The policy-level Applied-To field defines a clear boundary around a set of VMs, such as an entire application, allowing targeted policies for specific zones, tenants, or applications without interfering with policies defined for other applications, tenants, or zones. Distributed Firewall policies can explicitly block unsecure protocols such as Telnet, FTP, and TFTP across the data center, supporting protocol-level boundary enforcement. Distributed Firewall also supports targeted deny rules scoped to infrastructure groups via the Applied-To field to protect critical services, facilitating phased Zero Trust adoption. Distributed Firewall governance implements least-privilege security by preventing overly permissive rules such as any-to-any-allow configurations. Distributed Firewall policies manage security for Bare Metal servers through traffic-control rules, extending boundary enforcement beyond virtual workloads. For federated environments, Distributed Firewall policies applied globally allow sources or destinations to be any object without span restrictions, supporting multi-site boundary enforcement.

Security Services Platform adds environment-level boundary enforcement through Protection Rules, which define how traffic flows between environment pairs such as production, development, and test. Protection Rule actions can be set to Drop or Reject to block all traffic between specified environment pairs, or Allow for more selective enforcement. Security Services Platform Environment Protection evaluates whether workloads are protected by environment-specific segmentation policies and measures coverage including the percentage of environment pairs in blocked mode. Application Protection in Strict Mode enforces application-level firewall rules on all application workloads except infrastructure, with scoring based on workload coverage, traffic coverage, and lock-down policies. Security Intelligence, a capability within Security Services Platform, defines private IP ranges as the boundary for internal workloads, treating traffic that crosses this boundary as external. The Secure External Communications project identifies workloads with inbound or outbound connections to external IP addresses to mitigate vulnerability to attacks. Security Intelligence recommends identifying all inter-environment flows and securing them with specific policies before enforcing strict block rules, supporting a methodical approach to boundary hardening.

Network Detection and Response (NDR) monitors traffic across boundaries and collects detection events representing security-relevant activity that has occurred in the network. NDR can be integrated with SIEMs to send security event logs about network infrastructure for centralized boundary monitoring. In sensitive or classified environments, NDR can be configured for air-gapped networks, executing all detection, correlation, and response activities entirely within closed networks using local storage and processing without requiring external connectivity. NDR remediations for events detected on the Gateway Firewall are applied on the Distributed Firewall, providing a unified enforcement response across both the internal and external boundary layers.

vDefend does not define which boundaries an organization should establish or set the policies governing boundary placement decisions. Those are organizational architecture and governance responsibilities. The underlying networking infrastructure of VCF, comprising NSX segments, VLANs, and edge gateways, provides the segmentation and routing fabric on which vDefend's boundary enforcement operates.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides boundary protection mechanisms at the application delivery layer for traffic it proxies. Network Security Policies in Avi evaluate incoming client traffic based on network-level parameters and determine whether a connection should be accepted, discarded, or rate-limited. These policies apply IP-based traffic filtering at the virtual service level; a deny rule stops further policy evaluation, preventing downstream HTTP Security, Request, or Response policies from executing for that traffic. Network security policies are configurable per virtual service and per Virtual IP address, giving administrators auditable and consistent access controls across the deployment.

Avi's Web Application Firewall (WAF) inspects application-layer traffic at the proxy boundary using positive and negative security models. Positive Security rules define what constitutes allowed application behavior and enforce restrictions on traffic that does not conform to that model. WAF Application Rules provide protection against known attack patterns, including rules targeting specific CVEs; rules are automatically updated through the Controller Cloud Services connection, and existing rules continue to protect applications when that connection is unavailable. WAF rule actions support pass and deny options for controlling traffic based on policy matches. Administrators can also enable the Application Rules service through the Avi Cloud Console, which delivers automatically updated CVE-targeted rules directly to Avi Controllers.

For DDoS mitigation, Avi's DDoS Policy detects and mitigates Layer 4 through Layer 7 network attacks through the Network Security policy framework. This includes protection against DNS Reflection Ingress attacks, which involve sending DNS queries with spoofed IP addresses to flood a victim with unsolicited DNS server responses.

In Kubernetes deployments, the Avi Kubernetes Operator (AKO) extends boundary controls to Kubernetes ingress traffic. The L4 Rule custom resource definition (CRD) in AKO allows administrators to express custom Security Policies applied to virtual service traffic, including configuration for DDoS attack detection and mitigation. The `'insecureEdgeTerminationPolicy'` setting in AKO controls handling of insecure traffic, with a redirect option that enforces secure traffic routing through HTTP Request policies applied per FQDN.

Avi Service Engines implement traffic isolation between the data plane and the management and control plane using a dedicated management vNIC bound to the default Linux network namespace, with health monitor traffic further isolated through Linux network namespace features in the kernel. Service Engine IP addresses egressing the Data Plane vNIC are routed through the external network and subjected to routing isolation and ACL/firewalling controls present in that external network. A dedicated management network is required for communication between Avi Controllers and Service Engines. In isolated network deployments, each Avi Controller supports a second management IP address or DNS-resolvable FQDN for Service Engines connecting from an isolated segment, configured via the `'isolated-network-management-address'` setting.

In VCF deployments using the Avi-for-VCF integration, the Management Network hosts the Avi Controller and provides connectivity to vCenter, ESX hosts, and Supervisor control plane nodes, maintaining a defined boundary between management and workload traffic.

Incoming HTTP(S) traffic can be replicated to logging and sideband servers at the protocol level via the Virtual Service Sideband Profile, enabling deep traffic inspection by external appliances such as web application firewalls and supporting compliance and auditing requirements.

Avi also supports a Firewall Sandwich Topology, where virtual services and firewall pool members are chained so that application traffic traverses configured firewall members on its path from the Internet to internal servers. In this topology, a sample of traffic is inspected by the firewall while remaining traffic considered trusted is directly routed to the internal network.

Boundary protection for segments and layers outside Avi's application delivery scope, including network-level perimeter controls, east-west enforcement between application tiers, and internal boundary protection across the broader VCF environment, requires the VCF networking infrastructure and VMware vDefend, which is a separate product.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 2.1

Internal Data Flow Security

SCF Controls: CRY-03, CRY-04, DCH-03.1, DCH-03.3, DCH-14, DCH-14.2

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides cryptographic protection for data in transit across management, compute, storage, and inter-site networks. The architecture applies encryption at multiple layers using validated cryptographic modules and current TLS protocol versions.

VCF management and monitoring communications use TLS as the transport protocol. VCF Operations for Networks supports modern TLS protocol versions, with the ability to restrict cryptographic module usage to FIPS-validated modules by enabling FIPS mode for external connections. Telegraf, the metrics collection agent, is configured to require a modern minimum TLS version for its communication channels. When using the databus for on-premises environments, HTTPS is the recommended transport to protect data during transmission and to verify subscriber authenticity. The TLS implementation includes customizable PKI options ranging from fully automated certificate management within VCF to integration with enterprise PKI infrastructure such as Microsoft Active Directory Certificate Services. VCF Operations provides centralized certificate lifecycle management across VCF components, supporting auto-renewal for VMCA, MSCA, and OpenSSL CA, handling automated renewal, monitoring, and replacement. Machine SSL certificates can be renewed through the API for a specified period up to 730 days. Starting in vSphere 9.0, all vSphere TLS profiles are FIPS compliant, and the COMPATIBLE profile supports modern TLS cipher suites and elliptic curves. The vCenter appliance uses VMware's Boring Crypto Module version 6.0, which provides FIPS-validated cryptographic operations including AES, ECDSA, HMAC, RSA, and SHA-2 variants.

NSX, which provides networking services within VCF, uses FIPS 140-3 validated cryptographic modules by default. These modules are validated through the NIST Cryptographic Module Validation Program. NSX Manager uses FIPS 140 approved algorithms for authentication to its cryptographic module. For site-to-site connectivity, the NSX L2 VPN FIPS compliance suite uses FIPS-approved encryption with Perfect Forward Secrecy enabled and standardized Diffie-Hellman key exchange, providing transmission confidentiality for tunneled traffic. VCF Operations for Networks supports modern ECDSA and RSA signature algorithms for data source connections.

VCF Automation uses the BouncyCastle FIPS 2.0.0 cryptographic module, which is compliant with FIPS 140-3 (Certificate #4743). VCF Operations for Networks uses the BC-FJA (Bouncy Castle FIPS Java API) version 2.0.0 with FIPS 140-2 Certificate #37009. These validated modules underpin the cryptographic operations used for securing communications across the automation and operations components.

At the storage layer, vSAN provides data-in-transit (DIT) encryption that protects data as it moves between hosts within the cluster. DIT encryption is a cluster-wide setting that, when enabled, encrypts all data and metadata traffic across hosts. Forward secrecy is enforced for vSAN data-in-transit encryption, meaning that compromise of a long-term key does not expose previously encrypted traffic. DIT encryption operates independently of data-at-rest encryption and does not require external key management servers. The behavior differs by storage architecture: in vSAN Original Storage Architecture (OSA), data-at-rest encryption occurs at the target host's Local Object Manager layer, so data traverses the network before encryption, making DIT encryption strongly recommended. In vSAN Express Storage Architecture (ESA) in HCI mode, data is encrypted at the VM host before network transmission, making DIT encryption optional based on compliance requirements.

VM Encryption provides confidentiality protection across all datastore types including vSAN, iSCSI, NFS, and Fibre Channel. VM encryption is implemented on the ESX host rather than on the storage array, so it protects data both at rest and in transit to the storage backend. Disk encryption uses AES-256 as the disk encryption key.

Encrypted vSphere vMotion protects VM data during live migrations. For encrypted VMs, vMotion always uses encryption and cannot be disabled. For unencrypted VMs, encrypted vMotion offers three settings: Disabled, Opportunistic (default, uses encryption when supported), and Required. AES-NI significantly improves encryption performance for these operations. Cross-vCenter vMotion supports encryption when source and destination use shared key providers; vCenter Crypto Manager provides an importProvider method to import a vSphere Native Key Provider configuration between sites. vSphere Fault

Tolerance log traffic, which synchronizes VM state between primary and secondary instances, can also be encrypted to protect this synchronization data in transit.

Storage protocol support varies by type. vSAN File Service supports NFS4 Kerberos authentication with security options krb5, krb5i, and krb5p, where krb5p provides authentication plus encryption of data in transit. iSCSI uses CHAP for session authentication but does not encrypt data natively, so VM Encryption or in-guest encryption is needed for confidentiality on iSCSI networks. Fibre Channel Gen 7 supports end-to-end encryption with secure Host Bus Adapters.

HCX Network Extension services support transport encryption for data between site pairs, and this encryption is enabled by default. VCF Operations HCX tunnel encryption similarly uses transport encryption by default to protect Network Extension data and migration traffic between sites. This default-on approach reduces the risk of data being transmitted in cleartext during workload migrations or network extensions.

High-quality entropy generation on ESX hosts supports the proper functioning of security-related operations such as generating encryption keys for secure network communication. This foundational capability helps maintain the strength of cryptographic keys used across all transmission encryption functions in the platform.

VMware Kubernetes Service (VKS), which runs on vSphere Supervisor, applies TLS encryption across all control-plane communication paths. The Kubernetes API server enforces encrypted transmission within the control plane and between the control plane and its clients by default, so all API server interactions travel over TLS. Cipher suites are configurable at each component layer: the kube-apiserver `--tls-cipher-suites` parameter accepts a comma-separated list of permitted cipher suites; the kube-scheduler exposes the same `tls-cipher-suites` parameter to keep its API endpoint aligned; and the kubelet exposes `tlsCipherSuites` and `tlsMinVersion` settings in `KubeletConfiguration` to scope the permitted cipher algorithms and minimum protocol version at the node level. Antrea, the CNI plugin included with Supervisor, supports configurable TLS cipher suites for its own secure communication channels through the `tlsCipherSuites` setting, and the vSphere Cloud Provider Interface (CPI) exposes the same capability through a configurable cipher suite list.

For environments with strict cryptographic requirements, VKS supports FIPS mode through the ClusterClass variable `fips.enabled`, which controls which encryption algorithms are permitted at the node level. TanzuKubernetesRelease references carrying the `-fips.1` suffix indicate that FIPS cryptographic modules are active for that node pool. The Istio service mesh package, available as a standard package on VKS clusters, ships with FIPS compliance and supports mutual TLS (mTLS) between pods within the mesh; the `meshMTLS.minProtocolVersion` setting controls the minimum acceptable protocol version for all inter-service traffic. Ingress-layer encryption for workloads is handled by the Contour package, which exposes `tls.minimum-protocol-version` and `tls.maximum-protocol-version` settings so operators can define a bounded range of acceptable protocol versions for inbound HTTPS traffic. The Supervisor secret injection agent automatically configures mutual TLS for its communication with the vault agent injector service using auto-generated certificates. Harbor, available as a Supervisor Service, accepts custom TLS certificates through its `tlsCertificate.tls.crt` and `tlsCertificate.tls.key` configuration fields, supporting encrypted access to the container registry for image distribution.

Defining the encryption policy for customer workload traffic, selecting cipher and FIPS configurations for environments with stricter requirements, and validating that data transmitted from customer applications and containerized workloads meets confidentiality standards are organizational data-policy decisions.

VMware Private AI Services (PAIS) provisions VKS clusters using a FIPS-enabled Kubernetes build for cryptographic compliance across both control plane and worker node communications. The VKS cluster topology version is v1.33.1--vmware.1-fips-vkr.2 with FIPS compliance enabled, running on an Ubuntu 24.04 OS image, covering the cryptographic modules that protect data in transit within the cluster fabric.

PAIS, activated through the PAISConfiguration custom resource on the Supervisor, requires HTTPS for all external integrations. The `spec.clientTls.caBundleRefs` section of the PAISConfiguration YAML references CA trust bundles supplied as ConfigMap resources. Operators must configure HTTPS trust bundles for the OIDC provider, the Harbor container registry, content management systems hosting Knowledge Base data sources, MCP servers providing tools to models, and the pgvector database. Separate trust bundles are recommended per application, with periodic updates required before certificate expiration.

The PAIS Supervisor endpoint uses HTTPS on port 6443 with certificate-based authentication. The PAIS ingress endpoint is protected by a self-signed certificate stored in the `pais-ingress-default` Kubernetes Secret. Administrators retrieve the CA certificate using `kubectl get secrets/pais-ingress-default -o yaml` and distribute it to clients that connect to the service, including Grafana when configured to scrape the PAIS Prometheus endpoint. CA trust bundles for external entity connections are managed through ConfigMaps and updated as certificate content changes.

VCF Automation Provider Management for PAIS uses a base64-encoded certificate (`TM_CERT_BASE64`) obtained by running `openssl s_client` against the VCF Automation FQDN on port 443, enabling authenticated HTTPS communication between AI catalog tooling and the PAIS environment. MCP server integrations require the MCP server's issuer certificate to be added as a CA trust bundle before connecting over HTTPS using either Streamable HTTP or Server-Sent Events transport.

Telemetry sent from PAIS to the OpenTelemetry Collector is authenticated using a Kubernetes Secret containing Authorization Bearer tokens and custom authorization headers. LLM trace transport to the collector uses HTTP/protobuf or gRPC, both protecting trace traffic in transit.

One configuration detail that auditors should verify: PAIS Prometheus TLS client authentication and certificate validation are turned off by default (the `tls-client-authentication` setting on the Prometheus endpoint). Organizations should review this setting and enable mutual TLS where their policy requires it. The underlying network transport encryption between VMs and workload domains is provided by VCF and is documented in VCF Coverage.

VMware vDefend (Contributes)

VMware vDefend contributes to transmission confidentiality through inspection, visibility, and enforcement mechanisms at the network layer, while the underlying cryptographic protection of data in transit is the responsibility of endpoint applications and infrastructure components.

TLS Inspection uses a transparent TLS proxy to intercept and analyze encrypted traffic flows traversing the environment. This allows security policy to be applied to traffic that would otherwise be opaque and supports detection of threats embedded within encrypted sessions. TLS Inspection can be deployed to provide visibility into encrypted connections while preserving end-to-end encryption for flows not subject to a decryption policy, and supports both inbound and outbound inspection profiles.

Security Intelligence, integrated within the Security Services Platform (SSP), surfaces workloads communicating over application protocols that transport data without encryption. The Security Segmentation Report identifies communication chains containing at-risk unprotected members and quantifies the number of unprotected data flows hitting default-allow rules across observed traffic. Administrators can use this reporting to identify and prioritize remediation of encryption coverage gaps, including restricting or blocking cleartext protocols.

The Security Services Platform and its component services use FIPS 140-2 and FIPS 140-3 validated cryptographic modules for their own communications. Network Detection and Response (NDR) Sensors connect to the SSP using mutual TLS authentication (mTLS), with a dedicated certificate for each sensor signed by an intermediate certificate authority on the SSP. The SSP can be configured to forward log messages to a syslog server over TLS, and Malware Prevention Service remote logging likewise uses TLS to transmit log data to a remote log server. NDR also supports SSL verification for event logs sent over HTTPS. When NDR shares data to the cloud, it anonymizes sensitive customer information before transmission.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides cryptographic protection for data transmitted during disaster recovery operations, covering management communications and replication data flows.

All communications between the PNR server and VMware vCenter (vCenter) instances take place over TLS connections. PNR requires an SSL/TLS certificate, with x509v3 Extended Key Usage indicating TLS Web Server Authentication, as the endpoint certificate for all TLS connections to the PNR server. PNR defaults to the current TLS version for all communication endpoints and supports administrative configuration of the minimum acceptable protocol version. Administrators configure the minimum TLS protocol version by editing the `tls_minimum_protocol_version` parameter in the `envoy-proxy-config.json` file; when

changing the minimum version, the update must be applied consistently across all occurrences in the system. PNR uses TLS certificates and private keys to protect network communication and authenticate with other servers.

For replication data, vSphere Replication encrypts replication traffic in transit for both new and existing replications. Network encryption is mandatory when using vSphere Replication 9.0.3 and later and is enabled by default. PNR also supports configuring network encryption of replication traffic as an option for replication scenarios where mandatory encryption does not apply automatically. PNR supports protection and recovery of encrypted virtual machines through both array-based and vSphere Replication protection groups, allowing VM disk encryption to persist through the replication process. Recovery of encrypted virtual machines requires that the protected and recovery sites share a common Key Management Server (KMS), or that the KMS clusters at both sites use common encryption keys, to maintain key availability after failover.

Defining the encryption policy for environments with stricter requirements and validating that workload traffic running on protected virtual machines meets confidentiality standards are organizational data-policy decisions.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) applies TLS-based encryption across multiple communication paths, covering database client connections, management interfaces, service-to-service communication, and data migration traffic. Starting with DSM, the platform enforces FIPS 140-3 compliant cryptographic standards and validates certificates during upload, rejecting unsupported algorithms such as Ed25519.

For database client connections, DSM enforces a minimum TLS protocol version across all supported database engines. PostgreSQL instances enforce a configurable minimum TLS protocol version via the ``ssl_min_protocol_version`` setting and support certificate-based authentication with CA verification. PostgreSQL replication connections support SSL/TLS encryption with a configurable ``sslmode`` parameter to secure data in transit between source and target databases, and DSM validates SSL trust before establishing replication. MySQL locks TLS protocol enforcement at the platform level so users cannot weaken it. MySQL has ``require_secure_transport`` set to ON by default, which requires all client connections to use encrypted transport. MySQL supports FIPS mode via the ``ssl_fips_mode`` setting. DSM adds SQL Server as a supported database engine; SQL Server clusters use TLS to encrypt client connections, require a minimum TLS version for DSM operator management, and expose the ``network.tlsProtocols`` engine setting to configure the set of allowed TLS versions.

For management and service-to-service communication, the DSM Provider exposes an HTTPS endpoint. The Consumption Operator requires a TLS certificate for secure communication with the DSM provider. In network-isolated deployments, Consumption Operator image transfers to a private registry support optional TLS certificate authentication. Metrics forwarding from DSM to VCF Operations supports mutual TLS (mTLS) authentication, requiring a client certificate and private key. DSM SMTP settings include an Auto TLS option that establishes a secure connection to the SMTP server.

DSM provides certificate management capabilities to support the TLS infrastructure. Custom certificates are validated for FIPS 140-3 compliance at upload time; accepted key types are ECDSA P-256, ECDSA P-384, and RSA with a minimum key size of 2048 bits, and Ed25519 keys are rejected as non-compliant. Trusted root certificates added through the DSM UI must comply with FIPS requirements.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides application-layer transfer authorization mechanisms that verify client and service credentials before forwarding data to backend resources. For application traffic, Avi's OAuth and OpenID Connect (OIDC) integration supports the Authorization Code Grant Flow, through which the authorization server authenticates the resource owner, evaluates the client's access request, and issues access tokens only after authorization is confirmed. Clients must present a valid access token to the Avi virtual service; the Authorization Endpoint handles user-agent redirection to the authorization server, and the token endpoint validates the authorization code and authenticates the client using the `client_id` and `client_secret` before tokens are issued. This flow verifies that the requesting party holds the required authorization before any data transfer to the backend resource server is permitted.

For more granular application-layer authorization, Avi supports Authorization Policies and DataScript within OAuth/OIDC flows. These allow administrators to define rules that evaluate token claims and request attributes, granting or denying

forwarding based on whether the client meets the configured authorization criteria. This provides control over which clients and services have the write permissions or privileges required to access specific application endpoints.

For administrative operations on the Controller, Avi's role-based access control enforces object-level write permissions. Write access to objects such as Virtual Services, Application Profiles, SSL/TLS Certificates, and Certificate Management Profiles is granted at the role and tenant level, so that only users with the requisite permissions can modify transfer-related configurations. TACACS+ integration supports centralized authorization by delivering attribute-value pairs from the TACACS+ server that map users to specific roles and tenants. The PASS_ADD and PASS_REPL statuses grant authorization to successfully authenticated users, while the FAIL status rejects those without the required attributes. Cisco ISE can be configured as a remote authentication and authorization backend for Avi, including with external identity sources such as OpenLDAP, providing centralized identity management for Avi administrative access. In Avi Load Balancer SaaS deployments, authorization tokens can be generated for service account authentication to the SaaS Controller.

Control 2.2

Security Updates

SCF Controls: VPM-01, VPM-01.1, VPM-02, VPM-03, VPM-04, VPM-04.1, VPM-04.3, VPM-05, VPM-05.1, VPM-05.8

Aggregate Coverage: Meets

VCF (Meets)

VCF provides integrated lifecycle management that addresses new threats and vulnerabilities on an ongoing basis through a structured release model, centralized update orchestration, proactive vulnerability detection, configuration drift monitoring, and automated node health remediation for containerized workloads.

VCF follows a tiered release cadence consisting of major, minor, maintenance, and patch releases. Major and minor releases are fully synchronized across all VCF core components, following a unified consumption pattern that advances the entire platform to a new, consistent feature level. Maintenance releases are scheduled, cumulative updates focused on platform stability, providing bug and security fixes, hardware enablement changes, driver updates, guest OS support, and backward-compatible new features with limited scope to minimize operational impact. Patch releases provide time-sensitive fixes to security and catastrophic issues impacting business operations, and can be applied selectively to individual components without requiring synchronized updates across the full stack.

VCF Operations orchestrates centralized lifecycle management for the entire VCF stack, including pre-update validation with health checks and compatibility verification, update bundle management with download and staging for both online and offline environments, and component interdependency management that respects dependencies between VCF components during updates. VCF Operations requires a precheck to succeed before scheduling upgrades, and requires acknowledgment of any errors or warnings in the precheck report before proceeding. The upgrade planner allows administrators to select any supported version for each VCF core component, including specific patch versions and VCF Bill of Materials versions. When connected to an online or offline depot, binaries for the target versions of each core component can be downloaded in preparation for upgrading or updating. VMware Kubernetes Service (VKS) cluster version upgrades are managed through this same VCF lifecycle management framework, providing a controlled path for remediating vulnerabilities in the Kubernetes control plane and node components. The VCF Automation Provider Management UI exposes a VKS cluster management interface that verifies cluster management functions and overall health status across all elements.

For vCenter specifically, administrators can automate the installation of software updates to keep the system stable and protected, including automated checks for new updates and staging of updates through update policies that reduce waiting time. VCF Operations Marketplace displays the latest published version of each management pack by default and provides a version selector to view all available versions or choose a different version to download. VMware provides proactive notification when management packs are updated to maintain compatibility, emailing customers on older versions when a new update is released.

VCF supports rollback capabilities for updates. vCenter RDU upgrades perform automatic rollback if the upgrade fails. VCF Operations HCX supports rollback using vSphere snapshots if an unexpected issue in a new version cannot be resolved in a timely manner. Live Patching capabilities allow security updates to be applied to ESX hosts without requiring a host reboot, reducing maintenance windows and accelerating the deployment of time-sensitive security fixes. For containerized workloads running on VKS, Kubernetes Deployments support rolling updates that allow workload operators to replace container images with patched versions while maintaining service availability; rolling update strategies limit the number of unavailable pods during an update, and Kubernetes tracks revision history to support rollback if a patched image introduces regressions.

vSphere Lifecycle Manager (vLCM) manages the full software and firmware lifecycle for ESX hosts. vLCM images can have firmware add-ons added, replaced, removed, upgraded, or downgraded, enabling vendor-specific firmware and driver management alongside software updates. Administrators can initiate ESX host remediation manually or schedule recurring remediation tasks to run during defined maintenance windows, supporting a consistent patch deployment cadence. Build recommendations for vSAN and other components include all patches and driver updates for the current release, giving

administrators a clear target for what constitutes the latest stable configuration. VCF supports Ensure Accessibility maintenance mode for vSAN storage clusters, using durability components to maintain data availability during updates.

At the Kubernetes layer, MachineHealthCheck provides an automated remediation mechanism for VKS workload clusters that is equivalent to scheduled host remediation at the infrastructure layer. MachineHealthCheck monitors node health and automatically replaces nodes that fall outside defined health thresholds, with configurable parameters including max-unhealthy (which prevents mass remediation when the number of degraded nodes exceeds a specified absolute count or percentage), node-startup-timeout, and unhealthy-conditions to define what constitutes a degraded node. In ClusterClass-based VKS clusters, the machineHealthCheck.enabled parameter activates this capability. The VCF CLI provides `vcf cluster machinehealthcheck node get` and `vcf cluster machinehealthcheck control-plane get` commands to inspect the current health status of worker and control plane nodes, and MachineHealthCheck specifications can be updated via `kubectl patch` with JSON merge patch for ongoing policy adjustments.

VCF Operations Diagnostics automatically detects known issues and critical vulnerabilities within the VCF software stack, providing descriptions, root cause insights, and actionable remediation steps. Broadcom publishes security advisories for critical known vulnerabilities with step-by-step remediation instructions. VCF documentation explicitly recommends keeping infrastructure up to date by running current component versions as part of operations best practices, noting that running outdated components that are too far behind the latest version can cause support problems, upgrade problems, and higher operating costs, and that fixes for known issues are often only available in later versions. The vSphere documentation also recommends that organizations run vulnerability scans against their systems and applications on a defined schedule and document the frequency of scanning as part of ongoing vulnerability management. This guidance extends to individual platform services, with specific recommendations to run the latest version of VCF Operations for Networks for security fixes for all known vulnerabilities, and to upgrade VCF Operations HCX when updated releases become available to have the most recent fixes and security patches. At the container image level, the Harbor registry integrated with the VKS Supervisor cluster provides vulnerability scanning, content trust, and policy-based replication to support the security and integrity of containerized workloads. Kubernetes operational guidance recommends that container images be regularly scanned during creation and in deployment and that known vulnerable software be patched as part of an ongoing practice. VKS Cluster Management Policy Insights surface compliance findings with direct links to the affected cluster, project, and policy to streamline the remediation workflow. VCF Supervisor documentation also recommends creating VM images with the latest patches and required security settings for production environments.

VCF uses Configuration Profiles and Image-Based Lifecycle Management to periodically assess host configuration against a desired state. VCF Operations provides unified configuration management that enables scheduled drift detection for vCenter and cluster objects to proactively detect configuration deviations from the desired state. When drift is detected, the system alerts administrators. VCF Operations compliance management detects violations, highlights risk areas, and provides actionable remediation recommendations. Depending on the severity of non-compliance, administrators can configure automated remediation actions to bring objects back into compliance.

Security and operations teams can use the management interface, CLI tools, and APIs to automate security posture assessment and remediation workflows, including integration with third-party monitoring and SIEM tools for continuous vulnerability awareness.

VMware vDefend (Contributes)

VMware vDefend (VMware vDefend) contributes to continuous vulnerability remediation by providing network-level threat detection and automated remediation capabilities that address known and emerging threats across protected workloads.

vDefend Distributed IDS/IPS detects known attack signatures across east-west traffic within the data center. The IDS/IPS engine supports CVE-based signature searches, allowing administrators to identify and enable signatures that address specific newly disclosed vulnerabilities. Knowledge-based signatures cover attacks that are already known and documented; for custom applications and zero-day scenarios, administrators can author custom IDS/IPS signatures that extend detection beyond the standard signature set. This combination of vendor-maintained and custom signatures allows organizations to

respond to new vulnerability disclosures by deploying detection rules that identify exploitation attempts before patches can be applied.

Security Services Platform's Security Assessment generates Security Segmentation Reports and Blast Radius Reports that identify at-risk workloads, communication chains, and network flows, providing the visibility needed to plan and prioritize remediation activities. Security Services Platform identifies vulnerable workloads that could be exploited for lateral movement and evaluates whether workloads are protected by environment-specific segmentation policies such as Dev, Prod, and Test. Security Services Platform provides remediation workflows that translate detected threats into actionable security policy changes. When IDS/IPS or Gateway Firewall events identify malicious activity, administrators can apply remediation actions that create or modify Distributed Firewall rules and IDS/IPS policies to block the identified attack vectors. Two remediation strategies are available: Targeted remediations create narrow, precise policies that address the specific threat with minimal impact to existing workloads, while Comprehensive remediations create broader policies that defend against similar attack patterns. Intelligent Assist automates the selection between these strategies and handles the creation of groups, security profiles, rules, and policies needed to implement the remediation. The Response and Remediation feature performs automated policy creation based on user role and permissions.

Security Services Platform supports ongoing security posture management through asset inventory classification and traffic monitoring. Security Intelligence continuously monitors for new flows between environments and alerts administrators to unauthorized or unexpected traffic, enabling ongoing policy adjustments as workload communication patterns change. Security Intelligence generates microsegmentation recommendations by analyzing inventory assets to create or update vDefend sections. The Security Segmentation Score Breakdown report details protection coverage across environment pairs and highlights pairs that lack inter-environment policies, making coverage gaps easier to identify and address.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) supports continuous vulnerability remediation through software update management, patch scheduling controls, and infrastructure health monitoring, though the broader organizational processes for vulnerability identification, tracking, and lifecycle management fall outside DSM's direct scope.

DSM provides a Maintenance Policy that controls the scheduling and duration of software updates to the DSM plug-in. Administrators configure this policy from the vSphere Client under "Managing Data Services Manager Plug-in Software Updates," setting the duration window for applying software updates. Upgrade operations performed during the maintenance window may include CVE fixes, bug fixes, and performance improvements, making the maintenance window the primary vehicle for applying security-relevant patches to the database platform. The documentation also recommends always using database versions with the latest DSM components to maintain optimal performance and security.

Administrators who deploy DSM through VCF Automation can configure maintenance windows with greater granularity. The Monthly Occurrences setting allows selection of a specific day and one or more occurrences of that day within the month; if no specific occurrence is selected, the maintenance window runs on a weekly cadence by default.

For SQL Server workloads, DSM introduces per-engine maintenance windows for operating system patching, configurable by SQL Server administrators within the DSM UI. The documentation recommends that SQL Server instances follow the Cumulative Update (CU) branch, which packages functional, performance, and security updates for each major version, keeping the data service current with vendor-issued fixes.

The DSM controller monitors component and feature dependencies continuously, performing automated remediation when dependency status violations are detected. This mechanism also manages compatibility requirements when upgrading DSM within a VCF environment.

For ongoing health visibility, DSM generates alerts across multiple categories that surface conditions requiring remediation attention. Administrators can configure alert threshold values for CPU Health, Data Disk Health, System Disk Health, and Max Connections parameters, with separate thresholds for warning and critical severity. Infrastructure compliance is monitored through alerts such as INFRASTRUCTURE_POLICY_VC_ALARMS, which fires when active infrastructure resource alarms are detected in vCenter. When alerts trigger, DSM provides guidance to help administrators identify underlying causes;

administrators are advised to verify active vCenter alarms before performing maintenance or scale operations and to resolve active CPU or memory alarms on ESX hosts before scaling database instances.

DSM integrates with VCF Operations, which automatically discovers and monitors PostgreSQL and MySQL database clusters in the Ready state. When configured, VCF Operations displays performance data at three levels: cluster-level for overall health, node-level for infrastructure resource utilization, and database-level for KPIs such as Active Connections, Commits, Rollbacks, and Deadlocks. This integration provides operational visibility that supports remediation workflows.

Continuous vulnerability remediation also depends on activities outside DSM's direct scope. Identifying new CVEs and vulnerabilities in the database engines that DSM manages (PostgreSQL, MySQL, SQL Server, MinIO), evaluating their applicability to a specific deployment, prioritizing remediation, and tracking remediation status all require organizational vulnerability management processes and tools. Organizations should integrate DSM update notifications with their broader patch management workflows and maintain a vulnerability management program covering both the DSM management plane and the database engines it provisions.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several mechanisms that support an organization's vulnerability identification and remediation processes for application delivery infrastructure.

For application-layer vulnerability identification, Avi's Web Application Firewall (WAF) supports virtual patching through integration with Dynamic Application Security Testing (DAST) tools. Organizations can import scanner results into Avi to identify vulnerable application endpoints. The WAF creates Positive Security rules for each identified vulnerability, restricting requests to known-good parameters without requiring changes to the protected application. This allows organizations to limit exposure to identified vulnerabilities while application-level remediation is underway.

In 9.1, the Avi Cloud Console adds a Live Security Threat Intelligence service, which includes an Application Rules Service providing rules targeting known application vulnerabilities identified by CVE. The service covers over 5,000 applications and automatically synchronizes rule database updates, keeping CVE-based protections current without manual rule management. When the service is temporarily unavailable, Avi Controllers continue to operate using the cached rule database.

For tracking and documentation, the Avi Application Security Report generates a downloadable PDF documenting WAF security findings and pre-check results, supporting both technical review and organizational documentation requirements.

The WAF Recommendation system supports the tuning portion of the vulnerability management process by proposing configuration changes to address false positives, with reasoning and risk assessment accompanying each suggested change. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation. Alert Actions can trigger ControlScripts in response to system events, enabling automated remediation responses to detected conditions in place of manual administrator intervention.

For platform-level vulnerabilities in the Avi Controller and Service Engines, Avi supports patch application and rollback. After upgrading to a new version, old root partitions that may contain packages with known CVEs can be removed to reduce residual exposure. If a patch introduces instability, rollback features allow operators to return the Controller and all Service Engine groups to the prior version via CLI commands (rollback system, rollbackpatch system) or the REST API (POST api/rollback). The REST API also supports non-disruptive SE-group-specific rollback, allowing selective rollback of individual Service Engine groups. Organizations can lock the Avi Controller Linux system to a specific OS version to avoid CVE scanner false positives from inactive, unused package versions.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 2.3

System Hardening

SCF Controls: CFG-01, CFG-02, CFG-02.1, CFG-02.2, CFG-02.5, CFG-02.8, CFG-02.9, CFG-03, CFG-03.3, IAC-21

Aggregate Coverage: Meets

VCF (Meets)

VCF provides secure baseline configurations for all major platform components, consistent with industry-accepted hardening standards. The VCF Security Baseline is a purpose-built document that builds on VCF security fundamentals to address frequently requested compliance standards, regulations, and frameworks. It is designed and validated to tailor security configurations without affecting VCF's ability to meet its design objectives. Organizations can use the VCF Security Baseline to evaluate both default and non-default configurations and to secure their environments in a compliance context.

VCF Operations includes a consolidated out-of-the-box benchmark called the VCF 9 Security Baseline, which provides a ready-to-use compliance profile for evaluating the security posture of a VCF environment. This benchmark enables automated assessment of configurations against the documented baseline, helping maintain a consistent configuration across VCF components. ISO Security Standards compliance benchmarks are also available from the VCF Operations repository as a native pack, giving organizations the ability to measure their environment against internationally recognized hardening standards. Broadcom also provides DISA Security Technical Implementation Guides (STIGs) for VCF components, including vSphere 7.0 and vSphere 8.0 STIGs, which provide detailed instructions for securing and configuring systems to meet specific security requirements.

Individual VCF components have their own security configuration guides that document hardening recommendations. The vSphere Security Configuration Guide provides best practices for securing VMware vCenter, including securing the installation, configuring access and authentication, defining roles and permissions, and enabling auditing and logging. VMware ESX host hardening covers authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. The vSphere Security Configuration Guide documents specific STIG-aligned values for the `Security.PasswordQualityControlPwquality` setting on ESX hosts, including parameters such as `minlen=15`, `maxrepeat=3`, `maxclassrepeat=4`, `difok=4`, and `enforce_for_root`. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access.

VCF Operations also provides a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules. Beyond security settings, vSphere Lifecycle Manager maintains a desired-state cluster image that defines the ESX base build, vendor add-ons, and firmware for every host in a cluster, so the software baseline stays consistent across hosts, and VCF Operations runs scheduled drift detection that flags configuration deviations from the desired state for remediation. Administrators can configure individual configuration elements under Enforce Options, enabling granular control over which baseline settings are applied and enforced across the environment. This supports reducing organizational and business risk by maintaining configuration consistency. vSphere Host Profiles provide an additional mechanism for automated and centrally managed host configuration baseline enforcement, capturing a reference host's configuration and applying it consistently across ESX hosts, covering memory, storage, networking, and other configuration aspects.

For containerized workloads, VMware Kubernetes Service (VKS) includes preconfigured security policy templates. The Baseline security template provides a set of constraints that restrict known privilege escalations while maintaining compatibility with common containerized workloads.

DISA STIGs for Supervisor and VKRs are available to guide hardening of the Supervisor control plane and individual VKS cluster releases, providing baseline security guidance at the same standard as the DISA STIGs applied to VCF infrastructure components. The VKS cluster management interface provides out-of-the-box security policy templates that mirror industry-standard Pod Security Standards profiles, including both Baseline and Restricted configurations. Custom VKS Cluster

Management Security Policy templates are also available to fine-tune individual security context parameters and support governance controls tailored to specific organizational requirements.

Pod Security Admission (PSA), enabled in VKr 1.25 and later, enforces pod security standards at the namespace level. Three policy profiles are defined: Privileged (unrestricted, for system-level workloads), Baseline (helps prevent known privilege escalations while allowing the default minimally specified pod configuration), and Restricted (heavily restricted, following pod hardening best practices). Three enforcement modes are available: enforce, warn, and audit. The `podSecurityStandard` field in the ClusterClass API encodes the intended security posture in cluster definitions, accepting these modes with specific policy versions and namespace exemptions so that baseline security configurations are applied consistently across VKS deployments. System namespaces including `kube-system`, `tkg-system`, and `vmware-system-cloudprovider` are excluded from pod security enforcement. The PSA admission controller can also be statically configured with default enforce, audit, and warn levels for unlabeled namespaces, so namespaces created without explicit labels still receive a defined security baseline. To support gradual policy adoption, audit and warn modes can be set to a stricter level such as restricted while enforce remains at baseline, giving administrators visibility into policy violations before full enforcement is applied. VCF Automation IaaS Resource Policies provide an additional enforcement point at the management layer, supporting requirements that Kubernetes clusters operate at a minimum baseline pod security level.

Kubernetes-native kernel security mechanisms provide workload-level baseline hardening options. `seccomp` restricts the Linux kernel system call surface available inside containers using BPF-based profiles, and the `RuntimeDefault` `seccomp` profile provides a strong set of security defaults while preserving workload functionality. AppArmor and SELinux provide further kernel-level restrictions through default configurations that offer foundational protections. Kubernetes default RBAC role bindings should be reviewed as part of establishing a security baseline, as defaults may grant broader access than a hardened configuration requires. Isolating each workload in its own Kubernetes namespace allows tailored security policies to be applied per workload and restricts access to namespace-scoped resources such as ConfigMaps and Secrets.

Harbor Registry, available as a standard package for VKS clusters, supports a controlled baseline for container artifacts entering the environment. Harbor provides vulnerability scanning, content trust, and policy-based replication, along with role-based access control and artifact security policies, supporting controlled management of the container image supply chain. For stand-alone virtual machines deployed in vSphere Supervisor environments, Content Libraries can distribute VM images created with current patches and required security settings that follow corporate security policies.

VMware Private AI Services (PAIS) provides PAIS-specific declarative configuration mechanisms that organizations can use to define and apply baseline settings across the AI infrastructure stack on VCF.

The primary mechanism is the `PAISConfiguration` custom resource. Private AI Services settings are declared in a YAML file compliant with the `PAISConfiguration` schema and applied with `kubectl`, giving administrators a single resource that captures observability, identity, and trust configuration for an organization namespace. Observability includes the `spec.observability.prometheusRuntime` section for Prometheus metrics collection with a configurable storage class and metrics retention period, and an `llmTraces` section for routing large language model traces to an OpenTelemetry Collector. The `PAISConfiguration` custom resource can be patched with `kubectl patch` and verified with `kubectl get paisconfiguration`, supporting baseline change control and drift detection at the AI service layer.

Certificate trust is handled through the `spec.clientTls.caBundleRefs` section, which references ConfigMaps containing CA trust bundles. Private AI Services requires HTTPS trust bundles for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and MCP servers that provide tools to models. Trust bundles can be organized per application, with periodic updates required before certificate expiration. Access scope is restricted through the `authorizedGroups` setting, which limits Private AI Services access to specified OIDC groups.

Harbor registry distribution carries baseline controls for model and image artifacts. Replication rules support configurable filters, target namespace, and trigger mode, including a manual trigger mode, so administrators can align artifact replication with organizational policy for connected and disconnected sites. The Model Gallery uses Harbor project access capabilities to restrict access to sensitive training and tuning data. Air-gapped deployments capture the self-hosted registry URL and registry login credentials as part of the activation flow.

Workload resource baselines are defined through `SupervisorNamespaceClassConfig`, which specifies per-zone CPU limits, CPU reservations, memory limits, and memory reservations for resource allocation across zones. GPU-capable VM classes can carry GPU reservations and be confined to a single zone or supervisor namespace, supporting isolation of GPU consumption to a specific tenant. A default storage policy selection in the Private AI Services quickstart defines storage placement and resources for the service database.

Deep Learning VM (DL VM) baselines are captured through VCF Automation self-service catalog items that parameterize VM class, data disk size, user password, and optional SSH public key authentication for remote access. The DL VM OVF property `config-json` accepts a base64-encoded configuration file that controls DCGM Exporter metrics visibility through `export_dcgml_to_public` and JupyterLab authentication through `enable_jupyter_auth`, giving operators a consistent surface to define DL VM hardening parameters.

Credentials supplied during Private AI Services activation, including the private container registry password and proxy password, are stored as secrets in VCF Automation rather than as plaintext configuration values, supporting credential hygiene as part of the deployment baseline.

VMware vDefend (Meets)

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs,

and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the `va-configurator.xml` file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use `scram-sha-256` as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support `scram-sha-256`, `reject`, and `cert` authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the `postgrescluster-allow-non-ssl-system-users` setting in the advanced-system-config ConfigMap within the `dsm-system` namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

Control 2.4

Back Office Data Flow Security: Ensure the confidentiality, integrity, and mutual authenticity of data flows between local or remote SWIFT infrastructure components and the back-office first hops they connect to.

SCF Controls: AST-04, AST-04.1, DCH-03.1, DCH-14, DCH-14.2, DCH-25, GOV-15, NET-02, NET-02.3, NET-04, NET-05, NET-05.2

Aggregate Coverage: Meets

VCF (Meets)

VCF provides multiple layers of access control list (ACL) mechanisms and network traffic restriction capabilities that contribute to data flow enforcement, though full ACL governance across physical and virtual infrastructure requires organizational processes and may benefit from VMware vDefend for advanced stateful firewall rule sets.

At the network infrastructure layer, VCF uses vSphere Distributed Switches to centrally manage VLAN assignments, port group policies, and traffic shaping rules across all hosts in a workload domain. Distributed switches support traffic shaping policies that limit the bandwidth of incoming traffic, helping restrict which traffic types and volumes can traverse each network segment. Distributed port groups and uplink port groups also support a Traffic Filtering and Marking Policy, where per-rule actions can be set to Allow, Drop, or Tag traffic based on defined match criteria, providing rule-based traffic enforcement at the virtual switch level. Traffic segmentation is built into VCF's architecture: management, vMotion, vSAN, and NFS traffic each run on dedicated VLANs and VMkernel ports, and the vMotion network must be distinct from the vSAN network. This separation restricts which traffic types can traverse each segment by design. Private VLANs (PVLANS) provide additional Layer 2 isolation within a single VLAN through virtual network segmentation on distributed virtual switches, limiting communication between VMs even on the same segment. Distributed switches also support VLAN-based SPAN (VSPAN) for virtual distributed port mirroring, which aids in monitoring and validating traffic flows. At the ESX host level, a built-in firewall operates on a deny-by-default basis, closing all ports except those an administrator explicitly designates as authorized, giving each host an independent network access control point.

NSX extends these capabilities with software-defined networking constructs including segments, Tier-0 and Tier-1 gateways, and Virtual Private Clouds (VPCs). NSX Tier-0 gateways can be configured with linked Tier-1 gateways to create multi-tier topologies, enabling route-based traffic restrictions between network tiers. NSX edge gateways handle north-south routing. With vDefend deployed, North-South Firewall Rules on these gateways provide traffic protection, and an NSX project's default gateway firewall and distributed firewall rules (a vDefend capability) govern the default behavior of north-south and east-west traffic for workloads in that project. VPCs are self-contained virtual network environments that provide an abstraction layer for setting up isolated virtual private cloud networks with their own topology, IP address management, and permission models, allocatable to discrete projects in a self-service consumption model. NSX Manager enforces approved authorizations for controlling the flow of management information within network devices based on information flow control policies.

NSX also provides data flow enforcement at the load balancer tier through its Access List Control (ALC) feature. The NSX load balancer compares all traffic flowing through it with ACL statements, which either drop or allow the traffic based on configured rules. This gives administrators another enforcement point for restricting network traffic to only what is authorized.

At the Consumption layer, VMware Kubernetes Service (VKS) and the Supervisor extend ACL enforcement to containerized workloads through Kubernetes NetworkPolicy resources, which function as Layer 3/4 ACLs for pod-level traffic. NetworkPolicy objects specify allowed ingress and egress traffic by pod selector, namespace selector, IP block, port, and protocol; pods not selected by any NetworkPolicy receive no restriction by default, making explicit policy deployment necessary to enforce a default-deny posture across a cluster. VKS clusters run Antrea as the default CNI plugin, which implements NetworkPolicy enforcement through the AntreaPolicy feature gate and provides per-policy and per-rule packet and byte count statistics through the NetworkPolicyStats capability, giving administrators visibility into which policies are actively restricting traffic. For VKS clusters using NSX VPC networking, NSX-backed network policies apply distributed ACLs

at the hypervisor level, extending enforcement beyond the CNI layer. The ovn-kubernetes Transparent network mode similarly supports distributed ACLs applied via Kubernetes NetworkPolicy resources. For Layer 7 traffic control within VKS clusters, the Istio service mesh standard package provides a pluggable policy layer and configuration API supporting access controls, rate limits, and quotas based on workload identity; when deployed in ambient mode with strict mutual TLS, all service-to-service traffic within the mesh is subject to authentication before authorization checks apply, restricting lateral movement to explicitly permitted paths.

For file-level and storage data flow isolation, the Supervisor uses ACLs to isolate file share access within supervisor namespaces, restricting data access between workloads running in different namespaces. vSAN file services support managing ACLs on SMB shares using the MMC tool, giving administrators granular control over which users and systems can access shared storage resources. Administrators should be aware that ACL-based file share isolation in the Supervisor carries a risk of IP spoofing, which should be addressed through complementary network controls when deploying file shares in multi-tenant environments. Argo CD deployments on the Supervisor implement network segmentation and firewall rules to control communication between Argo CD components, following the principle of restricting inter-component traffic to only what each component requires. The Harbor container registry standard package enforces role-based access control over artifact access, complementing network-layer ACLs with image-level access restrictions.

For object-level access control, VCF Automation maintains an ACL table that defines which users can access specific defined entities. System administrators with the Manage General ACL right can create, modify, and remove ACL entries through the accessControls API. Those with the View General ACL right can audit ACL assignments on specific entities. Access to runtime defined entities is controlled through rights bundles and ACL entries. This ACL mechanism works alongside role-based access controls so that rights determine what actions a user can perform while ACLs determine which objects those actions apply to.

VCF Operations for Networks supports ACL visibility through its network assurance and verification capabilities, which allow administrators to validate that ACL configurations are applied as intended across the managed environment. This includes the ability to verify ACL configurations on supported physical network equipment such as Cisco ASR routers, helping validate that physical and virtual network access controls are consistent.

For workload-level traffic enforcement with stateful firewall rules, microsegmentation, and deep packet inspection, VMware vDefend and Gateway Firewall extend VCF's networking foundation with fine-grained Layer 2-7 policy enforcement. Organizations that require ACL governance beyond what VCF provides natively should establish processes for ACL review cycles, change management for firewall rules, and regular validation of both physical and virtual network access controls.

VMware vDefend (Meets)

VMware vDefend (DFW) and Gateway Firewall enable network-level policy enforcement that restricts east-west and north-south connections, including outbound transfers to unauthorized or geographically prohibited destinations. Gateway Firewall rules can deny all inter-project communication except for infrastructure protocols such as DHCP, DNS, NTP, and ICMP, providing a mechanism to prevent sensitive workloads from transferring data to unauthorized external destinations. URL filtering and TLS inspection extend these controls by enabling policy-based blocking or inspection of outbound connections based on category, reputation, or destination.

Security Intelligence, part of the Security Services Platform (SSP), provides flow visibility and audit capabilities that support compliance documentation for data transfer governance. The Export All Flows capability exports network flow data to a CSV file for analysis and compliance documentation. Security Intelligence also exports user-defined label assignments, which associate compute entities with classification tags, to CSV, supporting audit documentation of which workloads are subject to data handling policies. Policy recommendations generated by Security Intelligence can be exported in JSON or CSV format for further analysis. SSP stores processed, enriched, and correlated flow data, with aggregated flow records updated every six hours.

Network Detection and Response (NDR) anonymizes sensitive customer information when sharing data to cloud services, providing a privacy control over what platform telemetry leaves the environment. SSP regions can also be associated with security and network policies to control policy scope across multiple geographic locations, supporting governance of which security rules apply where.

vDefend operates at the network layer and does not enforce data residency, contractual, or legal compliance obligations directly. Those obligations require complementary governance frameworks and organizational processes that extend beyond network-level enforcement.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) contributes to network architecture and data flow documentation through its network mapping capabilities, which record the topology between protected and recovery sites and provide programmatic access to that information for inclusion in formal diagrams.

PNR supports site-wide network mappings that define how networks on the protected site correspond to networks on the recovery site. These mappings can specify a different network to use during recovery plan tests, capturing the separate set of data flows that apply during DR exercises. For stretched storage environments, network mappings can be configured manually to override automatic mapping behavior between sites.

The Protection and Recovery Plug-In for the VCF Operations orchestrator provides API workflows that enumerate these mappings programmatically. The Get Network Mappings workflow lists all networks on a local site with existing mappings. The Get Network Mapping Pairs workflow retrieves the full set of mapping pairs for a specified site. The Get Test Network Mapping Pairs workflow lists test network mappings between corresponding objects across the remote site, and can query both protected and recovery sites when both are registered as local, providing a complete picture of the site-to-site network topology. An Add Test Network Mapping to Recovery Plan workflow maps a remote network to a test network within a specific recovery plan. IP customization workflows allow per-mapping customization of IP mapping rules and can remove customization rules from existing mappings.

The Plug-In also supports inventory mapping workflows that span folder mappings, network mappings, resource pool mappings, and test network mappings, providing a unified interface for enumerating all inter-site relationships.

Organizations should incorporate PNR's network mapping data and Plug-In workflow outputs into their formal network architecture diagrams to document DR topology, test network configurations, and the data flows that traverse the replication paths between sites.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to this control through role-based access controls, identity integration, and connection-level authorization mechanisms that restrict data transfer operations to authenticated and authorized entities.

DSM provides two platform-level roles: DSM Admin and DSM User. These roles govern what operations a user may perform, including provisioning databases and establishing replication relationships between instances. Users can be sourced from LDAP or LDAPS identity providers, or maintained as local accounts. When directory service integration is configured, DSM uses the configured directory service for both authentication and authorization. Administrators import LDAP users through the DSM Admin UI and assign them the DSM Admin or DSM User role. MySQL database instances can further delegate authentication to Active Directory via LDAPS. SQL Server databases support Windows Principal authentication, allowing users to authenticate with Active Directory credentials; administrators can optionally configure privileged Active Directory account credentials to activate automated Kerberos integration. Role assignment determines which users are permitted to initiate operations that involve transferring data, such as establishing replication or running migrations.

For client applications and services connecting to DSM-managed database clusters, DSM enforces certificate-based trust requirements before connections can be established. Custom trusted certificates used in DSM must comply with FIPS requirements. Database clusters issue certificates for client connectivity and monitoring connections. PostgreSQL databases support host-based authentication (HBA) configuration, with the default configuration requiring SCRAM-SHA-256 authentication for service accounts including postgres_exporter and pgadmin. When LDAPS users access PostgreSQL databases, administrators configure specific privilege grants, including database and schema-level access, before those users can perform operations. These mechanisms control which client systems and identities may establish connections and exchange data with the managed databases.

Data transfer operations between DSM database instances carry additional authorization requirements tied to role and identity verification. During PostgreSQL database migration, DSM requires TLS verification between source and target clusters. For multi-site PostgreSQL replication, users with the DSM User role must manually establish trust between primary and secondary instances before replication proceeds; users with the DSM Admin role have trust established automatically. This role distinction governs which identities may initiate and complete cross-instance data transfers. MySQL database migration to DSM requires creation of a dedicated user account with minimum privileges of BACKUP_ADMIN, REPLICATION_SLAVE, SELECT, and INSERT on the mysql schema, restricting the migration account to only those permissions the operation requires. DSM also verifies network access to the source database and validates SSL trust during MySQL replication operations.

For data forwarded to external systems, DSM requires authenticated connections before transfer proceeds. Metrics forwarding supports Mutual TLS (mTLS) authentication, configured by enabling the Client Certificate Authentication option and supplying the client certificate and private key. Forwarding to other metrics targets requires verification of server address, port, authentication type, credentials, and certificates before the forwarding connection is accepted. Webhook notification endpoints support basic authentication with Authorization User and Password credentials, bearer token authentication via Authorization header, or authorization embedded in the webhook URL for Slack-compatible endpoints. For self-service database consumption, the Consumption Operator requires a TLS certificate for secure communication with the DSM provider, and an authentication secret containing the credentials needed to connect to the DSM provider must be created and configured before the operator can connect.

DSM's authorization mechanisms primarily govern user-initiated operations and connection-level access within the database service layer. Verifying authorizations for all Technology Assets, Applications and/or Services transferring data across interconnected systems requires organizational data governance processes that extend beyond DSM's scope. Organizations must define which services are authorized to connect to DSM-managed databases, maintain records of authorized interconnections, and audit application-layer data flows independently of the platform controls DSM provides.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides application-layer transfer authorization mechanisms that verify client and service credentials before forwarding data to backend resources. For application traffic, Avi's OAuth and OpenID Connect (OIDC) integration supports the Authorization Code Grant Flow, through which the authorization server authenticates the resource owner, evaluates the client's access request, and issues access tokens only after authorization is confirmed. Clients must present a valid access token to the Avi virtual service; the Authorization Endpoint handles user-agent redirection to the authorization server, and the token endpoint validates the authorization code and authenticates the client using the client_id and client_secret before tokens are issued. This flow verifies that the requesting party holds the required authorization before any data transfer to the backend resource server is permitted.

For more granular application-layer authorization, Avi supports Authorization Policies and DataScript within OAuth/OIDC flows. These allow administrators to define rules that evaluate token claims and request attributes, granting or denying forwarding based on whether the client meets the configured authorization criteria. This provides control over which clients and services have the write permissions or privileges required to access specific application endpoints.

For administrative operations on the Controller, Avi's role-based access control enforces object-level write permissions. Write access to objects such as Virtual Services, Application Profiles, SSL/TLS Certificates, and Certificate Management Profiles is granted at the role and tenant level, so that only users with the requisite permissions can modify transfer-related configurations. TACACS+ integration supports centralized authorization by delivering attribute-value pairs from the TACACS+ server that map users to specific roles and tenants. The PASS_ADD and PASS_REPL statuses grant authorization to successfully authenticated users, while the FAIL status rejects those without the required attributes. Cisco ISE can be configured as a remote authentication and authorization backend for Avi, including with external identity sources such as OpenLDAP, providing centralized identity management for Avi administrative access. In Avi Load Balancer SaaS deployments, authorization tokens can be generated for service account authentication to the SaaS Controller.

Control 2.5A

External Transmission Data Protection: Protect the confidentiality of SWIFT-related sensitive data transmitted or stored outside of the secure zone as part of operational processes.

SCF Controls: CRY-03, CRY-04, CRY-05, CRY-05.1, DCH-01, DCH-01.2, DCH-25

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides cryptographic protection for data in transit across management, compute, storage, and inter-site networks. The architecture applies encryption at multiple layers using validated cryptographic modules and current TLS protocol versions.

VCF management and monitoring communications use TLS as the transport protocol. VCF Operations for Networks supports modern TLS protocol versions, with the ability to restrict cryptographic module usage to FIPS-validated modules by enabling FIPS mode for external connections. Telegraf, the metrics collection agent, is configured to require a modern minimum TLS version for its communication channels. When using the databus for on-premises environments, HTTPS is the recommended transport to protect data during transmission and to verify subscriber authenticity. The TLS implementation includes customizable PKI options ranging from fully automated certificate management within VCF to integration with enterprise PKI infrastructure such as Microsoft Active Directory Certificate Services. VCF Operations provides centralized certificate lifecycle management across VCF components, supporting auto-renewal for VMCA, MSCA, and OpenSSL CA, handling automated renewal, monitoring, and replacement. Machine SSL certificates can be renewed through the API for a specified period up to 730 days. Starting in vSphere 9.0, all vSphere TLS profiles are FIPS compliant, and the COMPATIBLE profile supports modern TLS cipher suites and elliptic curves. The vCenter appliance uses VMware's Boring Crypto Module version 6.0, which provides FIPS-validated cryptographic operations including AES, ECDSA, HMAC, RSA, and SHA-2 variants.

NSX, which provides networking services within VCF, uses FIPS 140-3 validated cryptographic modules by default. These modules are validated through the NIST Cryptographic Module Validation Program. NSX Manager uses FIPS 140 approved algorithms for authentication to its cryptographic module. For site-to-site connectivity, the NSX L2 VPN FIPS compliance suite uses FIPS-approved encryption with Perfect Forward Secrecy enabled and standardized Diffie-Hellman key exchange, providing transmission confidentiality for tunneled traffic. VCF Operations for Networks supports modern ECDSA and RSA signature algorithms for data source connections.

VCF Automation uses the BouncyCastle FIPS 2.0.0 cryptographic module, which is compliant with FIPS 140-3 (Certificate #4743). VCF Operations for Networks uses the BC-FJA (Bouncy Castle FIPS Java API) version 2.0.0 with FIPS 140-2 Certificate #37009. These validated modules underpin the cryptographic operations used for securing communications across the automation and operations components.

At the storage layer, vSAN provides data-in-transit (DIT) encryption that protects data as it moves between hosts within the cluster. DIT encryption is a cluster-wide setting that, when enabled, encrypts all data and metadata traffic across hosts. Forward secrecy is enforced for vSAN data-in-transit encryption, meaning that compromise of a long-term key does not expose previously encrypted traffic. DIT encryption operates independently of data-at-rest encryption and does not require external key management servers. The behavior differs by storage architecture: in vSAN Original Storage Architecture (OSA), data-at-rest encryption occurs at the target host's Local Object Manager layer, so data traverses the network before encryption, making DIT encryption strongly recommended. In vSAN Express Storage Architecture (ESA) in HCI mode, data is encrypted at the VM host before network transmission, making DIT encryption optional based on compliance requirements.

VM Encryption provides confidentiality protection across all datastore types including vSAN, iSCSI, NFS, and Fibre Channel. VM encryption is implemented on the ESX host rather than on the storage array, so it protects data both at rest and in transit to the storage backend. Disk encryption uses AES-256 as the disk encryption key.

Encrypted vSphere vMotion protects VM data during live migrations. For encrypted VMs, vMotion always uses encryption and cannot be disabled. For unencrypted VMs, encrypted vMotion offers three settings: Disabled, Opportunistic (default, uses encryption when supported), and Required. AES-NI significantly improves encryption performance for these operations.

Cross-vCenter vMotion supports encryption when source and destination use shared key providers; vCenter Crypto Manager provides an `importProvider` method to import a vSphere Native Key Provider configuration between sites. vSphere Fault Tolerance log traffic, which synchronizes VM state between primary and secondary instances, can also be encrypted to protect this synchronization data in transit.

Storage protocol support varies by type. vSAN File Service supports NFS4 Kerberos authentication with security options `krb5`, `krb5i`, and `krb5p`, where `krb5p` provides authentication plus encryption of data in transit. iSCSI uses CHAP for session authentication but does not encrypt data natively, so VM Encryption or in-guest encryption is needed for confidentiality on iSCSI networks. Fibre Channel Gen 7 supports end-to-end encryption with secure Host Bus Adapters.

HCX Network Extension services support transport encryption for data between site pairs, and this encryption is enabled by default. VCF Operations HCX tunnel encryption similarly uses transport encryption by default to protect Network Extension data and migration traffic between sites. This default-on approach reduces the risk of data being transmitted in cleartext during workload migrations or network extensions.

High-quality entropy generation on ESX hosts supports the proper functioning of security-related operations such as generating encryption keys for secure network communication. This foundational capability helps maintain the strength of cryptographic keys used across all transmission encryption functions in the platform.

VMware Kubernetes Service (VKS), which runs on vSphere Supervisor, applies TLS encryption across all control-plane communication paths. The Kubernetes API server enforces encrypted transmission within the control plane and between the control plane and its clients by default, so all API server interactions travel over TLS. Cipher suites are configurable at each component layer: the `kube-apiserver` `--tls-cipher-suites` parameter accepts a comma-separated list of permitted cipher suites; the `kube-scheduler` exposes the same `'tls-cipher-suites'` parameter to keep its API endpoint aligned; and the `kubelet` exposes `'tlsCipherSuites'` and `'tlsMinVersion'` settings in `'KubeletConfiguration'` to scope the permitted cipher algorithms and minimum protocol version at the node level. Antrea, the CNI plugin included with Supervisor, supports configurable TLS cipher suites for its own secure communication channels through the `'tlsCipherSuites'` setting, and the vSphere Cloud Provider Interface (CPI) exposes the same capability through a configurable cipher suite list.

For environments with strict cryptographic requirements, VKS supports FIPS mode through the `ClusterClass` variable `'fips.enabled'`, which controls which encryption algorithms are permitted at the node level. Tanzu Kubernetes Release references carrying the `'-fips.1'` suffix indicate that FIPS cryptographic modules are active for that node pool. The Istio service mesh package, available as a standard package on VKS clusters, ships with FIPS compliance and supports mutual TLS (mTLS) between pods within the mesh; the `'meshMTLS.minProtocolVersion'` setting controls the minimum acceptable protocol version for all inter-service traffic. Ingress-layer encryption for workloads is handled by the Contour package, which exposes `'tls.minimum-protocol-version'` and `'tls.maximum-protocol-version'` settings so operators can define a bounded range of acceptable protocol versions for inbound HTTPS traffic. The Supervisor secret injection agent automatically configures mutual TLS for its communication with the vault agent injector service using auto-generated certificates. Harbor, available as a Supervisor Service, accepts custom TLS certificates through its `'tlsCertificate.tls.crt'` and `'tlsCertificate.tls.key'` configuration fields, supporting encrypted access to the container registry for image distribution.

Defining the encryption policy for customer workload traffic, selecting cipher and FIPS configurations for environments with stricter requirements, and validating that data transmitted from customer applications and containerized workloads meets confidentiality standards are organizational data-policy decisions.

VMware Private AI Services (PAIS) provisions VKS clusters using a FIPS-enabled Kubernetes build for cryptographic compliance across both control plane and worker node communications. The VKS cluster topology version is `v1.33.1--vmware.1-fips-vkr.2` with FIPS compliance enabled, running on an Ubuntu 24.04 OS image, covering the cryptographic modules that protect data in transit within the cluster fabric.

PAIS, activated through the `PAISConfiguration` custom resource on the Supervisor, requires HTTPS for all external integrations. The `spec.clientTls.caBundleRefs` section of the `PAISConfiguration` YAML references CA trust bundles supplied as `ConfigMap` resources. Operators must configure HTTPS trust bundles for the OIDC provider, the Harbor container registry, content management systems hosting Knowledge Base data sources, MCP servers providing tools to models, and the

pgvector database. Separate trust bundles are recommended per application, with periodic updates required before certificate expiration.

The PAIS Supervisor endpoint uses HTTPS on port 6443 with certificate-based authentication. The PAIS ingress endpoint is protected by a self-signed certificate stored in the `pais-ingress-default` Kubernetes Secret. Administrators retrieve the CA certificate using `kubectl get secrets/pais-ingress-default -o yaml` and distribute it to clients that connect to the service, including Grafana when configured to scrape the PAIS Prometheus endpoint. CA trust bundles for external entity connections are managed through ConfigMaps and updated as certificate content changes.

VCF Automation Provider Management for PAIS uses a base64-encoded certificate (`TM_CERT_BASE64`) obtained by running `openssl s_client` against the VCF Automation FQDN on port 443, enabling authenticated HTTPS communication between AI catalog tooling and the PAIS environment. MCP server integrations require the MCP server's issuer certificate to be added as a CA trust bundle before connecting over HTTPS using either Streamable HTTP or Server-Sent Events transport.

Telemetry sent from PAIS to the OpenTelemetry Collector is authenticated using a Kubernetes Secret containing Authorization Bearer tokens and custom authorization headers. LLM trace transport to the collector uses HTTP/protobuf or gRPC, both protecting trace traffic in transit.

One configuration detail that auditors should verify: PAIS Prometheus TLS client authentication and certificate validation are turned off by default (the `tls-client-authentication` setting on the Prometheus endpoint). Organizations should review this setting and enable mutual TLS where their policy requires it. The underlying network transport encryption between VMs and workload domains is provided by VCF and is documented in VCF Coverage.

VMware vDefend (Contributes)

VMware vDefend contributes to transmission confidentiality through inspection, visibility, and enforcement mechanisms at the network layer, while the underlying cryptographic protection of data in transit is the responsibility of endpoint applications and infrastructure components.

TLS Inspection uses a transparent TLS proxy to intercept and analyze encrypted traffic flows traversing the environment. This allows security policy to be applied to traffic that would otherwise be opaque and supports detection of threats embedded within encrypted sessions. TLS Inspection can be deployed to provide visibility into encrypted connections while preserving end-to-end encryption for flows not subject to a decryption policy, and supports both inbound and outbound inspection profiles.

Security Intelligence, integrated within the Security Services Platform (SSP), surfaces workloads communicating over application protocols that transport data without encryption. The Security Segmentation Report identifies communication chains containing at-risk unprotected members and quantifies the number of unprotected data flows hitting default-allow rules across observed traffic. Administrators can use this reporting to identify and prioritize remediation of encryption coverage gaps, including restricting or blocking cleartext protocols.

The Security Services Platform and its component services use FIPS 140-2 and FIPS 140-3 validated cryptographic modules for their own communications. Network Detection and Response (NDR) Sensors connect to the SSP using mutual TLS authentication (mTLS), with a dedicated certificate for each sensor signed by an intermediate certificate authority on the SSP. The SSP can be configured to forward log messages to a syslog server over TLS, and Malware Prevention Service remote logging likewise uses TLS to transmit log data to a remote log server. NDR also supports SSL verification for event logs sent over HTTPS. When NDR shares data to the cloud, it anonymizes sensitive customer information before transmission.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides cryptographic protection for data transmitted during disaster recovery operations, covering management communications and replication data flows.

All communications between the PNR server and VMware vCenter (vCenter) instances take place over TLS connections. PNR requires an SSL/TLS certificate, with x509v3 Extended Key Usage indicating TLS Web Server Authentication, as the endpoint certificate for all TLS connections to the PNR server. PNR defaults to the current TLS version for all communication endpoints.

and supports administrative configuration of the minimum acceptable protocol version. Administrators configure the minimum TLS protocol version by editing the `tls_minimum_protocol_version` parameter in the `envoy-proxy-config.json` file; when changing the minimum version, the update must be applied consistently across all occurrences in the system. PNR uses TLS certificates and private keys to protect network communication and authenticate with other servers.

For replication data, vSphere Replication encrypts replication traffic in transit for both new and existing replications. Network encryption is mandatory when using vSphere Replication 9.0.3 and later and is enabled by default. PNR also supports configuring network encryption of replication traffic as an option for replication scenarios where mandatory encryption does not apply automatically. PNR supports protection and recovery of encrypted virtual machines through both array-based and vSphere Replication protection groups, allowing VM disk encryption to persist through the replication process. Recovery of encrypted virtual machines requires that the protected and recovery sites share a common Key Management Server (KMS), or that the KMS clusters at both sites use common encryption keys, to maintain key availability after failover.

Defining the encryption policy for environments with stricter requirements and validating that workload traffic running on protected virtual machines meets confidentiality standards are organizational data-policy decisions.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) applies TLS-based encryption across multiple communication paths, covering database client connections, management interfaces, service-to-service communication, and data migration traffic. Starting with DSM, the platform enforces FIPS 140-3 compliant cryptographic standards and validates certificates during upload, rejecting unsupported algorithms such as Ed25519.

For database client connections, DSM enforces a minimum TLS protocol version across all supported database engines. PostgreSQL instances enforce a configurable minimum TLS protocol version via the `ssl_min_protocol_version` setting and support certificate-based authentication with CA verification. PostgreSQL replication connections support SSL/TLS encryption with a configurable `sslmode` parameter to secure data in transit between source and target databases, and DSM validates SSL trust before establishing replication. MySQL locks TLS protocol enforcement at the platform level so users cannot weaken it. MySQL has `require_secure_transport` set to ON by default, which requires all client connections to use encrypted transport. MySQL supports FIPS mode via the `ssl_fips_mode` setting. DSM adds SQL Server as a supported database engine; SQL Server clusters use TLS to encrypt client connections, require a minimum TLS version for DSM operator management, and expose the `network.tlsProtocols` engine setting to configure the set of allowed TLS versions.

For management and service-to-service communication, the DSM Provider exposes an HTTPS endpoint. The Consumption Operator requires a TLS certificate for secure communication with the DSM provider. In network-isolated deployments, Consumption Operator image transfers to a private registry support optional TLS certificate authentication. Metrics forwarding from DSM to VCF Operations supports mutual TLS (mTLS) authentication, requiring a client certificate and private key. DSM SMTP settings include an Auto TLS option that establishes a secure connection to the SMTP server.

DSM provides certificate management capabilities to support the TLS infrastructure. Custom certificates are validated for FIPS 140-3 compliance at upload time; accepted key types are ECDSA P-256, ECDSA P-384, and RSA with a minimum key size of 2048 bits, and Ed25519 keys are rejected as non-compliant. Trusted root certificates added through the DSM UI must comply with FIPS requirements.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides native, configurable cryptographic mechanisms to protect the confidentiality of data in transit at both the application data plane and the Controller management plane.

Each virtual service in Avi is associated with an SSL/TLS Profile, which defines the accepted protocol versions, cipher suites, and their priority order. SSL/TLS Profiles are managed at Templates > Security > SSL/TLS Profile in the Controller UI. Predefined profile templates are available, including a System-Standard template, and administrators can create custom profiles to enforce the cipher suites and protocol versions appropriate for their environment. Elliptic Curve (EC) cryptography is available for virtual services and supports Perfect Forward Secrecy with less computational overhead than RSA-based key exchange. TLS persistence state exchanged between Service Engines when a client reconnects is carried in encrypted form.

At the L4 proxy level, the Default-TLS protocol parser can be associated with a virtual service to inspect TLS handshake data using DataScript, supporting selective offload and re-encryption scenarios.

In Kubernetes environments, the Avi Kubernetes Operator (AKO) supports a PKIProfile custom resource definition that enables certificate-based authentication and encryption for backend service communication. The System-Standard SSL Profile can be applied through the RouteBackendExtension CRD to enable SSL/TLS re-encryption for traffic to backend servers, providing modern cipher suites for Kubernetes ingress and routing scenarios. In VCF environments, the Avi load balancer uses secrets to handle encrypted HTTPS traffic, configured through the VCF IaaS Service Console.

When FIPS mode is enabled on the Avi Controller cluster, all cryptographic operations across the Controller and Service Engines are restricted to FIPS 140-3 approved algorithms. Avi uses the OpenSSL FIPS Provider version 3.1.2 in this mode, which has been validated at FIPS 140-3 Security Level 1 and awarded Certificate #4985 by CMVP. Enabling FIPS mode is a cluster-level configuration that applies uniformly to all cryptographic material handled by the platform. FIPS mode does not support SSL Client Hello events in Avi DataScript, and post-quantum cryptographic capabilities are not available in FIPS mode.

The Avi Controller and Service Engines use SSH for secure management communication. The SE_SECURE_CHANNEL designation classifies traffic between the Controller and Service Engines to maintain a dedicated secure communication channel. Avi also integrates with Let's Encrypt via the ACME protocol to automate certificate issuance and renewal for virtual services, and with hardware security modules such as the Thales Luna HSM for external key management. Remote server file transfer supports Secure Copy Protocol (SCP) and Secure File Transfer Protocol (SFTP). For deployments requiring hardware acceleration, Avi Service Engine integrates with Intel QuickAssist Technology to offload bulk cryptographic operations following SSL/TLS handshake completion.

Avi DataScript exposes cryptographic functions for application-layer use cases. The `avi.crypto.encrypt()` function encrypts data using a caller-provided key, optional initialization vector, and algorithm parameter. The HTTP Cookie Encryption Gateway uses these functions to encrypt cookie values in HTTP responses, protecting session state carried between client and server. The `avi.utils.rand_bytes` function generates cryptographically secure random bytes for token and nonce generation.

Defining which application traffic requires encryption and configuring the virtual service profiles to apply protection at the appropriate boundary are organizational data-policy decisions.

Control 2.6

Operator Session Confidentiality and Integrity

SCF Controls: AST-27, CFG-02.5, CRY-01, CRY-03, CRY-04, IAC-20.4, NET-01, NET-06.3

Aggregate Coverage: Meets

VCF (Meets)

VCF provides cryptographic protection for data in transit across management, compute, storage, and inter-site networks. The architecture applies encryption at multiple layers using validated cryptographic modules and current TLS protocol versions.

VCF management and monitoring communications use TLS as the transport protocol. VCF Operations for Networks supports modern TLS protocol versions, with the ability to restrict cryptographic module usage to FIPS-validated modules by enabling FIPS mode for external connections. Telegraf, the metrics collection agent, is configured to require a modern minimum TLS version for its communication channels. When using the databus for on-premises environments, HTTPS is the recommended transport to protect data during transmission and to verify subscriber authenticity. The TLS implementation includes customizable PKI options ranging from fully automated certificate management within VCF to integration with enterprise PKI infrastructure such as Microsoft Active Directory Certificate Services. VCF Operations provides centralized certificate lifecycle management across VCF components, supporting auto-renewal for VMCA, MSCA, and OpenSSL CA, handling automated renewal, monitoring, and replacement. Machine SSL certificates can be renewed through the API for a specified period up to 730 days. Starting in vSphere 9.0, all vSphere TLS profiles are FIPS compliant, and the COMPATIBLE profile supports modern TLS cipher suites and elliptic curves. The vCenter appliance uses VMware's Boring Crypto Module version 6.0, which provides FIPS-validated cryptographic operations including AES, ECDSA, HMAC, RSA, and SHA-2 variants.

NSX, which provides networking services within VCF, uses FIPS 140-3 validated cryptographic modules by default. These modules are validated through the NIST Cryptographic Module Validation Program. NSX Manager uses FIPS 140 approved algorithms for authentication to its cryptographic module. For site-to-site connectivity, the NSX L2 VPN FIPS compliance suite uses FIPS-approved encryption with Perfect Forward Secrecy enabled and standardized Diffie-Hellman key exchange, providing transmission confidentiality for tunneled traffic. VCF Operations for Networks supports modern ECDSA and RSA signature algorithms for data source connections.

VCF Automation uses the BouncyCastle FIPS 2.0.0 cryptographic module, which is compliant with FIPS 140-3 (Certificate #4743). VCF Operations for Networks uses the BC-FJA (Bouncy Castle FIPS Java API) version 2.0.0 with FIPS 140-2 Certificate #37009. These validated modules underpin the cryptographic operations used for securing communications across the automation and operations components.

At the storage layer, vSAN provides data-in-transit (DIT) encryption that protects data as it moves between hosts within the cluster. DIT encryption is a cluster-wide setting that, when enabled, encrypts all data and metadata traffic across hosts. Forward secrecy is enforced for vSAN data-in-transit encryption, meaning that compromise of a long-term key does not expose previously encrypted traffic. DIT encryption operates independently of data-at-rest encryption and does not require external key management servers. The behavior differs by storage architecture: in vSAN Original Storage Architecture (OSA), data-at-rest encryption occurs at the target host's Local Object Manager layer, so data traverses the network before encryption, making DIT encryption strongly recommended. In vSAN Express Storage Architecture (ESA) in HCI mode, data is encrypted at the VM host before network transmission, making DIT encryption optional based on compliance requirements.

VM Encryption provides confidentiality protection across all datastore types including vSAN, iSCSI, NFS, and Fibre Channel. VM encryption is implemented on the ESX host rather than on the storage array, so it protects data both at rest and in transit to the storage backend. Disk encryption uses AES-256 as the disk encryption key.

Encrypted vSphere vMotion protects VM data during live migrations. For encrypted VMs, vMotion always uses encryption and cannot be disabled. For unencrypted VMs, encrypted vMotion offers three settings: Disabled, Opportunistic (default, uses encryption when supported), and Required. AES-NI significantly improves encryption performance for these operations. Cross-vCenter vMotion supports encryption when source and destination use shared key providers; vCenter Crypto Manager provides an importProvider method to import a vSphere Native Key Provider configuration between sites. vSphere Fault

Tolerance log traffic, which synchronizes VM state between primary and secondary instances, can also be encrypted to protect this synchronization data in transit.

Storage protocol support varies by type. vSAN File Service supports NFS4 Kerberos authentication with security options krb5, krb5i, and krb5p, where krb5p provides authentication plus encryption of data in transit. iSCSI uses CHAP for session authentication but does not encrypt data natively, so VM Encryption or in-guest encryption is needed for confidentiality on iSCSI networks. Fibre Channel Gen 7 supports end-to-end encryption with secure Host Bus Adapters.

HCX Network Extension services support transport encryption for data between site pairs, and this encryption is enabled by default. VCF Operations HCX tunnel encryption similarly uses transport encryption by default to protect Network Extension data and migration traffic between sites. This default-on approach reduces the risk of data being transmitted in cleartext during workload migrations or network extensions.

High-quality entropy generation on ESX hosts supports the proper functioning of security-related operations such as generating encryption keys for secure network communication. This foundational capability helps maintain the strength of cryptographic keys used across all transmission encryption functions in the platform.

VMware Kubernetes Service (VKS), which runs on vSphere Supervisor, applies TLS encryption across all control-plane communication paths. The Kubernetes API server enforces encrypted transmission within the control plane and between the control plane and its clients by default, so all API server interactions travel over TLS. Cipher suites are configurable at each component layer: the kube-apiserver `--tls-cipher-suites` parameter accepts a comma-separated list of permitted cipher suites; the kube-scheduler exposes the same `tls-cipher-suites` parameter to keep its API endpoint aligned; and the kubelet exposes `tlsCipherSuites` and `tlsMinVersion` settings in `KubeletConfiguration` to scope the permitted cipher algorithms and minimum protocol version at the node level. Antrea, the CNI plugin included with Supervisor, supports configurable TLS cipher suites for its own secure communication channels through the `tlsCipherSuites` setting, and the vSphere Cloud Provider Interface (CPI) exposes the same capability through a configurable cipher suite list.

For environments with strict cryptographic requirements, VKS supports FIPS mode through the ClusterClass variable `fips.enabled`, which controls which encryption algorithms are permitted at the node level. TanzuKubernetesRelease references carrying the `-fips.1` suffix indicate that FIPS cryptographic modules are active for that node pool. The Istio service mesh package, available as a standard package on VKS clusters, ships with FIPS compliance and supports mutual TLS (mTLS) between pods within the mesh; the `meshMTLS.minProtocolVersion` setting controls the minimum acceptable protocol version for all inter-service traffic. Ingress-layer encryption for workloads is handled by the Contour package, which exposes `tls.minimum-protocol-version` and `tls.maximum-protocol-version` settings so operators can define a bounded range of acceptable protocol versions for inbound HTTPS traffic. The Supervisor secret injection agent automatically configures mutual TLS for its communication with the vault agent injector service using auto-generated certificates. Harbor, available as a Supervisor Service, accepts custom TLS certificates through its `tlsCertificate.tls.crt` and `tlsCertificate.tls.key` configuration fields, supporting encrypted access to the container registry for image distribution.

Defining the encryption policy for customer workload traffic, selecting cipher and FIPS configurations for environments with stricter requirements, and validating that data transmitted from customer applications and containerized workloads meets confidentiality standards are organizational data-policy decisions.

VMware Private AI Services (PAIS) provisions VKS clusters using a FIPS-enabled Kubernetes build for cryptographic compliance across both control plane and worker node communications. The VKS cluster topology version is v1.33.1--vmware.1-fips-vkr.2 with FIPS compliance enabled, running on an Ubuntu 24.04 OS image, covering the cryptographic modules that protect data in transit within the cluster fabric.

PAIS, activated through the PAISConfiguration custom resource on the Supervisor, requires HTTPS for all external integrations. The `spec.clientTls.caBundleRefs` section of the PAISConfiguration YAML references CA trust bundles supplied as ConfigMap resources. Operators must configure HTTPS trust bundles for the OIDC provider, the Harbor container registry, content management systems hosting Knowledge Base data sources, MCP servers providing tools to models, and the pgvector database. Separate trust bundles are recommended per application, with periodic updates required before certificate expiration.

The PAIS Supervisor endpoint uses HTTPS on port 6443 with certificate-based authentication. The PAIS ingress endpoint is protected by a self-signed certificate stored in the `pais-ingress-default` Kubernetes Secret. Administrators retrieve the CA certificate using `kubectl get secrets/pais-ingress-default -o yaml` and distribute it to clients that connect to the service, including Grafana when configured to scrape the PAIS Prometheus endpoint. CA trust bundles for external entity connections are managed through ConfigMaps and updated as certificate content changes.

VCF Automation Provider Management for PAIS uses a base64-encoded certificate (`TM_CERT_BASE64`) obtained by running `openssl s_client` against the VCF Automation FQDN on port 443, enabling authenticated HTTPS communication between AI catalog tooling and the PAIS environment. MCP server integrations require the MCP server's issuer certificate to be added as a CA trust bundle before connecting over HTTPS using either Streamable HTTP or Server-Sent Events transport.

Telemetry sent from PAIS to the OpenTelemetry Collector is authenticated using a Kubernetes Secret containing Authorization Bearer tokens and custom authorization headers. LLM trace transport to the collector uses HTTP/protobuf or gRPC, both protecting trace traffic in transit.

One configuration detail that auditors should verify: PAIS Prometheus TLS client authentication and certificate validation are turned off by default (the `tls-client-authentication` setting on the Prometheus endpoint). Organizations should review this setting and enable mutual TLS where their policy requires it. The underlying network transport encryption between VMs and workload domains is provided by VCF and is documented in VCF Coverage.

VMware vDefend (Meets)

VMware vDefend contributes to transmission confidentiality through inspection, visibility, and enforcement mechanisms at the network layer, while the underlying cryptographic protection of data in transit is the responsibility of endpoint applications and infrastructure components.

TLS Inspection uses a transparent TLS proxy to intercept and analyze encrypted traffic flows traversing the environment. This allows security policy to be applied to traffic that would otherwise be opaque and supports detection of threats embedded within encrypted sessions. TLS Inspection can be deployed to provide visibility into encrypted connections while preserving end-to-end encryption for flows not subject to a decryption policy, and supports both inbound and outbound inspection profiles.

Security Intelligence, integrated within the Security Services Platform (SSP), surfaces workloads communicating over application protocols that transport data without encryption. The Security Segmentation Report identifies communication chains containing at-risk unprotected members and quantifies the number of unprotected data flows hitting default-allow rules across observed traffic. Administrators can use this reporting to identify and prioritize remediation of encryption coverage gaps, including restricting or blocking cleartext protocols.

The Security Services Platform and its component services use FIPS 140-2 and FIPS 140-3 validated cryptographic modules for their own communications. Network Detection and Response (NDR) Sensors connect to the SSP using mutual TLS authentication (mTLS), with a dedicated certificate for each sensor signed by an intermediate certificate authority on the SSP. The SSP can be configured to forward log messages to a syslog server over TLS, and Malware Prevention Service remote logging likewise uses TLS to transmit log data to a remote log server. NDR also supports SSL verification for event logs sent over HTTPS. When NDR shares data to the cloud, it anonymizes sensitive customer information before transmission.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides cryptographic protection for data transmitted during disaster recovery operations, covering management communications and replication data flows.

All communications between the PNR server and VMware vCenter (vCenter) instances take place over TLS connections. PNR requires an SSL/TLS certificate, with x509v3 Extended Key Usage indicating TLS Web Server Authentication, as the endpoint certificate for all TLS connections to the PNR server. PNR defaults to the current TLS version for all communication endpoints and supports administrative configuration of the minimum acceptable protocol version. Administrators configure the minimum TLS protocol version by editing the `tls_minimum_protocol_version` parameter in the `envoy-proxy-config.json` file; when

changing the minimum version, the update must be applied consistently across all occurrences in the system. PNR uses TLS certificates and private keys to protect network communication and authenticate with other servers.

For replication data, vSphere Replication encrypts replication traffic in transit for both new and existing replications. Network encryption is mandatory when using vSphere Replication 9.0.3 and later and is enabled by default. PNR also supports configuring network encryption of replication traffic as an option for replication scenarios where mandatory encryption does not apply automatically. PNR supports protection and recovery of encrypted virtual machines through both array-based and vSphere Replication protection groups, allowing VM disk encryption to persist through the replication process. Recovery of encrypted virtual machines requires that the protected and recovery sites share a common Key Management Server (KMS), or that the KMS clusters at both sites use common encryption keys, to maintain key availability after failover.

Defining the encryption policy for environments with stricter requirements and validating that workload traffic running on protected virtual machines meets confidentiality standards are organizational data-policy decisions.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) applies TLS-based encryption across multiple communication paths, covering database client connections, management interfaces, service-to-service communication, and data migration traffic. Starting with DSM, the platform enforces FIPS 140-3 compliant cryptographic standards and validates certificates during upload, rejecting unsupported algorithms such as Ed25519.

For database client connections, DSM enforces a minimum TLS protocol version across all supported database engines. PostgreSQL instances enforce a configurable minimum TLS protocol version via the ``ssl_min_protocol_version`` setting and support certificate-based authentication with CA verification. PostgreSQL replication connections support SSL/TLS encryption with a configurable ``sslmode`` parameter to secure data in transit between source and target databases, and DSM validates SSL trust before establishing replication. MySQL locks TLS protocol enforcement at the platform level so users cannot weaken it. MySQL has ``require_secure_transport`` set to ON by default, which requires all client connections to use encrypted transport. MySQL supports FIPS mode via the ``ssl_fips_mode`` setting. DSM adds SQL Server as a supported database engine; SQL Server clusters use TLS to encrypt client connections, require a minimum TLS version for DSM operator management, and expose the ``network.tlsProtocols`` engine setting to configure the set of allowed TLS versions.

For management and service-to-service communication, the DSM Provider exposes an HTTPS endpoint. The Consumption Operator requires a TLS certificate for secure communication with the DSM provider. In network-isolated deployments, Consumption Operator image transfers to a private registry support optional TLS certificate authentication. Metrics forwarding from DSM to VCF Operations supports mutual TLS (mTLS) authentication, requiring a client certificate and private key. DSM SMTP settings include an Auto TLS option that establishes a secure connection to the SMTP server.

DSM provides certificate management capabilities to support the TLS infrastructure. Custom certificates are validated for FIPS 140-3 compliance at upload time; accepted key types are ECDSA P-256, ECDSA P-384, and RSA with a minimum key size of 2048 bits, and Ed25519 keys are rejected as non-compliant. Trusted root certificates added through the DSM UI must comply with FIPS requirements.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides native, configurable cryptographic mechanisms to protect the confidentiality of data in transit at both the application data plane and the Controller management plane.

Each virtual service in Avi is associated with an SSL/TLS Profile, which defines the accepted protocol versions, cipher suites, and their priority order. SSL/TLS Profiles are managed at Templates > Security > SSL/TLS Profile in the Controller UI. Predefined profile templates are available, including a System-Standard template, and administrators can create custom profiles to enforce the cipher suites and protocol versions appropriate for their environment. Elliptic Curve (EC) cryptography is available for virtual services and supports Perfect Forward Secrecy with less computational overhead than RSA-based key exchange. TLS persistence state exchanged between Service Engines when a client reconnects is carried in encrypted form. At the L4 proxy level, the Default-TLS protocol parser can be associated with a virtual service to inspect TLS handshake data using DataScript, supporting selective offload and re-encryption scenarios.

In Kubernetes environments, the Avi Kubernetes Operator (AKO) supports a PKIProfile custom resource definition that enables certificate-based authentication and encryption for backend service communication. The System-Standard SSL Profile can be applied through the RouteBackendExtension CRD to enable SSL/TLS re-encryption for traffic to backend servers, providing modern cipher suites for Kubernetes ingress and routing scenarios. In VCF environments, the Avi load balancer uses secrets to handle encrypted HTTPS traffic, configured through the VCF IaaS Service Console.

When FIPS mode is enabled on the Avi Controller cluster, all cryptographic operations across the Controller and Service Engines are restricted to FIPS 140-3 approved algorithms. Avi uses the OpenSSL FIPS Provider version 3.1.2 in this mode, which has been validated at FIPS 140-3 Security Level 1 and awarded Certificate #4985 by CMVP. Enabling FIPS mode is a cluster-level configuration that applies uniformly to all cryptographic material handled by the platform. FIPS mode does not support SSL Client Hello events in Avi DataScript, and post-quantum cryptographic capabilities are not available in FIPS mode.

The Avi Controller and Service Engines use SSH for secure management communication. The SE_SECURE_CHANNEL designation classifies traffic between the Controller and Service Engines to maintain a dedicated secure communication channel. Avi also integrates with Let's Encrypt via the ACME protocol to automate certificate issuance and renewal for virtual services, and with hardware security modules such as the Thales Luna HSM for external key management. Remote server file transfer supports Secure Copy Protocol (SCP) and Secure File Transfer Protocol (SFTP). For deployments requiring hardware acceleration, Avi Service Engine integrates with Intel QuickAssist Technology to offload bulk cryptographic operations following SSL/TLS handshake completion.

Avi DataScript exposes cryptographic functions for application-layer use cases. The `avi.crypto.encrypt()` function encrypts data using a caller-provided key, optional initialization vector, and algorithm parameter. The HTTP Cookie Encryption Gateway uses these functions to encrypt cookie values in HTTP responses, protecting session state carried between client and server. The `avi.utils.rand_bytes` function generates cryptographically secure random bytes for token and nonce generation.

Defining which application traffic requires encryption and configuring the virtual service profiles to apply protection at the appropriate boundary are organizational data-policy decisions.

Control 2.7

Vulnerability Scanning

SCF Controls: VPM-01, VPM-01.1, VPM-02, VPM-04, VPM-06, VPM-06.1, VPM-06.2, VPM-06.4

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several built-in capabilities that support routine vulnerability scanning and configuration error detection across the infrastructure stack, though a complete vulnerability management program requires integration with dedicated scanning tools for guest operating systems and applications.

VCF Operations includes a diagnostics engine that automatically detects known issues and critical vulnerabilities within the VCF software stack. The engine scans the platform against VMware best practices, logs, and properties to identify diagnostic findings that match known issues, providing detailed descriptions, root cause insights, and actionable remediation steps. The Diagnostic Findings feature provides a consolidated view of known product issues, VMware Security Advisory (VMSA)-based security exposures, and best-practice recommendations across the environment. The Findings Catalog displays the complete list of diagnostic signatures checked at any given time, allowing administrators to see exactly what conditions are being evaluated. Administrators can manage diagnostics parameters through a JSON solution configuration file to customize which rules are active, adjust defaults, and control how findings are handled. These diagnostics build on the capabilities of several legacy tools and operational data to provide integrated issue detection and remediation.

VCF Operations also supports advanced query capabilities that can identify virtual machines running vulnerable operating systems, including specific detection for end-of-life platforms such as Microsoft Windows Server 2003, Microsoft Windows Server 2008, Red Hat Enterprise Linux 5 and 6, and SUSE Linux Enterprise 10. These queries can group results by VLAN for security assessment and compliance monitoring purposes.

The Security Operations dashboard consolidates user and infrastructure security elements into a single view, helping administrators identify areas that require attention. This dashboard highlights security-relevant findings across the VCF environment, providing a centralized starting point for security posture review.

For configuration error detection, VCF Operations monitors configuration errors generated from infrastructure components such as NSX networking, grouping findings by hostname. Alert definitions can be created to monitor virtual machines and hosts with custom symptom parameters, enabling identification of configuration problems before users encounter them. The Configuration Drifts feature in VCF Operations provides proactive monitoring of configuration changes across vCenter instances and vSphere clusters, comparing current values against configuration templates to identify drift. vSphere Configuration Profiles must be enabled on clusters to view drift status. Configuration drift detection compares each vCenter instance's current configuration against the defined template values, and the Configuration Drift dashboard allows administrators to view and monitor drift statuses across the environment.

For patch compliance scanning, vSphere Lifecycle Manager manages all hosts in a cluster collectively with a single image and tracks the current state of each host against the desired cluster image specification, reporting compliance status. The compliance check capability compares the current image on a host against the desired image and reports compatibility status. PowerCLI provides cmdlets for scanning virtual machines and hosts against defined baselines, including the Test-Compliance command to scan entities against downloaded patches and identify which hosts or components are missing security updates. Dynamic baselines update automatically based on specified criteria each time new patches are downloaded, allowing ongoing comparison of system state against current patch levels. The vCenter appliance can also be configured to perform automatic checks for available patches from a configured repository URL, enabling timely awareness of patch availability for the management plane itself. This automatic checking is configured through the vCenter Management Interface (the Check-for-updates-automatically setting) and supports proxy server configuration for environments without direct repository access.

VMware releases security advisories (VMSAs) for critical known vulnerabilities with step-by-step remediation instructions. VCF Operations Diagnostic Findings provides a consolidated view of VMSA-based security exposures alongside best-practice recommendations, connecting advisory information directly to the operational environment.

The DISA STIG Viewer tool provides automated checking of system configurations against STIG requirements, helping identify security vulnerabilities and configuration deviations for environments that follow DISA hardening guidance. This offers a structured approach to configuration compliance scanning against industry-standard best practices.

While VCF provides vulnerability detection and compliance scanning for its own infrastructure stack, scanning of guest operating systems and applications running on VCF requires integration with third-party vulnerability scanning tools. VCF's REST APIs and PowerCLI support enable integration with external scanners and security information and event management platforms to extend scanning coverage beyond the infrastructure layer.

VMware vDefend (Contributes)

VMware vDefend contributes to vulnerability awareness through Security Services Platform analytics and IDS/IPS threat detection, though it does not perform host-based or authenticated application-layer vulnerability scanning.

The Security Services Platform generates Security Segmentation Reports and Blast Radius Reports as part of the vDefend Security Assessment workflow. The Security Segmentation Report assesses security posture by analyzing network traffic over a configurable time range, identifying workloads running obsolete operating systems and using risky protocols, and providing specific improvement recommendations. Blast Radius Reports break down at-risk workloads, communication chains, and network flows to support protection planning. The Security Services Platform also provides an application monitoring view that displays information about running applications and identifies potential security risks, enabling assessment and remediation planning.

The IDS/IPS subsystem contributes vulnerability-specific context by detecting exploitation attempts against known vulnerabilities. IDS/IPS event monitoring records Common Vulnerability Scoring System (CVSS) scores and CVE reference information for vulnerabilities targeted by active exploits. Administrators can search the signature library by specific CVE IDs to assess whether detection coverage is in place for known vulnerabilities. The Security Services Platform provides IDS/IPS performance metrics to monitor detection readiness across the environment.

Because vDefend operates at the network layer, dedicated host-based and authenticated application-layer scanning tools are required to fully satisfy this control. Coverage remains at Contributes.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to the vulnerability remediation process primarily through its software update mechanisms and compliance tracking features. DSM does not provide vulnerability scanning or external CVE tracking; those functions require organizational processes and tools outside the platform.

DSM supports software remediation through update bundles that apply patches to DSM appliances and managed database versions. The DSM controller manages component dependencies through status monitoring and automated remediation, helping maintain a consistent update baseline across the environment. Database engines, including PostgreSQL and MySQL, can be upgraded to new minor and major versions through the DSM interface; upgrade operations during the maintenance window may include CVE fixes, bug fixes, and performance improvements, allowing operators to remediate known vulnerabilities by updating to patched releases.

To support issue identification, DSM surfaces database alerts with mitigation suggestions so that operators can resolve operational issues without disrupting database services. Operators should verify VM status and infrastructure health when resolving alerts to identify underlying causes. The platform can generate and download log bundles that aggregate relevant logs from database VMs to support faster diagnosis when a service faces a problem. Operators can also review active VMware vCenter infrastructure alarms through DSM troubleshooting guidance and resolve the underlying problems causing those alarms.

Data service policies in DSM include a compliance tab that tracks whether deployed databases conform to the policy. When a data service policy is deleted, the associated services are marked as non-compliant, providing visibility into configuration drift. These policies can be enforced across different tenants, supporting consistent configuration standards across the environment.

DSM handles the patching and software update aspects of vulnerability remediation within its own scope and provides monitoring and compliance visibility. The broader requirements of the control, including external vulnerability scanning to identify CVEs in database software, a centralized vulnerability tracking system for prioritization and assignment, and defined organizational remediation timelines and escalation procedures, must be addressed through organizational processes and tools that operate alongside DSM.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) supports vulnerability detection for web applications through its Web Application Firewall (WAF) Dynamic Application Security Testing (DAST) integration. The Avi SDK includes a DAST vulnerability scanner script, delivered in the DAST directory on the Avi Controller, which integrates with OWASP ZAP Attack Proxy and Qualys Web App Scanning to assess web application vulnerabilities and drive virtual patching. When a DAST scan identifies vulnerabilities, the `avi-iwaf-vpatch.py` tool automates virtual patch creation by generating Positive Security location rules for each vulnerable URL and Positive Security rules for each supported issue type. This allows the WAF to block requests targeting known vulnerable application paths while underlying code remediation proceeds.

In 9.1, the Avi Cloud Console adds an Application Rules service that provides rules specifically designed to block attacks on known application vulnerabilities, many correlated with CVE identifiers, and automatically updates those rules on the Avi Controller. This complements DAST-driven virtual patching with a continuously refreshed, CVE-mapped rule set covering known application vulnerability classes.

The DAST integration has acknowledged limitations: it does not detect all cookie-related security issues, and some flagged vulnerabilities may require manual remediation rather than automated virtual patching. Organizations should validate scan results and supplement Avi's application-layer DAST capability with platform-level scanning of the Avi Controller infrastructure through VCF platform vulnerability management tooling.

Avi also supports configuration error detection through its inventory fault monitoring system. The Controller's `inventoryfaultconfig` setting allows independent tracking of license faults, migration faults, backup scheduler faults, SSL profile faults, and deprecated API version faults, with alert generation on configured conditions. This supports detection of misconfigured components before they affect application delivery.

The Avi Application Security Report consolidates security findings for a selected virtual service. The report includes ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking IP addresses, and trend summaries showing total and flagged requests. Reports can be generated through the Avi UI or the Avi Controller CLI and downloaded in PDF format, supporting auditor review and periodic vulnerability assessment documentation workflows.

Organizations running Avi on VCF should also lock the Avi Controller Linux OS to a specific version to reduce false-positive CVE scanner findings that arise from inactive OS package versions present on the system but no longer in active use.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 2.8

Critical Activity Outsourcing: Ensure the protection of the local SWIFT infrastructure from risks exposed by the outsourcing of critical activities.

SCF Controls: BCD-02, PRM-05, PRM-06, TPM-01, TPM-02, TPM-03, TPM-03.1, TPM-03.2, TPM-03.3, TPM-04, TPM-04.1, TPM-04.3, TPM-04.4, TPM-05, TPM-05.2, TPM-05.4, TPM-05.5, TPM-05.6, TPM-05.7, TPM-08, TPM-09, TPM-10

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several capabilities that support the identification and documentation of critical technology assets, applications, services, and data within a virtualized infrastructure.

VMware vCenter maintains a real-time inventory of all managed objects, including hosts, VMs, clusters, datastores, and networks, and supports linking multiple vCenter instances for centralized inventory management. The vCenter inventory tracks multiple instances of ClusterComputeResource, ComputeResource, Datacenter, Datastore, DistributedVirtualSwitch, and Folder objects, providing a structured view of all infrastructure components. VCF Operations can export lists of resources, such as powered-off virtual machines, to CSV files for offline documentation and review.

VCF Operations includes a Business Applications feature that allows administrators to group related infrastructure objects and assign business criticality classifications. Each Business Application can be tagged with a criticality level of Critical, Medium, or Low, with Medium as the default. The Object Summary card within VCF Operations displays details including the application's source, application tag, environment, and business criticality rating. This classification capability allows infrastructure teams to maintain a structured view of which applications and their underlying resources are most important to the organization.

VCF Operations Service Discovery automatically detects running services across the environment. Service Discovery displays a list of all supported services that can be discovered and those currently discovered on VMs once configured. It also discovers performance metrics for individual service objects and service type objects, maintaining a catalog of known services and their relationships to underlying infrastructure. This automated discovery reduces manual effort in maintaining an accurate asset inventory.

VCF Operations also provides alert definitions with configurable Impact and Criticality metadata. The Impact setting can be configured to values such as Risk to indicate potential problems, while the Criticality setting can be set to values like Immediate for proper alert prioritization. Alert notifications can be filtered by impact category and criticality level, helping teams classify infrastructure resources by their importance and focus attention on the most important infrastructure components. VCF Operations Insights data tracks resource capacity and can notify project owners of changes affecting their assets.

VCF Automation provides complementary asset identification capabilities through its resource discovery and tagging system. The discovery process automatically identifies machines, storage volumes, networks, load balancers, and security groups for each cloud account region that has been added. Once discovered, these resources can be organized using tags that facilitate search and identification. Tags placed on cloud zones, network profiles, storage profiles, and individual infrastructure resources function as capability tags that define desired capabilities and support governance by expressing capabilities and constraints. Using logical, human-readable tags for storage, network, and infrastructure items is recommended to facilitate search and identification functions.

VCF Automation organizes infrastructure through projects, which link users, catalog items, and IaaS resources to the locations where items are deployed. The Overview tab displays infrastructure and consumption metrics, providing a consolidated view of resource usage. Resource details views support filtering based on attributes such as project membership, enabling administrators to locate and review specific subsets of the infrastructure.

Blueprints in VCF Automation allow users to model complex IT services by visually designing infrastructure components such as VMs, networks, storage, and software components. Resource objects in blueprints represent the infrastructure components and services that are provisioned and managed, providing an architectural record of how assets support business functions.

Together, these inventory, discovery, classification, tagging, and visualization capabilities give operations teams the tools to identify, classify, and document the technology assets that support essential business functions. However, VCF provides the technical tooling for asset identification and classification rather than the organizational processes needed to define which assets are critical to the business mission. Establishing criticality criteria, maintaining asset documentation, and conducting periodic reviews of critical asset designations require organizational processes that operate alongside the platform's capabilities.

VMware vDefend (Contributes)

VMware vDefend contributes to identifying and documenting critical technology assets through the Security Services Platform (SSP) and its Security Intelligence feature, which provide asset inventory, classification, and visualization capabilities oriented toward network security segmentation planning.

Security Services Platform maintains a Platform Inventory of infrastructure assets, collecting status information for each asset including identification of assets that are timed out or out of sync. The inventory view provides filtering by Name and Status to locate specific infrastructure assets and identify their operational state. Tags assigned to each infrastructure asset are displayed for verification of tag assignments.

Security Intelligence gathers infrastructure services and servers from CSV files and discovers additional services and servers based on traffic flows analyzed from ESX hosts. During CSV import, Security Intelligence parses and validates the content format and inventory asset data. Security Intelligence also maps discovered unique assets during segmentation analysis, including workloads, groups, IP addresses, distributed virtual port groups (DVPGs), segments, tiers, infrastructure services, and infrastructure servers.

Security Services Platform identifies and publishes application assets, classifying them as either critical or regular applications. This criticality classification supports the identification of mission-critical technology assets within the environment. The inventory hierarchy spans regions, zones, environments, applications, and tiers, with each level displaying the total number of assets within its scope.

Security Intelligence organizes discovered and imported assets into structured Asset Collections: groups, infrastructure assets, environments (such as Production, Non-Prod, DMZ, PCI, and Development), applications, and application tiers. The Environment Asset Collection maps security zones to the operational contexts that support business functions. Application Asset Collections group workloads that provide enterprise functionalities, linking infrastructure resources to the business services they support. The Infrastructure Asset Collection node covers core networking services that enterprise workloads depend on, including LDAP, DNS, NTP, and DHCP. An Unknown Asset Collection surfaces compute entities that are not in the NSX inventory but are present in the data center and communicating to NSX entities, supporting discovery of assets that should be formally inventoried.

Security Intelligence Workload Classification can be set to "Infrastructure Service" to indicate that a compute entity provides infrastructure services such as DNS, DHCP, LDAP, and Syslog. Inferred infrastructure classifications for compute entities can be reviewed, accepted, or modified through the Monitor & Plan > Security Explorer interface.

These capabilities contribute to the control but do not fully satisfy it. vDefend's asset identification is scoped to network security segmentation planning rather than the enterprise-wide technology asset catalog this control requires. Identifying all critical technology assets, applications, services, and data across an organization requires broader inventory and configuration management capabilities within VCF, such as VCF Operations business application views, VMware vCenter inventory exports, and VCF Automation project tagging, which provide the enterprise-wide asset catalog that vDefend's security-focused inventory complements.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) organizes its protection model around identifying which assets are critical enough to warrant disaster recovery protection. Protection groups are an explicit declaration of critical assets, organizing virtual machines into logical units based on their replication and recovery requirements. Placing a workload in a protection group is a deliberate act of classifying it as essential to business operations.

Inventory mappings document how each protected-site asset (resource pools, folders, networks, datastores) corresponds to recovery-site resources, creating a structured record of the infrastructure that supports critical workloads. Site-wide inventory mappings apply defaults across all protected VMs, while per-VM customizations document specific recovery configurations for workloads with unique requirements.

The Protection and Recovery Configuration Import/Export Tool exports a complete record of the DR asset inventory, including site names, inventory mappings, placeholder datastores, advanced settings, array managers with SRA information, protection groups, and recovery plans. This export provides a structured, portable document of which assets are protected and how they are configured for recovery. The export is produced in XML format, enabling automated processing and retention as a configuration record.

PNR generates and exports reports documenting each run of a recovery plan, each test of a recovery plan, and each test cleanup operation. These reports provide an auditable record of which recovery plans executed and which protected workloads were involved.

PNR tracks site metrics including paired sites, pair names, vCenter addresses, site connectivity status, and counts of protection groups, recovery plans, protected virtual machines, and array managers. VCF Operations collects configuration, component health, and usage information from protection and recovery servers and site pairs, providing consolidated visibility into the DR infrastructure as a class of managed assets.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides several mechanisms that allow administrators to restrict where application traffic is processed and where associated data is stored, supporting organizational requirements to control the location of information processing.

Service Engine Group placement controls are the primary mechanism. Administrators can scope Service Engine deployment by host, cluster, or data store by configuring the Host Scope and Data Store settings under Placement Scope for each SE Group at the vCenter level. This confines traffic processing to specific physical infrastructure resources. The Data Store Scope setting in the SE Group Advanced Parameters offers three modes: Local (the Service Engine uses only storage on the physical host, keeping processed data local to that host), Shared (Avi prefers shared storage but allows specific data stores to be included or excluded), and Any (Avi determines the best available storage option).

At the tenant level, Avi's multi-tenancy model provides additional processing location isolation. The behavior depends on tenant context: tenants in Tenant Context provide both control plane isolation and data plane isolation, fully separating application traffic between tenants. Tenants in Provider Context provide control plane isolation only. The `enforce_label_group` setting on a tenant further restricts access to resources tagged with specific label groups, controlling which Service Engines and resources a given tenant can access.

In Kubernetes environments, the Avi Kubernetes Operator (AKO) CRD Operator manages namespace-scoped resources with tenant isolation for multi-tenancy support, extending processing location controls to containerized workloads. The Avi integration with VCF also allows provider administrators to define infrastructure boundaries through regions and organizations in the VCF Automation Provider Management Portal, with region quotas specifying accessible zones and capacity allocation.

The organization is responsible for identifying processing and storage location requirements based on applicable business, regulatory, or contractual obligations, and for configuring the placement and scoping controls accordingly. Avi provides the enforcement mechanisms; defining acceptable locations and verifying that restrictions are correctly applied are organizational responsibilities.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 2.9

Transaction Business Controls

SCF Controls: AST-14, DCH-01, DCH-01.2, DCH-25, DCH-25.1, MON-16, SAT-03.2

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 2.10

Application Hardening

SCF Controls: CFG-02, CFG-02.5, CFG-02.7, CFG-02.9, CFG-03, IAC-20, IAC-21

Aggregate Coverage: Meets

VCF (Meets)

VCF provides secure baseline configurations for all major platform components, consistent with industry-accepted hardening standards. The VCF Security Baseline is a purpose-built document that builds on VCF security fundamentals to address frequently requested compliance standards, regulations, and frameworks. It is designed and validated to tailor security configurations without affecting VCF's ability to meet its design objectives. Organizations can use the VCF Security Baseline to evaluate both default and non-default configurations and to secure their environments in a compliance context.

VCF Operations includes a consolidated out-of-the-box benchmark called the VCF 9 Security Baseline, which provides a ready-to-use compliance profile for evaluating the security posture of a VCF environment. This benchmark enables automated assessment of configurations against the documented baseline, helping maintain a consistent configuration across VCF components. ISO Security Standards compliance benchmarks are also available from the VCF Operations repository as a native pack, giving organizations the ability to measure their environment against internationally recognized hardening standards. Broadcom also provides DISA Security Technical Implementation Guides (STIGs) for VCF components, including vSphere 7.0 and vSphere 8.0 STIGs, which provide detailed instructions for securing and configuring systems to meet specific security requirements.

Individual VCF components have their own security configuration guides that document hardening recommendations. The vSphere Security Configuration Guide provides best practices for securing VMware vCenter, including securing the installation, configuring access and authentication, defining roles and permissions, and enabling auditing and logging. VMware ESX host hardening covers authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. The vSphere Security Configuration Guide documents specific STIG-aligned values for the `Security.PasswordQualityControlPwquality` setting on ESX hosts, including parameters such as `minlen=15`, `maxrepeat=3`, `maxclassrepeat=4`, `difok=4`, and `enforce_for_root`. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access.

VCF Operations also provides a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules. Beyond security settings, vSphere Lifecycle Manager maintains a desired-state cluster image that defines the ESX base build, vendor add-ons, and firmware for every host in a cluster, so the software baseline stays consistent across hosts, and VCF Operations runs scheduled drift detection that flags configuration deviations from the desired state for remediation. Administrators can configure individual configuration elements under Enforce Options, enabling granular control over which baseline settings are applied and enforced across the environment. This supports reducing organizational and business risk by maintaining configuration consistency. vSphere Host Profiles provide an additional mechanism for automated and centrally managed host configuration baseline enforcement, capturing a reference host's configuration and applying it consistently across ESX hosts, covering memory, storage, networking, and other configuration aspects.

For containerized workloads, VMware Kubernetes Service (VKS) includes preconfigured security policy templates. The Baseline security template provides a set of constraints that restrict known privilege escalations while maintaining compatibility with common containerized workloads.

DISA STIGs for Supervisor and VKRs are available to guide hardening of the Supervisor control plane and individual VKS cluster releases, providing baseline security guidance at the same standard as the DISA STIGs applied to VCF infrastructure components. The VKS cluster management interface provides out-of-the-box security policy templates that mirror industry-standard Pod Security Standards profiles, including both Baseline and Restricted configurations. Custom VKS Cluster

Management Security Policy templates are also available to fine-tune individual security context parameters and support governance controls tailored to specific organizational requirements.

Pod Security Admission (PSA), enabled in VKr 1.25 and later, enforces pod security standards at the namespace level. Three policy profiles are defined: Privileged (unrestricted, for system-level workloads), Baseline (helps prevent known privilege escalations while allowing the default minimally specified pod configuration), and Restricted (heavily restricted, following pod hardening best practices). Three enforcement modes are available: enforce, warn, and audit. The `podSecurityStandard` field in the ClusterClass API encodes the intended security posture in cluster definitions, accepting these modes with specific policy versions and namespace exemptions so that baseline security configurations are applied consistently across VKS deployments. System namespaces including `kube-system`, `tkg-system`, and `vmware-system-cloudprovider` are excluded from pod security enforcement. The PSA admission controller can also be statically configured with default enforce, audit, and warn levels for unlabeled namespaces, so namespaces created without explicit labels still receive a defined security baseline. To support gradual policy adoption, audit and warn modes can be set to a stricter level such as restricted while enforce remains at baseline, giving administrators visibility into policy violations before full enforcement is applied. VCF Automation IaaS Resource Policies provide an additional enforcement point at the management layer, supporting requirements that Kubernetes clusters operate at a minimum baseline pod security level.

Kubernetes-native kernel security mechanisms provide workload-level baseline hardening options. `seccomp` restricts the Linux kernel system call surface available inside containers using BPF-based profiles, and the `RuntimeDefault` `seccomp` profile provides a strong set of security defaults while preserving workload functionality. `AppArmor` and `SELinux` provide further kernel-level restrictions through default configurations that offer foundational protections. Kubernetes default RBAC role bindings should be reviewed as part of establishing a security baseline, as defaults may grant broader access than a hardened configuration requires. Isolating each workload in its own Kubernetes namespace allows tailored security policies to be applied per workload and restricts access to namespace-scoped resources such as `ConfigMaps` and `Secrets`.

Harbor Registry, available as a standard package for VKS clusters, supports a controlled baseline for container artifacts entering the environment. Harbor provides vulnerability scanning, content trust, and policy-based replication, along with role-based access control and artifact security policies, supporting controlled management of the container image supply chain. For stand-alone virtual machines deployed in vSphere Supervisor environments, Content Libraries can distribute VM images created with current patches and required security settings that follow corporate security policies.

VMware Private AI Services (PAIS) provides PAIS-specific declarative configuration mechanisms that organizations can use to define and apply baseline settings across the AI infrastructure stack on VCF.

The primary mechanism is the `PAISConfiguration` custom resource. Private AI Services settings are declared in a YAML file compliant with the `PAISConfiguration` schema and applied with `kubectl`, giving administrators a single resource that captures observability, identity, and trust configuration for an organization namespace. Observability includes the `spec.observability.prometheusRuntime` section for Prometheus metrics collection with a configurable storage class and metrics retention period, and an `llmTraces` section for routing large language model traces to an OpenTelemetry Collector. The `PAISConfiguration` custom resource can be patched with `kubectl patch` and verified with `kubectl get paisconfiguration`, supporting baseline change control and drift detection at the AI service layer.

Certificate trust is handled through the `spec.clientTls.caBundleRefs` section, which references `ConfigMaps` containing CA trust bundles. Private AI Services requires HTTPS trust bundles for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and MCP servers that provide tools to models. Trust bundles can be organized per application, with periodic updates required before certificate expiration. Access scope is restricted through the `authorizedGroups` setting, which limits Private AI Services access to specified OIDC groups.

Harbor registry distribution carries baseline controls for model and image artifacts. Replication rules support configurable filters, target namespace, and trigger mode, including a manual trigger mode, so administrators can align artifact replication with organizational policy for connected and disconnected sites. The Model Gallery uses Harbor project access capabilities to restrict access to sensitive training and tuning data. Air-gapped deployments capture the self-hosted registry URL and registry login credentials as part of the activation flow.

Workload resource baselines are defined through `SupervisorNamespaceClassConfig`, which specifies per-zone CPU limits, CPU reservations, memory limits, and memory reservations for resource allocation across zones. GPU-capable VM classes can carry GPU reservations and be confined to a single zone or supervisor namespace, supporting isolation of GPU consumption to a specific tenant. A default storage policy selection in the Private AI Services quickstart defines storage placement and resources for the service database.

Deep Learning VM (DL VM) baselines are captured through VCF Automation self-service catalog items that parameterize VM class, data disk size, user password, and optional SSH public key authentication for remote access. The DL VM OVF property `config-json` accepts a base64-encoded configuration file that controls DCGM Exporter metrics visibility through `export_dcgml_to_public` and JupyterLab authentication through `enable_jupyter_auth`, giving operators a consistent surface to define DL VM hardening parameters.

Credentials supplied during Private AI Services activation, including the private container registry password and proxy password, are stored as secrets in VCF Automation rather than as plaintext configuration values, supporting credential hygiene as part of the deployment baseline.

VMware vDefend (Meets)

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs,

and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the `va-configurator.xml` file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use `scram-sha-256` as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support `scram-sha-256`, `reject`, and `cert` authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the `postgrescluster-allow-non-ssl-system-users` setting in the advanced-system-config ConfigMap within the `dsm-system` namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

Control 2.11A

RMA Business Controls: Restrict transaction activity to validated and approved business counterparties.

SCF Controls: DCH-01, DCH-01.1, DCH-01.2, DCH-03.1, DCH-14, PRM-05, PRM-06

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 3.1

Physical Security

SCF Controls: AST-09, NET-14.5, PES-01, PES-02, PES-02.1, PES-03, PES-04, PES-04.1, PES-05, PES-06, PES-06.3, PES-12

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 4.1

Password Policy

SCF Controls: CFG-02, CFG-02.5, IAC-01, IAC-10, IAC-10.1

Aggregate Coverage: Meets

VCF (Meets)

VCF enforces password complexity, length, and lifespan requirements across its component stack, with each component providing configurable password policies.

At the platform level, VCF uses the Linux PAM (Pluggable Authentication Module) framework to enforce default password complexity rules. The default policy requires passwords of at least 12 characters containing at least one lowercase letter, one uppercase letter, one digit, one special character, and at least five different characters. The PAM module limits password entry attempts to a maximum of three retries before returning an error. On VMware ESX hosts, the password complexity policy is enforced for the root user, helping maintain strong credentials on the hypervisor layer.

VMware vCenter's built-in authentication service, VCF SSO, enforces a password policy for local domain accounts with a default password lifetime of 90 days, configurable through the VCF SSO password policy settings in vCenter. For users authenticated through external identity sources such as Active Directory, password restrictions, expiration, and account lockout are governed by the identity source domain rather than VCF SSO policies.

NSX Manager and NSX Edge enforce password complexity through Linux PAM modules. Default requirements include a minimum of 12 characters (maximum 128), at least one lowercase letter, one uppercase letter, one numeric character, one special character, and at least five different characters. NSX Edge adds restrictions against dictionary words, palindromes, and monotonic character sequences of more than four. All of these parameters are configurable through the NSX Authentication Policy Settings or the NSX Manager API, including minimum and maximum password length, required count of uppercase, lowercase, special, and numeric characters, password uniqueness, and hashing algorithm. NSX Manager enforces a retry limit of three attempts when setting a new password. For password lifespan, NSX Manager supports configuring password expiration with a range from 1 to 9,999 days.

VCF Operations applies password complexity requirements at multiple levels. The admin user account requires a minimum of 15 characters with at least one uppercase letter, one lowercase letter, one digit, and one special character. The default password strength policy allows configuration of the minimum password length starting at eight characters. The password policy settings are managed through Administration > Global Settings > User Access > Password Policy, which provides controls for password strength, password change policy, and account lockout. VCF Operations locks user accounts based on the password lockout policy, with a default threshold of seven failed login attempts, or if a user enters an incorrect password three times within five minutes. VCF Operations for Networks locks a user account after five consecutive failed login attempts for 15 minutes.

VCF Automation supports its own password policy system settings, including account lockout after a configurable number of invalid login attempts. The lockout interval specifying the duration before automatic unlock is also configurable. Provider administrators can unlock a user account manually without waiting for the lockout interval to expire. VCF Automation passwords require a minimum of 15 characters.

VCF Operations provides centralized password lifecycle management for all VCF components. Administrators can rotate passwords on demand or schedule automatic rotation on a recurring basis. During rotation, VCF Operations generates a randomized password that conforms to the component's password policy and re-establishes the relevant component integrations automatically. The VCF Operations UI offers preset rotation intervals, and the API supports custom scheduling. VCF Operations also provides a password remediation capability through the Security > Password management interface, allowing administrators to update service account credentials and synchronize passwords when they have drifted out of sync between components.

The VCF API supports managing the local accounts global password policy in vCenter. The `Invoke-GetLocalAccountsGlobalPolicy` and `Invoke-SetLocalAccountsGlobalPolicy` operations allow administrators to retrieve and update the vCenter password policy programmatically through the vSphere Automation SDK for PowerShell.

VCF documentation recommends setting passwords following a common set of requirements across all accounts. While individual components support different password parameters and defaults, administrators can align password policies across the environment to establish a consistent security posture. The combination of enforced defaults, per-component customization options, password expiration controls, and centralized rotation provides the mechanisms needed to enforce complexity, length, and lifespan requirements for password-based authentication throughout the VCF stack.

VMware vDefend (Contributes)

VMware vDefend (vDefend) enforces password complexity, length, and lifespan requirements for its management interface accounts, contributing to the organization's password-based authentication posture.

Security Services Platform (SSP) is the centralized management console for vDefend. SSP enforces password policies for local user accounts: admin and audit user passwords require a minimum of 12 characters and a maximum of 128 characters, and must contain at least one uppercase letter, one lowercase letter, one numeric character, and one special character. The same complexity criteria apply during password changes and resets. Local user passwords are valid for 180 days; a notification banner appears in the SSP UI 30 days before expiration to prompt users to update their password. Installer user passwords are valid for 60 days. The License Hub component of SSP also enforces password complexity requirements during local password change operations.

SSP supports integration with directory services, including Active Directory over LDAP and OpenLDAP. When remote users or remote user groups are configured through LDAP, SSP applies the password expiration settings configured in the directory service; password expiry for these accounts cannot be modified from the SSP UI. SSP uses Authelia, an open-source authentication and authorization server, to handle authentication requests, including two-factor authentication and single sign-on.

For Identity Firewall, vDefend uses an LDAP password to authenticate connections to the directory service used for identity-based policy enforcement.

vDefend is a network security product and not a general-purpose identity management system. Its management interfaces enforce password complexity, length, and lifespan policies for vDefend administrative access. Satisfying this control fully requires applying equivalent password policies across all systems within the organization's environment, which is an organizational responsibility beyond vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the `va-configurator.xml` file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied

consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) enforces password complexity and length requirements for all local user accounts. Local user passwords must contain a minimum of 8 and a maximum of 20 characters, including at least one uppercase letter, one lowercase letter, one number, and one special character from the set (?!@#\$\$%^&*). These requirements apply both at account creation and at every subsequent password reset; DSM rejects any new password that does not satisfy all criteria before accepting the change. Administrators can set the `force_password_change` flag on individual local user accounts to require a password reset at the next login, supporting periodic credential rotation and post-provisioning hygiene workflows.

The root account for the DSM provider VM carries its own complexity requirements: a minimum of 15 and a maximum of 32 characters, requiring at least one uppercase letter, one lowercase letter, one number, and one special character. These constraints are enforced during OVA deployment, so the appliance cannot be instantiated with a weak root credential. The root password expiry date must be set to a valid future date and cannot be configured to never expire, making root credential rotation mandatory. DSM checks root password status at regular intervals and generates a `ROOT_USER_PASSWORD_EXPIRE_SOON` alert when the credential is approaching expiration, giving administrators advance notice before a reset is required.

For PostgreSQL database instances managed by DSM, the default host-based authentication (HBA) configuration applies the `scram-sha-256` algorithm, a salted challenge-response mechanism that avoids transmitting cleartext passwords during authentication. Custom `pg_hba.conf` entries also default to `scram-sha-256` as the password-based authentication method. Local user management passwords within the DSM platform are encrypted using PGP symmetric encryption with dedicated keys (`PGCRYPTO_PASSWORD` and `PGCRYPTO_ALGORITHM`).

DSM supports both local user authentication and LDAPS-based directory service authentication for platform access. Local users are authenticated by validating the email address and password against DSM's internal store. When LDAPS is configured, password lifecycle management, including organizational complexity and lifespan policies, is delegated to the directory service. PostgreSQL and MySQL database instances can independently be configured for LDAP or Active Directory authentication, allowing database-level credential management to align with enterprise directory policies. For PostgreSQL, the `Enable Directory Service Authentication` toggle on the database creation form activates this integration when a default directory service is configured. Administrators should configure LDAPS where enterprise password governance policies must extend to database-level credentials, or rely on DSM's built-in local user password policy where directory integration is not used.

For SQL Server database instances, DSM supports SQL User authentication with standard SQL Server logins and passwords. The DSM privileged service account used for automated SQL Server tasks must be configured with its password policy set to `Never Expire` to prevent service interruptions; administrators should account for this service account exception when reviewing password lifespan policies across DSM-managed database instances.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer (Avi) enforces password-based authentication controls through the Avi Controller's administrative identity plane, addressing complexity, length, and lifespan for locally authenticated accounts.

The Controller's strong password enforcement feature requires each password to contain at least one uppercase character, at least one lowercase character, at least one numeric character, and at least one special character from the allowed set. The Controller rejects passwords consisting of sequences of adjacent keyboard keys. These requirements apply to both newly created accounts and to existing accounts when a user changes their password. Complexity enforcement is controlled through

the `password_strength_check` setting, which the Controller applies at the portal level regardless of the administrative interface used.

The minimum permissible password length is configurable through the `minimum_password_length` setting. The Controller enforces a minimum of 8 characters by default; administrators can raise this threshold via the REST API or CLI. The Avi License Hub enforces stricter length requirements for its admin and audit accounts: a minimum of 12 characters and a maximum of 128 characters.

Password expiration is enforced through user account profiles using the `password_expiration_days` setting. The Default-User-Account-Profile sets password expiration at 365 days. The Controller displays a notification banner in the UI 30 days before a password expires to prompt renewal. The expiration period is configurable per profile.

Password history enforcement restricts users from reusing recent passwords by comparing proposed updates against a configurable list of previous password hashes. The history count is configurable from 1 to 10 previous passwords, with a default of 5.

Locally authenticated users change their own password through the My Account menu, which requires entry of the current password before accepting a new one. Administrators can generate a random password for a local user account or input a new password manually during a password reset. User-initiated password recovery through the GUI is supported when SMTP email is configured.

These controls apply to locally authenticated Avi Controller accounts. For administrators who authenticate against external directories such as LDAP, password complexity and lifespan are managed by those external directories.

Control 4.2

Multi-Factor Authentication

SCF Controls: IAC-06

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 5.1

Logical Access Control: Enforce the security principles of need-to-know access, least privilege, and separation of duties for operator accounts.

SCF Controls: HRS-01, HRS-02, HRS-04.1, HRS-11, IAC-08, IAC-20, IAC-21

Aggregate Coverage: Meets

VCF (Meets)

VCF enforces role-based access control across all major platform components, restricting access to technology assets, applications, services, and data based on assigned roles with defined permissions. RBAC is applied consistently throughout the stack, covering compute management, networking, storage, operations management, automation services, and Kubernetes workloads.

VMware vCenter provides fine-grained authorization through a permissions model that associates roles with users or groups on objects in the vCenter inventory hierarchy. Roles are sets of privileges, and vCenter defines three authorization levels: operator (read-only access to configuration, the most restricted level), administrator (read and write access to configuration but cannot manage user accounts, intended for users who alter vCenter configuration or exercise control functions), and super administrator (full control). When a predefined role is modified, the updated privilege set applies immediately to all users assigned that role. New roles are created with three default system-defined privileges (System.Anonymous, System.Read, System.View), and administrators add specific privileges to match the intended access level. vCenter also supports creation of custom roles with granular privilege assignment and permission propagation to vSphere objects in the inventory hierarchy.

NSX implements RBAC by assigning users predefined roles with specific permissions. The platform includes 15 built-in roles: Enterprise Admin, Admin, Network Admin, Network Operator, Security Admin, Security Operator, Cloud Admin, Cloud Operator, Cloud Project Admin, Load Balancer Admin, Load Balancer Operator, VPN Admin, GI Platform Admin, NSX Platform Admin, and Support Bundle Collector. These roles follow the principle of least privilege, with each role carrying only the permissions needed for its functional area. NSX RBAC applies across multiple operational domains including inventory, plan and troubleshoot, and system management functions. NSX also supports project-scoped RBAC, where Network Admin, Network Operator, Security Admin, and Security Operator roles assigned within a project have permissions limited to that project's scope rather than the entire NSX system. This project-scoped model extends to VPCs and subnets within the NSX networking hierarchy. For organizations that need role definitions beyond the built-in set, NSX allows creation of custom roles tailored to specific operational requirements. Only an Enterprise Administrator can assign the role management permission to a custom role. NSX Federation extends RBAC to multi-site deployments, applying the same access control model across federated NSX instances. Principal identities, which are used for service-to-service authentication local to NSX, also support RBAC role assignment, so automated integrations operate under the same access control model as human users.

VCF Operations enforces RBAC through the assignment of service roles to users and groups. Administrators configure role-based permissions through the Roles tab under Infrastructure Operations, where individual permissions can be selected or deselected to define what each role is authorized to do. The System Administrator role includes rights covering approvals, audits, certificates, datastores, edge clusters, integrations, LDAP settings, namespaces, proxy rules, system settings, tokens, and truststore operations. Administrative operations such as password management require authentication with a user assigned the ADMIN role. VCF Operations also defines its own roles within vCenter, with privileges named using a convention that appends the role to the product name (such as VCF Operations ContentAdmin Role and VCF Operations PowerUser Role). The PowerUser role has privileges to perform the actions of the Administrator role except for user management and cluster management. A further restricted PowerUserMinusRemediation role excludes remediation actions in addition to those limitations. A vCenter administrator assigns these roles to users, and VCF Operations maps vCenter users to the appropriate role.

vSAN supports RBAC and permissions management for authentication and authorization of storage operations. The vSAN Security Configuration Guide provides guidance on configuring these role-based controls for storage infrastructure.

VCF Automation governs access through multiple RBAC mechanisms at different scopes. At the organization level, rights bundles assign specific API permissions to roles including Organization Administrator, Organization Auditor, and Organization User. Group membership and role assignment are managed through the Access Control interface, and organization administrators can edit role assignments for groups at any time. At the project level, VCF Automation defines three distinct roles: administrators, members, and viewers, providing tiered access to project resources and operations. VCF Automation also governs blueprints, catalogs, content libraries, and custom entities through its role model. The Assembler Administrator role has read and write access to the entire user interface and API resources, while other roles have progressively narrower permissions.

For Kubernetes workloads running on VMware Kubernetes Service (VKS), VCF enforces RBAC through two complementary control layers. At the vSphere layer, vSphere Namespaces assign three permission roles: Owner (full control including namespace deletion), Can Edit (provisioning and operating workloads), and Can View (read-only access). At the Kubernetes layer, the Kubernetes RBAC authorization framework governs access to all API server requests through four core objects: Roles define permissions scoped to a single namespace, ClusterRoles define permissions applying cluster-wide, and RoleBindings and ClusterRoleBindings associate those roles with authenticated subjects such as users, groups, or ServiceAccounts. Permissions are purely additive with no deny rules, and administrators can restrict access to individual resource instances by name using the resourceNames list in role rules.

VKS clusters integrate with VCF SSO so that Kubernetes RoleBinding objects grant RBAC permissions directly to VCF SSO users and groups. This means the same identity provider that governs VMware vCenter access also governs Kubernetes cluster access, providing a consistent identity model across both the platform and workload layers. Cluster operators use kubectl or the Kubernetes API to assign role permissions to developers and other personas with defined responsibilities.

Kubernetes RBAC also governs ServiceAccounts, which provide discrete identities for pods and automation processes. This separation allows human access and workload access to be governed independently, with each scoped to the minimum permissions required for its function. ServiceAccounts follow the principle of least privilege by receiving only the minimum set of permissions required to function correctly, and RBAC should be applied to Secret objects to enforce least-privilege access to sensitive data stored within namespaces.

The Kubernetes RBAC API includes built-in controls against privilege escalation: the API prevents users from editing roles or role bindings to gain permissions beyond those they already hold, and this enforcement applies at the API level regardless of the authorization mode in use. Role-binding authority can be explicitly delegated by granting a user permission to perform the bind verb on a specific Role or ClusterRole, limiting the roles that identity can delegate to others.

In multi-tenant VKS deployments, RBAC is the primary mechanism for isolating tenants within a shared cluster. Administrators use Role and RoleBinding objects at the namespace level to restrict each tenant's access to its assigned namespaces, and ClusterRole and ClusterRoleBinding objects to control access to cluster-level resources, blocking unprivileged users from crossing tenant boundaries.

Supervisor services deployed on VKS clusters extend RBAC to their own access models. The Secret Store Supervisor Service enforces role-based access control across administrator, DevOps engineer, and application tenant roles, controlling who can manage and retrieve sensitive data. The Argo CD Supervisor Service implements RBAC through a configurable policy field using Casbin syntax, with the spec.rbac.policy setting defining role assignments and permission rules; policy rules (p rules) control account permissions including the ability to grant admin roles to specific local accounts, and group mappings (g rules) assign accounts to role groups.

VMware Private AI Services (PAIS) provides role-based access control scoped to its AI services and AI workload delivery components. The central mechanism is OIDC group-based authorization for PAIS. When activating PAIS in an organization namespace, administrators populate the authorizedGroups setting with one or more OIDC group identifiers so that only users who belong to those groups can access the service. The OIDC configuration supports a configurable groups claim name through the oidc-groups-claim setting, with the groups claim carried in the Access Token and evaluated at access time. PAIS requires an OIDC provider configured as a public client application with Authorization Code and Refresh Token grant types,

and it can be configured with one OIDC provider. Additional OAuth 2.0 client identifiers can be accepted by configuring Extra Audiences through the `oidc-extra-audiences` setting when the OIDC provider issues tokens for multiple audiences.

PAIS extends the same identity model to the Grafana observability platform used for PAIS metrics. Grafana role assignment is configured through the `grafana-oidc-role-mapping` property using an expression such as `contains(groups['*'], 'pais-access-group') && 'Admin' || 'Viewer'`, so OIDC group membership maps automatically to Grafana Admin or Viewer roles. PAIS uses the same OIDC provider for Grafana authentication that it uses for service access.

For machine learning model storage, the Model Gallery uses Harbor project access capabilities to restrict access to the sensitive data used to train and tune models. PAIS integrates with Harbor registries as the model storage backend and requires authentication and certificate-based trust for model retrieval. PAIS is compatible with OCI-compliant registries from other vendors when deployed in a disconnected or air-gapped environment, and the project-scoped access controls apply to the chosen registry.

Access to PAIS catalog items for GPU-accelerated VKS clusters and other AI workloads is governed through project-based permissions in VCF Automation. PAIS custom forms in blueprints can be modified to control user inputs at request time, scoping which configuration choices a requester can make when provisioning AI workloads. Knowledge Base data sources used by PAIS retrieval augmented generation require authenticated access to external repositories, including user name and password authentication for SharePoint On-Premises data sources and access keys with list and read permissions on the target bucket for Amazon S3 compatible stores. PAIS uses a CA trust bundle for secure communication with external services and databases.

These PAIS-specific controls operate at the AI services and workload layer. Access to the underlying compute, storage, and networking infrastructure is governed by platform-level RBAC in VCF, including VCF SSO and VMware vCenter role assignments, and database-level access for vector and operational data is governed by Data Services Manager. PAIS adds service-level and workload-level RBAC for AI-specific assets on top of the VCF platform foundation rather than replacing those platform controls.

VMware vDefend (Contributes)

VMware vDefend (vDefend) enforces role-based access control across its security management interfaces to restrict access to firewall policy administration, threat analysis functions, and monitoring capabilities based on assigned user roles.

The vDefend distributed firewall (DFW) implements RBAC to control who can create or modify firewall rules, limiting policy changes to authorized personnel. Access to DFW monitoring features, including Firewall Insights, requires one of three designated roles: Enterprise Admin, Security Admin, or Security Operator. Rule Analysis operations within the platform are also role-gated across the five defined role types.

Security Services Platform (SSP) implements RBAC with five defined roles governing access to platform operations: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. Each role carries differentiated permissions; Full Access grants create, read, update, and delete capabilities, while Read-only access is available for monitoring-oriented roles such as Auditor and Support Bundle Collector. Role assignments can be applied to individual remote users or to remote user groups managed through a directory service, allowing administrators to align vDefend access with existing organizational structures. Multiple roles can be assigned to a single user or group to meet varying operational requirements. SSP's RBAC model also applies to License Hub operations, restricting licensing management actions to authorized roles.

Security Intelligence RBAC in 9.1 uses the same five-role model as SSP (Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector), aligning Security Intelligence access governance with SSP's permission model and providing consistent role boundaries across both the detection and platform layers.

For organizations using VCF Automation for vDefend firewall management, VCF Automation provides a dedicated Firewall category under RBAC rights, controlling access to the management and viewing of DFW rules, Tenant Gateway Firewall policy, VPC Gateway Firewall policy, and VPC Security Profiles. This allows organizations to scope firewall administration

rights independently of other VCF Automation capabilities, supporting separation of duties between network automation and security policy management.

vDefend's RBAC controls complement the broader VCF RBAC model by restricting access to network security policy management independently of compute, storage, or platform configuration access. An administrator with VMware vCenter privileges does not automatically gain the ability to modify firewall rules or security analytics configurations unless explicitly granted the appropriate vDefend roles. This separation of duties between infrastructure administration and security policy management supports distinct team structures for network security management.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) enforces logical access control through a privilege-based authorization model. A privilege in PNR is the right to perform a specific action, such as creating a recovery plan or modifying a protection group. PNR restricts login access to VMware vCenter administrators by default, and other users must be explicitly granted access by an administrator before they can perform any protection or recovery operations. PNR augments vCenter roles and permissions with additional privileges that allow detailed control over PNR-specific tasks and operations.

PNR roles follow least privilege through granular role assignment. The vSphere Replication predefined roles can be cloned and customized by adding or removing individual privileges, allowing administrators to create custom roles that grant only the minimum permissions needed for a specific function. The Propagate to Children option can be deselected to create permission hierarchies that override inherited permissions at specific nodes without affecting child object permissions. vSphere Replication enforces permission denial with an error message when users without appropriate privileges attempt restricted operations. PNR roles do not include vSphere Replication privileges, so a user who is not a vCenter administrator but requires both PNR and vSphere Replication operations should be added to two separate user groups rather than granted full vCenter administrator privilege.

For cross-site operations, PNR enforces dual-site authorization. PNR requires permissions on both vCenter objects and on PNR objects to function properly, and PNR verifies permissions on the remote vCenter instance as part of its access control validation. Removing a user's permission on a protected site stops that user from continuing operations on resources at that site. In shared recovery site configurations, the vCenter administrator must manage permissions so that each user has sufficient privileges to configure and use PNR while no user has access to resources belonging to other organizations. PNR restricts users in shared recovery site configurations from renaming, moving, or deleting data centers or hosts.

For automatic protection of virtual machines, administrators can assign the SrmAdministrator or SrmProtectionGroupsAdministrator role to the automatic protection user or user group rather than granting global vCenter administrator privilege. The PNR clean room Orchestrator restricts connections to only IP addresses or IP address ranges that have been added to a configured management access list, providing network-layer access enforcement on top of the role-based model. For PNR deployed with VCF Automation, access is controlled through role-based permissions assigned to Provider Administrators, Organization Administrators, Project Administrators, and Project Advanced Users. Provider Administrators select which replication classes each Organization can use, and Organization Administrators manage the pairing of namespaces and assignment of replication classes within their Organization.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) enforces logical access control through a two-tier role-based access control model at the platform level, combined with database-native privilege controls within provisioned database services.

At the platform level, DSM defines two roles: the DSM Admin role and the DSM User role. Administrators hold full visibility and management authority over all data services in the environment, while users assigned the DSM User role are restricted to viewing and managing only the objects they own. The DSM console enforces this separation by restricting the views and actions available to each role, so users cannot see or interact with objects outside their assigned scope. Role assignments and user management are configured through the vSphere Client Permissions interface under the Data Services Manager Configure tab.

Namespace-based scoping provides an additional layer of least-privilege enforcement. DSM User role assignments can be scoped to one or more specific namespaces, restricting a user's access to only the namespaces they are explicitly assigned, and DSM Users can view only the namespaces to which they have been granted access. Namespaces control database creation permissions such that only users associated with a given namespace can create databases within it. Namespaces that are externally managed through VCF Automation are treated as read-only within DSM. Only users with appropriate DSM permissions can configure infrastructure policies, keeping resource configuration authority separate from general data service access.

DSM supports both local users and LDAP-based directory service users. Local users are created through the DSM UI with role assignments that control namespace access. For LDAP environments, roles can be assigned to Directory Service Groups, enabling group-based access control. The DSM Admin role, when assigned to a Directory Service Group, grants super-user permissions to all members of that group. This allows organizations to manage platform access through existing directory group structures.

Within provisioned databases, access enforcement is applied at the database engine level. PostgreSQL databases support the GRANT command to assign privileges on specific databases and schemas to individual database users; LDAPS-authenticated users require explicit grants for the databases and schemas they are authorized to access. MySQL databases require explicit privilege grants to LDAPS-authenticated users via the GRANT command to control database access, and DSM assigns operating privileges to the default database user while revoking create and update privileges on the mysql.system schema, limiting user access to system-level objects. For SQL Server databases, DSM grants the cluster administrator login restricted read-only privileges and specific ALTER privileges for server management and auditing, rather than full administrative access. DSM's internal dsm_mgmt management login restricts users from accessing or modifying system-level objects, keeping administrative operations within an isolated context. User-defined DDL triggers that execute during DSM management operations are confined to a database-level security context, blocking access to the server-level permissions held by the internal management account.

The DSM service account that communicates with VMware vCenter is required to hold only the specific vCenter permissions necessary for its operations, including service account creation, plug-in registration, and resource management. Administrators can verify and update these credentials through Settings > System Settings under Target vCenter. DSM clears the vCenter administrator credentials secret from storage after successful registration, reducing the exposure window for those credentials. A global alert is raised if the service account lacks the required permissions, supporting ongoing privilege verification.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer provides a native, multi-tiered Role-Based Access Control (RBAC) framework that governs all administrative access to the Avi Controller. At the base level, Avi roles assign one of four privilege types to each resource category: Write (full create, read, modify, and delete access), Read (view-only access to configuration, health, and analytics data without modification capability), Assorted (a mixed access level combining permissions across specific operations), and No Access (no access to the resource at all, including the inability to read or list it). Roles are combined with tenants to define the complete authorization settings for each user, scoping what resources a user can interact with and what actions they may take.

Beyond base privilege levels, the Extended Granular RBAC feature refines access using markers, which are key-value label pairs assigned to Avi objects. A role definition specifies that a user may access only objects bearing labels that match the role's marker set. The allow_unlabelled_access parameter controls whether a user can view objects that lack matching labels, allowing administrators to restrict visibility to labeled objects only. Label groups can be associated with tenants to enforce label-based access policies across the tenant boundary. Multiple label values can be mapped to a single key, enabling flexible classification schemes. This mechanism enables resource-level scoping across tenants and teams: for example, restricting a group of operators to only the virtual services labeled with their team's identifier, without granting visibility into other teams' objects.

At the finest granularity, Avi implements sub-resource (field-level) RBAC, which scopes which specific fields within a configuration object a given user is authorized to modify. Sub-resource definitions can be combined so that a user can configure multiple fields or features within a single object while remaining restricted from updating others. Label-based permissions for cloud objects extend this field-level control to infrastructure resources managed by the Avi Controller. Virtual service configuration exposes RBAC directly: the RBAC tab in the Virtual Service advanced setup provides label-based access control for health monitors and associated objects, extending role enforcement down to individual service configuration items.

For GSLB deployments, the Avi Controller enforces RBAC through role references such as `Gslb_Group_Enabled` and `Gslb_Health_Monitor` that can be assigned to user accounts with tenant-level scope. These role references apply to follower sites configured with federated JWT profiles, scoping which accounts can modify GSLB configuration.

The Avi Controller applies RBAC within the License Hub, limiting which users can perform specific actions based on their assigned role.

For deployments using the Avi Kubernetes Operator (AKO), the Avi Controller implements RBAC by assigning tenants and roles to user accounts at the Kubernetes or OpenShift cluster level. AKO Custom Resource Definitions (CRDs) can leverage Kubernetes RBAC policies to restrict which user groups can configure routing rules, extending the Controller's authorization model into the Kubernetes control plane.

For deployments on Microsoft Azure, Avi integrates with Azure IAM to control which Azure identities have access to Avi Load Balancer resources hosted in Azure. Administrators can use built-in Azure roles such as Reader (read-only access) or Owner (full access), or define custom roles for finer control over specific resources.

RBAC configuration is managed through the Users section of the Avi Controller UI. Roles are defined per resource type and then assigned to users within a tenant. Extended Granular RBAC markers are attached to individual Avi objects (virtual services, pools, health monitors, and others) and referenced in the role definition. Sub-resource RBAC is configured as part of the Extended Granular RBAC object, combining field-level restrictions as needed.

Control 5.2

Token Management

SCF Controls: CFG-02, CRY-01, IAC-01, IAC-10.7

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 5.3A

Staff Screening Process: To the extent permitted and practicable, ensure the trustworthiness of staff operating the local SWIFT environment by performing regular staff screening.

SCF Controls: HRS-01, HRS-02.1, HRS-04, HRS-04.1, HRS-10

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 5.4

Physical and Logical Password Storage

SCF Controls: IAC-10, IAC-10.11, IAC-10.5, IAC-10.6

Aggregate Coverage: Meets

VCF (Meets)

VCF includes built-in password management capabilities that address the storage, protection, and lifecycle management of credentials for the components and service accounts within the platform. These capabilities function as an integrated credential manager for the VCF stack, though they do not replace a general-purpose enterprise password manager tool.

VCF Operations provides a centralized password management interface accessible through the Security menu. This interface gives administrators a consolidated view of all managed accounts, their current statuses, and any remediation needs across the VCF fleet. Platform Operators can manage passwords for integrated components, including VMware ESX hosts, VMware vCenter, NSX, and other VCF components, from this single pane. A password management dashboard provides visibility into password status across the environment. Passwords for managed components can be rotated on demand or scheduled for automatic rotation on a recurring basis. The UI offers preset intervals for scheduled rotation, and the API supports custom intervals for more granular scheduling. During rotation, VCF Operations generates a randomized password based on the component's password policy and reestablishes the respective component integrations automatically. Passwords can also be retrieved programmatically through the VCF Operations API.

NSX Manager provides its own password management capabilities for local user accounts through the user interface, CLI, and API. Administrators can reset user passwords through a Local Users interface, and the system supports auto-generated passwords for both Administrator and Auditor accounts. An API endpoint at System Administration > Configuration > Fabric > Nodes > User Management is available for programmatic password management operations. Additional VCF components such as HCX Manager support password updates for administrative accounts via CLI. VMware vCenter provides the `dir-cli password create` CLI command, which generates a random password that meets the platform's complexity requirements and can be used for service accounts or third-party solution users managed through VCF SSO.

Password protection within the platform uses multiple mechanisms. NSX Manager local user passwords are secured using Linux/PAM libraries, which store hashed and salted representations in /etc/shadow. Other passwords stored within NSX Manager are encrypted using a random key held in the local file system, and all passwords across NSX Manager databases, configuration files, and log files are encrypted using strong one-way hashing with a salt. The platform documentation recommends that any password output from manual update operations be saved to a secure location with encryption for later retrieval. ESX hosts include a `Security.PasswordHistory` advanced system setting that specifies the number of previous passwords retained per user account to prevent reuse; this history check is enforced when passwords are changed through the VIM LocalAccountManager.changePassword API.

VCF's standard web interfaces and APIs are compatible with external privileged access management and credential vaulting solutions. Organizations that use enterprise-grade password management tools can integrate them with VCF through its well-documented REST APIs and web-based management consoles, extending their enterprise credential management strategy to cover VCF infrastructure credentials alongside other systems.

VCF's password management is scoped to its own credential ecosystem. The platform provides the tooling to manage, rotate, generate, store, and protect the passwords for VCF component service accounts and local user accounts. An organization's broader password management needs, including end-user credentials, application passwords, and credentials for systems outside the VCF stack, require a dedicated enterprise password manager solution that is outside VCF's scope.

VMware vDefend (Contributes)

Within vDefend's own management interface, Security Services Platform (SSP) protects authenticators by supporting both local account credentials and directory-managed authentication via Active Directory over LDAP or OpenLDAP, with the SSP Installer enforcing authentication, authorization, and access control as critical elements of user management. In 9.1, SSP uses

Authelia, an open-source authentication and authorization server that provides two-factor authentication (2FA) and single sign-on (SSO) capabilities for platform administrators, giving the management plane a stronger authenticator posture commensurate with the sensitivity of the systems administrators access.

SSP implements role-based access control to limit system access based on user roles, with local user management in the License Hub restricting actions to authorized users only. Local administrative and audit user passwords are established during deployment and can be changed only by authorized users through the SSP UI or Installer UI, restricting credential modification to authenticated administrators.

At the network layer, vDefend's Identity Firewall maps authenticated user identity to IP addresses and applies Distributed Firewall rules based on Active Directory user and group membership rather than source IP address alone. Administrators can create firewall rules using AD users and groups as source criteria, enforce access controls on virtual machines and physical devices through Event Log Scraping for login detection, and apply security policies to virtual machines based on dynamic name-based criteria combined with AD group membership. These mechanisms tie network access decisions to the authenticated identity of the originating user, supporting the broader goal of restricting access to sensitive systems in proportion to their classification.

Protecting authenticators for systems and applications outside of vDefend's management plane, such as enforcing password storage standards or token lifecycle management across the broader organization, remains outside vDefend's scope.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms for managing authenticators across both the administrative plane and the database layer, supporting the secure credential management aspect of this control.

For administrative access to the DSM platform, the system supports two authentication paths: local user accounts authenticated by email ID and password, and LDAPS-integrated accounts authenticated by matching the email domain against a registered LDAPS server. When directory service credentials are non-functional, DSM falls back to local user authentication, maintaining access continuity. Administrators configure and manage these authentication sources through the DSM Admin UI, which also provides a Permissions view for creating, monitoring, and managing configured users. LDAPS integration supports certificate-based validation of the directory service connection, with administrators able to upload directory service server certificates through the Admin UI to establish trusted connections. LDAP groups can be assigned roles within DSM, enabling group-based access control aligned with directory service group membership.

At the database layer, DSM supports directory service authentication for PostgreSQL, MySQL, SQL Server, and MinIO databases. For PostgreSQL, host-based authentication (HBA) rules determine how clients are authenticated, using ordered matching rules that evaluate connection type, client address, requested database, and user name. The default HBA configuration includes a final catch-all entry using scram-sha-256, with optional LDAP entries for directory-integrated authentication. This HBA configuration can be modified through the DSM interface. For MySQL databases, LDAPS authentication is available using Active Directory Global Catalog, with support for multi-domain controller deployments via the AD Secure/SSL Global Catalog on port 3269. Directory service authentication for individual database instances can be enabled or disabled through the Enable Directory Service Authentication toggle in the database settings.

For SQL Server databases, DSM uses contained database users, where users authenticate directly against the database and identity information resides within the database. DSM supports Windows Authentication for SQL Server server-level logins through Active Directory integration, enabling Kerberos-based single sign-on for clients joined to the same domain. SQL Server Authentication logins can also be created on all DSM clusters. Administrators configure which user types are permitted per data service policy, selecting between Windows Principal authentication using Active Directory credentials and SQL User authentication using standard SQL Server logins. An internal management login (`dsm_mgmt`) restricts access to system-level objects, keeping administrative operations within an isolated context.

DSM enforces password policies for local accounts, including complexity requirements, and applies a root password expiry on a three-month rotation cycle. For service-to-service communication, DSM uses authentication secrets (`dsm-auth-creds`) containing endpoint credentials and root CA certificates, with automatic secret generation available through the Consumption Operator installation. Prometheus metrics forwarding supports configurable authentication options, including no

authentication, certificate-only authentication, basic authentication with username and password, or a combination of certificate and basic authentication.

Regarding authentication strength appropriate to data classification, DSM provides the authentication mechanisms that administrators can configure to match organizational security policies, but it does not automatically enforce differentiated authentication strength based on data classification. Organizations must define their data classification scheme and determine which DSM authentication options (local credentials, LDAPS, HBA rules, certificate validation, Kerberos) apply to each tier of sensitivity. DSM contributes the technical controls; the alignment between authentication strength and data classification requires organizational governance to establish and maintain.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides mechanisms to securely manage authenticators across two distinct planes: the Controller management plane (admin access) and the application data plane (end-user client authentication for load-balanced applications).

For the management plane, Avi maintains user accounts in two categories: local users managed directly on the Controller, and remote users authenticated through an external authentication, authorization, and accounting (AAA) server. Avi uses Authentication Profiles to configure how administrators authenticate to the Controller. Authentication Profiles support LDAP for credential validation against a directory service, SAML for federated authentication that delegates the process to a centralized identity provider (IdP), and basic authentication. The recommended approach is federated authentication, which centralizes the authentication process by delegating to an external IdP rather than managing credentials locally on the Controller. SAML profiles verify user identity without storing credentials on untrusted systems, and Avi Controller SAML authentication profiles can be integrated with Workspace ONE Access for catalog-based application access. Admin users can also authenticate using password-less SSH-based login as an alternative to password-based authentication. On every user login, the Auth Mapping Profile evaluates authorization mapping rules and updates the user record with tenant and role pairs drawn from the IdP's assertions.

For the application data plane, Avi acts as a proxy that applies client authentication policies to inbound application traffic. Supported methods include LDAP authentication (checking client credentials against a directory service), SAML single sign-on (enabling federated application access with a single credential set), OAuth and OIDC (where Avi acts as a client and resource server, with the authorization server authenticating clients and validating authorization codes before issuing tokens), and JSON Web Token (JWT) validation. The SSO Policy supports configurable Authentication Rules and Authorization Rules with path-based matching criteria, allowing different authentication requirements to be applied to different application paths. More granular authorization in OAuth/OIDC flows is available through Authorization Policies or DataScript.

Organizations configure which authentication method applies to each virtual service or application based on the sensitivity of the data accessed. Avi's Authentication Profiles and SSO Policies provide the technical enforcement points to apply different authentication strengths across the application portfolio, but the mapping from data classification tier to required authentication method is an organizational governance decision that must be defined and maintained by the organization.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 6.1

Malware Protection

SCF Controls: END-01, END-04, END-04.1, IRO-01, IRO-02, MON-02, MON-02.2

Aggregate Coverage: Meets

VCF (Meets)

VCF provides several platform capabilities that support malicious code protection, though organizations must deploy additional tools to achieve full antimalware coverage across endpoints.

At the hypervisor layer, VMware ESX supports Secure Boot and code signing to restrict unauthorized code from executing on hosts. Trusted Platform Module (TPM) support enables boot-time integrity measurement, and VMware vCenter provides APIs to retrieve TPM event logs for validating boot-time measurements or configuring firmware trust with an attestation service. Administrators can verify that hosts have booted in a known good configuration by checking TPM device status and event logs through the vCenter trusted infrastructure API. ESX host TPM modules must be verified as running the latest 2.0 firmware, and if not in use, disabled in the BIOS. Virtual machines can be configured with UEFI firmware for guest operating system boot integrity. Windows guest operating systems support Virtualization Based Security (VBS), which enables Device Guard to help prevent malware from running and Credential Guard to protect credential secrets; these features are configurable through Group Policy on VMs with ESX 6.7 or later compatibility. Virtual machines can also have the Guest Integrity (GI) security device enabled through the VMware Host Client, which is the platform foundation for VMware AppDefense.

The vSphere Security Configuration Guide provides hardening recommendations for ESX hosts, including configuring authentication and authorization settings, disabling unnecessary services, and enabling security features like Secure Boot and TPM. These configuration baselines are industry-standard best practices for host hardening.

vSphere Lifecycle Manager and VCF Operations Configuration Profiles maintain desired-state configuration for ESX hosts. Configuration Drifts in VCF Operations provides a proactive method to monitor configuration changes and identify when vCenter instances and vSphere clusters deviate from their approved baselines. Drift status is updated through a collection cycle that runs every 8 hours. This helps identify when host software or configuration has been modified from its approved state, which can indicate unauthorized changes or tampering.

VCF's networking layer, NSX, supports integration with third-party endpoint protection solutions for virtual machine security. The platform documentation references specific partner integrations including Symantec Endpoint Protection and ESET Antivirus/Security software, which provide anti-malware, intrusion prevention, and firewall capabilities for guest virtual machines. NSX App IDs can be used in conjunction with these third-party solutions for network management and security policy enforcement. Organizations can implement security groups, define security policies, and use NSX's integration with third-party security solutions for virtual machine protection.

NSX Guest Introspection provides an agent-based framework that supports endpoint security within virtual machines. The Guest Introspection Agent must be installed and running in each guest VM, and logged-in users should not have the privilege to remove or stop the agent. This architecture enables third-party security solutions to inspect guest operating system activity without requiring agents to be installed directly on the hypervisor. The security and integrity of the guest operating system must be maintained for these integrations to function correctly.

For container workloads, the VCF CLI supports cosign signature verification for container images through the `imgpkg` tool, which enables finding and copying cosign signatures. Image pull authentication through `imagePullSecrets` restricts container image pulls to authenticated private registries. Plugin discovery image signature verification is supported, with configurable public key paths for the cosign verifier. These capabilities help restrict deployment of images that have been tampered with.

VCF Operations supports the deployment and monitoring of agents on endpoint virtual machines, with guest operation privileges required to install agents. Automated software update capabilities in vCenter help keep systems current with security patches, reducing the window of exposure to known malware exploits.

For organizations that deploy VMware vDefend, a separately licensed advanced service, distributed malware prevention capabilities become available. The NSX Application Platform hosts the Malware Prevention for vDefend feature, which can be deployed from the Local Manager UI in NSX Federation environments. When host clusters are activated for Distributed Malware Prevention, a service virtual machine (SVM) is deployed on each host to perform malware scanning. vDefend also supports IDS/IPS capabilities alongside distributed malware prevention. The DistributedMps runbook is available to verify the health of the Malware Prevention Service pipeline and diagnose issues such as protection not working on a particular VM or certain files not being scanned.

Malware prevention activities generate log data for audit and forensic purposes. The Malware Prevention for vDefend feature writes log files that can be used for troubleshooting and security monitoring, and remote logging can be configured on the malware prevention SVMs for centralized log collection.

VMware Private AI Services (PAIS) includes model validation capabilities that scan machine learning model files for malicious content before they are accepted into a Model Gallery. The validation runs as a sandbox process on Deep Learning VMs and covers integrity verification through hash code checking, malware scanning, serialization attack scanning, and inference behavior testing with NVIDIA Triton Inference Server. Both the malware and serialization checks run as part of the validation workflow required before a model can be uploaded to a Model Gallery and made available to downstream model endpoints, knowledge bases, or AI agents.

Machine learning model files are a category of artifact that traditional endpoint security tools may not inspect. Serialized models in formats such as Python pickle files can carry executable payloads that activate when an application or researcher loads the model. The PAIS Model Gallery intake workflow treats this upload boundary as a security checkpoint, requiring each artifact to pass hash, malware, serialization, and inference behavior tests before it is published for use. PAIS guidance also directs organizations to distribute only models that have been validated internally on a Deep Learning VM rather than pulling artifacts directly from the Internet, where models may contain malicious code or be tuned for malicious behavior. The validation is operated by MLOps engineers, who confirm that onboarded models meet the organization's security, privacy, and technical requirements.

For platform-level malware protection covering virtual machines, VMware ESX hosts, and general workloads running on the PAIS infrastructure, organizations rely on VCF platform controls and, where deployed, VMware vDefend. PAIS adds the specialized scanning layer applied to AI model artifacts at the point of intake, addressing a threat surface that general-purpose antimalware tools do not typically cover.

VMware vDefend (Contributes)

VMware vDefend provides multiple layers of malicious code detection and prevention through its Malware Prevention Service and IDS/IPS capabilities. Together these address the detection aspect of this control directly and contribute to the eradication aspect by restricting malicious code from executing and spreading across the network.

The Malware Prevention Service deploys as a service virtual machine (SVM) on each host in a cluster, with Guest Introspection thin agents installed on each protected guest VM. This architecture separates the detection engine from the protected workload, giving the service visibility into file activity, process execution, and network events from outside the guest. On Linux guests, a File and Network Agent handles file and network traffic introspection. A Host Agent (MUX) component running on ESX hosts supports the Guest Introspection functionality.

The service detects both known and unknown malicious files, including zero-day threats. Supported file categories include Windows executables (.exe, self-extracting), Linux executables (.elf), installer files (.msi), and shortcut files (.lnk), among others. When a file is analyzed, Malware Prevention assigns a verdict and classifies the threat by malware class (virus, trojan horse, worm, adware, ransomware, spyware) and malware family. A single detection event can be associated with multiple malware families and classes. Upon detection, the service can take direct remediation actions, including denying access to suspicious files or deleting files identified as malicious. An allowlist capability enables administrators to override verdicts for files known to be legitimate, suppressing false positives without disabling broader detection.

Beyond file-based detection, Malware Prevention Service includes fileless malware detection to identify attacks that operate entirely within system memory using existing binaries and in-memory operations such as PowerShell or VBScript, without

leaving executable artifacts on disk. The service monitors Indicators of Compromise including process command lines, process hashes, process execution trees, and in-memory executions. In-memory script buffer executions are scored for threat severity and assigned a verdict of malicious or suspicious, with the associated malware family and class displayed on the Malware Prevention Dashboard.

When malware is detected, the service extracts artifacts and in-memory script buffers that security teams can use to define incidents of compromise and create new detection rules for similar future threats. This extends malware coverage as new threat patterns are identified within the environment.

The Malware Prevention Dashboard in Security Services Platform aggregates detection events for malicious files, suspicious files, and uninspected files over configurable time periods. Each unique file is tracked by hash, and events can be filtered by verdict criteria. This centralized visibility allows security teams to identify malware incidents, track detection trends, and coordinate eradication efforts across the virtualized environment.

vDefend IDS/IPS provides signature-based and behavioral intrusion detection and prevention at the distributed firewall level, complementing Malware Prevention with network-layer detection of malware delivery attempts, command-and-control communications, and lateral movement patterns associated with malware infections. IDS/IPS operates at the virtual network interface level, providing visibility into east-west traffic between workloads that perimeter security tools cannot inspect.

While vDefend provides strong detection and file-level remediation capabilities, complete eradication of malicious code from infected guest operating systems typically requires endpoint security agents operating inside the guest. vDefend restricts malware from spreading across the network and blocks or removes detected malicious files, but cleaning an already-infected system requires host-level remediation tooling.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) generates audit records from multiple internal sources and provides mechanisms to centrally view, access, and export those records for review and analysis. The platform captures audit events covering user

actions performed through the DSM UI and API, as well as actions that DSM itself initiates. This includes administrative operations, database lifecycle events, and system-level activities. The System Audit Events view, accessible through the System Audit section of the Provider interface, is the central location for tracking non-database-related operations and tasks.

The audit records generated by DSM contain structured fields that support systematic review. Each audit event includes a Component field identifying which DSM component performed the operation, an Event Type field identifying the category of the event, an Event Details field providing operation-specific context, Event Time in UTC, a Status field, and a Source field identifying either the user identifier (Email ID) that initiated the operation or "System" when DSM itself initiated it. Gateway audit log files are stored on the Provider VM at `/var/log/tadm/provider/audit/` with filenames in the format `gateway-audit-timestamp.log`, and contain standard Kubernetes audit events. When a default S3 provider log repository is configured, DSM automatically archives gateway audit log files to that repository on a periodic basis to an S3 subpath named "gateway audit," providing an off-platform collection point.

For database-level audit logging, PostgreSQL databases provisioned by DSM include the `pgaudit` extension, which provides audit logging capabilities across all supported PostgreSQL versions. The `pgaudit` extension captures database-level audit events separately from the gateway-level audit trail, giving administrators visibility into both infrastructure-level operations and database operations as distinct audit sources. SQL Server databases provisioned by DSM include configurable server auditing with preset audits for login tracking and log retention. The Login Auditing option automatically creates an audit for login events, and DSM supports the T-SQL `CREATE AUDIT` and `CREATE AUDIT SPECIFICATION` DDL for custom audit definitions. These SQL Server capabilities add a third distinct audit source alongside gateway and PostgreSQL audit streams.

DSM supports audit record export in CSV and XLSX formats through the ACTIONS dropdown in the System Audit Events view. Exports include all audit events visible to the current user regardless of pagination limits. DSM also supports log forwarding via syslog, enabling organizations to route audit data to external log management and SIEM platforms for automated collection and analysis across multiple sources. VI administrators can monitor PostgreSQL and MySQL clusters deployed by DSM using VCF Operations, which automatically discovers clusters in the Ready state and displays performance data at the cluster, node, and database levels.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer contributes to malicious code protection at the application delivery layer through WAF-based payload inspection, IP Reputation threat intelligence, Application Rules, and Bot Management.

The Avi WAF inspects inbound HTTP/HTTPS request bodies and parameters against signature-based rules, including ModSecurity rules, to detect and block exploit payloads, injection attacks, and known malware delivery patterns. WAF rules are configurable per virtual service and can be tuned to reduce false positives while maintaining coverage of malicious traffic patterns. Configuration is managed through the Avi Controller UI under the WAF Policy section for each virtual service.

The Application Rules service, available through Avi Cloud Console Live Security Threat Intelligence, provides automatically updated WAF rules targeting known vulnerabilities with CVE mappings across more than 5,000 applications, including WordPress, Drupal, and Apache. These rules are pushed automatically to Avi Controllers, reducing the window between vulnerability disclosure and protection.

Avi's IP Reputation service provides a threat intelligence feed that classifies IP addresses known to be infected with malware or identified as contacting malware distribution points (threat category code 6). The service also identifies IP addresses known to distribute malware, shell code, rootkits, worms, or viruses, including Windows exploit IP addresses. An "All threats" classification (threat category code 32) can be applied to block any suspicious IP addresses at the application delivery layer. IP Reputation data is synchronized via Avi Cloud Services and can be referenced in virtual service policies to block malicious source traffic before it reaches protected workloads. This is configured under Administration > External Services > Cloud Services.

Avi Bot Management provides a default System-BotDetectionPolicy that can be bound to virtual services to detect and mitigate malicious bots used in online fraud, credential stuffing, and automated data scraping. Bot Management performs heuristic scanning of User-Agent strings to detect malicious patterns such as SQL injections, marking such requests as bad bot

of type web attack. In Kubernetes deployments, the Avi Kubernetes Operator (AKO) supports assigning a BotDetectionPolicy to virtual services via the botPolicyRef parameter, extending bot detection to Kubernetes ingress workloads.

Avi WAF does not include built-in virus or file-content malware scanning. Avi documentation explicitly recommends deploying a dedicated virus and malware scanning tool on the upload directories of protected applications to detect and mitigate malicious uploads, including uploads that may bypass WAF inspection. Malware detection and eradication for workloads running behind Avi is the responsibility of endpoint protection tools deployed on those workloads. Organizations should configure WAF policies, Application Rules, IP Reputation, and Bot Management on Avi virtual services while also deploying dedicated antimalware solutions on application workloads and their supporting infrastructure.

Control 6.2

Software Integrity

SCF Controls: END-06, END-06.1, IRO-01, IRO-02, MON-01.7, MON-02, MON-02.2

Aggregate Coverage: Meets

VCF (Meets)

VCF provides multiple layers of integrity checking for software, firmware, and configurations across the platform stack, from hardware boot validation through ongoing operational monitoring.

At the hardware level, VCF supports Secure Boot, Trusted Platform Modules (TPM), and Intel Trusted Execution Technology (TXT) to validate system firmware and boot integrity. VMware vCenter can retrieve the TPM event log for configuring firmware trust with an attestation service or validating boot-time TPM measurements, and APIs are available to list configured TPM devices and endorsement keys on each host. The hypervisor enforces code signing to restrict execution to authorized code. Each vSphere Installation Bundle (VIB) has an associated acceptance level, controlled through the Host-Image-Profile-Acceptance-Level setting, and VIB signature validation uses a cryptographic checksum to confirm that each package was produced by its authorized author.

vSphere Lifecycle Manager (vLCM) is the primary tool for software and firmware integrity validation. Administrators define a desired software specification for each cluster, and vLCM compares the committed specification against each host to identify drift from the expected software baseline. A compliance check can be performed against the committed draft to confirm host conformance. The `Initialize-SettingsHostsSoftwareCheckSpec` cmdlet in PowerCLI initializes a software check specification with a `commit` parameter to define the desired software version, and the `Invoke-CheckHostSoftwareAsync` cmdlet runs a remediation pre-check to confirm software and hardware compatibility before applying changes. When enabling a cluster to use a software specification, administrators can submit a `Software.CheckSpec` structure to define which preliminary checks to run. Draft specifications can be validated before committing to confirm they are complete and conflict-free, and remediation pre-checks include hardware compatibility validation to identify issues before applying updates. When vLCM downloads a software package for a host update, it verifies the SHA-256 checksum of each downloaded package to confirm integrity before applying it. The vSphere Image Library provides a complementary SHA-256 verification mechanism: administrators can compare the checksum of an imported image against the checksum generated when the image was created, supporting integrity validation when images are transferred between different vCenter instances.

vSphere Configuration Profiles extend desired-state management by enabling drift detection for vSphere clusters. When Configuration Profiles are enabled, VCF Operations monitors drift status through a collection cycle that runs every 8 hours, providing a proactive method to detect when cluster configurations have changed from their expected state.

vCenter includes File Integrity Monitoring, which maintains cryptographic checksums representing the current state of the vCenter file system and schedules periodic integrity scans. The File Integrity Monitoring Status API, accessible via standard HTTPS requests, returns a `files_changed` boolean field indicating whether monitored files have been altered and a `check_time` field containing the Unix timestamp of the last completed scan. Administrators can configure the scan frequency in seconds through the API, allowing the monitoring interval to be tuned for operational requirements.

VCF Operations extends configuration validation to the broader VCF deployment. It exposes a `POST /v1/vcf-management-components/validations` API endpoint that validates JSON deployment configuration files before they are applied. The VCF Installer deployment wizard similarly validates install specifications before starting the setup process, allowing administrators to review failed validations and resolve issues using the remediation information provided in error messages. An optional API operation allows administrators to verify whether an install spec is valid before beginning deployment. The configuration validation process examines configuration files for errors and conflicts, returning output that helps avoid loading an incorrect configuration.

For virtual machines, VCF supports UEFI Secure Boot to verify guest operating system integrity at boot time. VMware Tools packages are signed, with verification performed during installation and updates. VCF Operations management pack PAK files

are also signed with digital signatures that indicate the original developer or publisher and provide authenticity verification; VCF Operations displays a warning if a PAK file lacks a valid signature.

Certificate validation is built into the platform at multiple levels. VCF detects when certificates have expired or are nearing their expiration dates. The Certificates tab in VCF Operations displays certificate expiration status for each workload domain. VCF Operations provides a Certificates widget to view certificates that require attention based on their expiration dates. NSX Manager certificate expiry scanning identifies appliance certificates due to expire within 31 days, and critical severity alarms are generated after certificate expiration.

At the storage layer, vSAN provides data integrity checking through end-to-end checksum verification, confirming that each copy of a file matches the source. When a checksum mismatch is detected, vSAN automatically repairs the data by overwriting the incorrect copy with the correct version. The system checks data validity during read and write operations and reports errors when repair is not possible. Object checksum can be configured through vSAN storage policies to control whether checksum calculations are performed. vSAN configuration validation checks are performed as part of the host synchronization process, confirming that vSAN settings remain consistent across cluster members. RAID-5 and RAID-6 erasure coding provide additional data protection as policy-driven attributes that can be applied to virtual machine components.

The VMware Kubernetes Service (VKS) and vSphere Supervisor layer extends integrity checking to containerized workloads. At the Kubernetes API layer, administrators can deploy ValidatingAdmissionPolicy resources using Common Expression Language (CEL) expressions to enforce configurable validation checks on every object submitted to the API server. The validationActions field controls whether validation failures generate audit log entries, warnings, or hard rejections, and the failurePolicy field defines how policy evaluation errors are handled, including failures from CEL parse errors, type check errors, and runtime errors. ValidatingAdmissionWebhook resources provide an additional validation layer after all mutations are complete. For container image integrity, the kubelet image verification mode is configurable per VKS cluster with four settings: NeverVerify, NeverVerifyPreloadedImages (the default), NeverVerifyAllowlistedImages, and AlwaysVerify; the AlwaysVerify setting requires cryptographic signature verification for every image before it is permitted to run. Admission controllers can automatically verify image signatures at deploy time to validate their authenticity and integrity. Harbor, available as a Supervisor service and certified by Broadcom for compatibility with Supervisor networking, storage, and authentication, provides registry-layer integrity controls including vulnerability scanning, content trust, and policy-based replication; Harbor signs images as trusted before they are available for deployment. During VKS cluster lifecycle operations, pre-checks are enforced before cluster upgrades to validate system state and confirm compatibility. The VCF CLI binary, used for Consumption layer operations, can be verified using a sha256sum.txt checksum file available alongside the CLI download from the VCF Automation Tenant Portal.

For ongoing configuration integrity monitoring, VCF Operations includes a Compliance Checks capability that supports compliance validation throughout workload transitions. Organizations can run compliance checks in parallel and review the results to identify where configurations have drifted from established security baselines. VCF supports checking system configurations against DISA STIG requirements using automated tools, providing a mechanism to validate that security configurations remain aligned with the established hardening standards. DISA STIGs are also available for Supervisor and VKS release (VKr) components, extending this hardening validation to the containerized workload layer.

VMware vDefend (Contributes)

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include

an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) generates audit records from multiple internal sources and provides mechanisms to centrally view, access, and export those records for review and analysis. The platform captures audit events covering user actions performed through the DSM UI and API, as well as actions that DSM itself initiates. This includes administrative

operations, database lifecycle events, and system-level activities. The System Audit Events view, accessible through the System Audit section of the Provider interface, is the central location for tracking non-database-related operations and tasks.

The audit records generated by DSM contain structured fields that support systematic review. Each audit event includes a Component field identifying which DSM component performed the operation, an Event Type field identifying the category of the event, an Event Details field providing operation-specific context, Event Time in UTC, a Status field, and a Source field identifying either the user identifier (Email ID) that initiated the operation or "System" when DSM itself initiated it. Gateway audit log files are stored on the Provider VM at `/var/log/tdm/provider/audit/` with filenames in the format `gateway-audit-timestamp.log`, and contain standard Kubernetes audit events. When a default S3 provider log repository is configured, DSM automatically archives gateway audit log files to that repository on a periodic basis to an S3 subpath named "gateway audit," providing an off-platform collection point.

For database-level audit logging, PostgreSQL databases provisioned by DSM include the `pgaudit` extension, which provides audit logging capabilities across all supported PostgreSQL versions. The `pgaudit` extension captures database-level audit events separately from the gateway-level audit trail, giving administrators visibility into both infrastructure-level operations and database operations as distinct audit sources. SQL Server databases provisioned by DSM include configurable server auditing with preset audits for login tracking and log retention. The Login Auditing option automatically creates an audit for login events, and DSM supports the T-SQL `CREATE AUDIT` and `CREATE AUDIT SPECIFICATION` DDL for custom audit definitions. These SQL Server capabilities add a third distinct audit source alongside gateway and PostgreSQL audit streams.

DSM supports audit record export in CSV and XLSX formats through the ACTIONS dropdown in the System Audit Events view. Exports include all audit events visible to the current user regardless of pagination limits. DSM also supports log forwarding via syslog, enabling organizations to route audit data to external log management and SIEM platforms for automated collection and analysis across multiple sources. VI administrators can monitor PostgreSQL and MySQL clusters deployed by DSM using VCF Operations, which automatically discovers clusters in the Ready state and displays performance data at the cluster, node, and database levels.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides configuration integrity validation through automated pre-operation checks, on-demand consistency verification, and image integrity verification at the application delivery layer.

The Avi Controller CLI includes a `show config-consistency-check` command that reports the current consistency state of controller configuration. Operators can run this command at any time to verify that configuration state is consistent across cluster nodes and to surface any drift or discrepancies.

Before upgrade operations, the Controller runs automated pre-upgrade verification that confirms Controller Cluster readiness, detects whether an upgrade is already in progress, validates active version compatibility across the cluster, and verifies Service Engine reachability. In the Avi for VCF deployment, the Controller requires verification of image checksums or digital signatures to confirm file integrity before upgrade proceeds. A system configuration check validates the overall system state before upgrade operations begin. The upgrade pre-check system produces mandatory error messages for requirement violations that cannot be overridden and warning messages for optional requirements that can be skipped. The Avi Controller system report for upgrade operations records each pre-check result, including check code, description, state, start time, end time, and duration, providing a full audit record of the validation sequence.

The Dry Run feature performs configuration validation in an isolated container before an upgrade is committed, including partial Controller initialization, configuration migration, new schema item validation, and configuration testing. Operators can review progress using the VIEW PROGRESS option under Administration > Update > System and return to the pre-check screen to evaluate results before proceeding.

Before applying patches, the Controller performs patch compatibility checks to verify that a patch is safe to apply and that system stability will be maintained. Before restore operations, the Controller executes a pre-restore validation sequence covering Controller Cluster readiness, active upgrade operation detection, ServiceEngineGroup upgrade status, backup configuration version compatibility, FIPS mode compatibility, image object presence, configuration validity, and FIPS mode alignment between the backup file and the target environment.

The Avi Controller maintains checksums and creation timestamps for custom IPAM script files, providing integrity tracking and an audit trail for configuration scripts used in custom IPAM implementations.

For FIPS 140-3 compliance, Avi Load Balancer applies enhanced controls over software and firmware module integrity and module updates, including tighter requirements on module update procedures.

In Kubernetes deployments, the Avi Kubernetes Operator (AKO) performs syntactical validation of Custom Resource Definition (CRD) objects at creation time, verifying configuration correctness and surfacing errors through effective status messages. AKO also monitors certificate files and Kubernetes secrets, with certificate and secret update events visible via AKO logs.

These mechanisms operate at the Avi application delivery layer. Software and firmware integrity for the underlying compute, storage, and networking infrastructure relies on VCF through Secure Boot, VIB acceptance levels, and TPM attestation, which are covered under VCF Coverage. Organizations should account for both layers when demonstrating full coverage of this control.

Control 6.3

Database Integrity

SCF Controls: AST-28, AST-28.1, IRO-01, IRO-02, MON-02, MON-02.2

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 6.4

Logging and Monitoring

SCF Controls: DCH-18, MON-01, MON-01.16, MON-02, MON-02.2, MON-08, MON-10

Aggregate Coverage: Meets

VCF (Meets)

VCF provides centralized collection and management of security-related event logs across all platform components. Every major subsystem supports syslog forwarding to external log aggregation infrastructure, enabling integration with any SIEM or centralized logging platform that accepts standard syslog input. In addition, VCF Log Management provides a built-in log aggregation and analysis capability within the platform itself.

VMware ESX hosts can be configured to send syslog messages to a remote log server using the `esxcli system syslog config set` command, specifying the target server IP address and port. ESX syslog messages conform to RFC 3164. Configurable syslog log levels allow administrators to tune the verbosity of forwarded events using `esxcli system syslog` commands. The syslog directory location on ESX hosts is controlled through the `Syslog.global.logDir` parameter. The `Syslog.global.auditRecord.remote` parameter separately controls whether security audit records are transmitted to the remote hosts configured in `Syslog.global.logHost`. ESX hosts maintain local logging with configurable retention and rotation policies, maintaining six log files that rotate at each power-cycle by default or at a configured file size. When the configured file limit is reached, the oldest file is deleted. The ESX Dump Collector and vSphere Syslog Collector can be configured to redirect ESX memory dumps and system logs to a network server for persistent log storage.

VMware vCenter provides syslog forwarding through both its management API and direct configuration. The vCenter Management API exposes endpoints to set the syslog forwarding configuration (PUT), retrieve the current configuration (GET), and test the connection with remote syslog servers (POST). vCenter syslog forwarding supports TCP, UDP, TLS, and RELP protocols, giving administrators flexibility in how log data is transmitted to the collection infrastructure. The remote syslog target must be a server running rsyslog. vCenter event streaming to a remote syslog server is activated through the `vpzd.event.syslog.enabled` option in the vCenter Management Interface, and the Appliance Management Interface supports a maximum of three remote syslog destination hosts. vCenter retains performance data with configurable intervals and automatic purge policies.

NSX Manager can export syslog to a remote server with configurable protocol, port, and log level. NSX audit logs, which record security-related events such as logon, logoff, and access to resources, are sent directly to the configured remote syslog server. NSX Manager audit logs also record failed login attempts with username and timestamp information, and log user account role changes for remote users authenticated through identity sources. Each audit log entry contains the timestamp, source, result, and a description of the event. API calls from all sources and users are audited, and each audit log associated with an API call includes a request ID parameter for traceability. This logging is always enabled and cannot be disabled. NSX also captures logical switch messages and other operational events in its audit log. On ESX hosts, NSX syslog data is stored in `/var/log/nsx-syslog` and can be forwarded alongside other host logs. NSX Manager syslog supports TLS protocol on port 6514 for encrypted log transmission.

VCF Log Management is the centralized log collection platform within the VCF stack, gathering logs from vCenter, ESX hosts, NSX, VCF Operations, and VCF Operations for Networks. It can be configured to pull tasks, events, and alerts from vCenter instances and receive syslog feeds from ESX hosts through its Log Collections configuration. VCF Log Management provides an analysis interface where administrators can search and filter log events, create queries based on timestamp, text, source, and structured fields, and build dashboards for operational and security scenarios. Content packs for VCF components provide pre-built dashboards, alerts, and queries for common use cases, including a content pack for VCF Operations for Networks. Log-based alert definitions allow administrators to trigger notifications when specific log patterns are detected.

VCF Operations supports centralized log collection and editing of log sources through Infrastructure Operations, under Configurations and Log Collection. VCF Operations Host System Properties allow configuration of a remote syslog host for centralized log collection. The audit log in VCF Operations is integrated with syslog, and the syslog collector can be

configured to collect all audit logs. VCF Operations can also send user activity audit logs to an external syslog server. Audit logs capture administrative actions carried out through the API, the user interface, and the CLI, including regular CRUD operations and login/logout alerts. Note that SSH login logs are not captured in VCF Operations audit logs; SSH logs can be found in `/var/log/auth.log`. VCF Operations supports outbound integrations that distribute alerts and log data to external systems via email, SNMP traps, REST webhooks, log files, and Slack notification plugins.

VCF Operations for Networks supports centralized log collection and editing of log sources through its own Infrastructure Operations configuration. Remote syslog servers must be configured to accept syslog traffic over UDP. All platform servers in a VCF Operations for Networks cluster use the same remote syslog server, though individual collectors can be pointed to different remote syslog servers. The audit log in VCF Operations for Networks is integrated with syslog.

Additional VCF components also support centralized log forwarding. The Foundation Load Balancer supports forwarding logs to a syslog server via IP address configuration, with certificate-based secure communication for log forwarding. VCF Operations HCX supports configuring a remote syslog server that receives logs from both the HCX manager and appliance virtual machines, and appliances deployed after adding the external syslog server automatically forward log messages. VCF Identity Broker supports log collection as well.

The Consumption layer of VCF, which encompasses VMware Kubernetes Service (VKS) clusters running on vSphere Supervisor, provides its own log collection and forwarding capabilities that integrate with the broader platform logging infrastructure. Kubernetes audit logging within VKS generates a security-relevant, chronological record of cluster activity, documenting the sequence of API calls made by users, applications, and the control plane. This includes authentication events, authorization decisions, resource creation and modification, and user impersonation requests, with each impersonation request recorded individually in the audit log. Audit verbosity is governed by a Kubernetes audit policy that specifies which events to capture and at what level of detail; available backends for writing audit records include log files at `/var/log/kubernetes/audit/` and external webhook endpoints. Kubernetes system component logs are configurable for verbosity, ranging from coarse-grained error reporting to fine-grained trace output covering HTTP access logs, pod state changes, and other operational detail. Fluent Bit is available as a standard package for VKS clusters and serves as the log forwarding agent. Once deployed as a DaemonSet on every node, Fluent Bit collects Kubernetes container logs, API audit logs, Linux daemon logs, and Linux authentication logs, then forwards them to a configured destination. Supported forwarding destinations include Syslog (port 514 for UDP, port 6514 for TCP), HTTP endpoints, Elasticsearch, Kafka, and Splunk. When integrated with VCF Log Management, Fluent Bit forwards over the CFAPI protocol; VCF Log Management accepts log forwarding connections on HTTPS port 9543 or HTTP port 9000 at the `/api/v2/events` endpoint. A logging management server must be deployed and accessible from the VKS cluster to receive, store, and analyze forwarded logs; the Consumption layer provides the collection and forwarding mechanisms rather than the SIEM itself. The Supervisor control plane also forwards its VM system logs to external syslog servers in RFC 5424 format over TCP, managed by Fluent Bit pods in the `vmware-system-logging` namespace whose status can be queried using `kubectl` commands.

For workloads running as vSphere Pods within vSphere Namespaces, administrators configure the `LogAgentConfiguration` custom resource to stream syslog messages directly to a remote syslog server. Log messages from vSphere Pods include structured metadata fields covering namespace name, pod UID, pod name, container name, and ESX host name, enabling precise attribution and filtering at the receiving SIEM or log aggregation platform.

VCF also aligns with global compliance logging requirements: auditable events are logged across the platform. This baseline of audit event generation feeds into the centralized collection mechanisms described above.

VMware vDefend (Contributes)

VMware vDefend (vDefend) supports network security monitoring through multiple integrated capabilities that contribute to enterprise-wide monitoring frameworks.

Security Intelligence, hosted on the Security Services Platform (SSP), provides continuous visibility into network traffic flows across protected workloads. It monitors flows between application pairs, updates the Policy Protection Status for each application to indicate that flows are being monitored, and continuously detects new flows between environment pairs, alerting administrators to unauthorized or unexpected traffic. The Monitor & Plan Overview page presents a consolidated view

of pending actions, data collection activity status, network security posture, flow trends, and a summary of suspicious traffic. The Security Intelligence Recommendations monitoring capability checks for changes in the scope of monitored entities every hour when the Monitoring toggle is enabled, allowing administrators to keep policy recommendations current as environments evolve. Segmentation Monitoring provides dedicated views of application and infrastructure flows with configurable time ranges spanning from the last hour to the last month, and displays flows related to detected infrastructure servers in a specified time interval.

The Network Detection and Response (NDR) Sensor checks the status of activated detection features every 15 minutes and updates its configuration accordingly, supporting sustained threat detection coverage. NDR Sensor health status monitoring tracks whether key components, including network traffic capture, file analysis, and data transmission, are operating properly. The NDR Sensor also sends alerts notifying administrators of conditions such as services being down, high CPU, memory, or disk usage, packet drops, or missed heartbeats. NDR provides role-based access control covering triage operations such as viewing detections and campaigns, as well as SIEM configuration management.

The Security Services Platform monitors its own health, with Yellow or Red health status indicators displayed when issues occur in subcomponents. SSP monitoring tracks the status of the flow clustering job that runs every hour and reports suspicious traffic detector execution status after each run, with values such as SUCCESS, NOT_ENOUGH_BASELINE, and FAILURE.

The Security dashboard provides a consolidated view for monitoring and configuring security features across network workloads. In federated deployments, the Global Manager provides centralized event management and monitoring for malicious IP blocking activity across all Local Managers.

vDefend generates Unified Security Logs that VCF Log Management can collect and analyze. These logs cover Distributed Firewall, Gateway Firewall, Identity Firewall, FQDN Analysis, TLS Inspection, Intrusion Detection/Prevention System (IDPS), and URL Filtering activity. Broader log aggregation and SIEM correlation for enterprise-wide monitoring remain the responsibility of the SIEM and logging infrastructure deployed alongside vDefend.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides monitoring capabilities specific to the disaster recovery domain and integrates with the broader VCF monitoring ecosystem through dedicated Protection and Recovery dashboards in VCF Operations. VCF Operations collects configuration, component health, and usage information from protection and recovery servers and site pairs, presenting this through an overview dashboard that displays all site pairs, configurations, health scores, and protection and recoverability status for sites and virtual machines. PNR provides default health alerts for protection groups, recovery plans, cloud file systems, recovery SDDCs, and protected sites through VCF Operations, and the dashboards surface alerts informing administrators about configurations and deployments that require attention. Separate dashboard views cover vSAN Snapshots and Replication monitoring, and an Inventory view provides health status, metrics, alerts, and network topology for all monitored objects.

Within its own domain, PNR provides event logging and configurable alarms for replication and recovery operations. Administrators can create alarms that trigger on specified event conditions, with support for email notifications, SNMP traps, or script execution in response. PNR monitors connections between sites by sending periodic ping requests, logs connection check events, and generates alarms when broken connections are detected. The alarm system generates warning-level alerts for expired snapshot schedules, replication errors such as missing VMs, and connectivity issues with protected and target sites. PNR also monitors resource consumption on the Protection and Recovery Server host and raises alarms when configurable resource thresholds are reached.

PNR includes a health monitoring service that checks each health finding every five minutes and records a timestamp at each check. Health findings are tracked with status history that can be reviewed over configurable time periods, defaulting to a 24-hour window. The Protection and Recovery Appliance supports syslog forwarding to a remote syslog server for log analysis and centralized monitoring, allowing appliance-level events to flow into existing log management infrastructure.

The Clean Room Orchestrator, part of PNR's Cyber Recovery capabilities, supports monitoring of clean room events, tasks, and alarms for recovery operations. Clean Room Orchestrator can forward events to VCF Operations, Microsoft Sentinel, or

Splunk Cloud for centralized monitoring, supporting organizations that require DR event data to flow into enterprise SIEM and log management platforms as part of a broader monitoring strategy. The Clean Room Orchestrator integrates with endpoint detection and response tools, including CrowdStrike and Carbon Black sensor appliances, for threat detection within isolated recovery environments.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) produces structured audit logs that record platform-level and gateway-level operations, and provides several mechanisms that contribute to protecting those logs from unauthorized access and loss.

At the platform level, DSM maintains gateway audit log files on the Provider VM at `/var/log/tdm/provider/audit/`, with individual files named using a timestamp format (`gateway-audit-timestamp.log`). Local retention covers the last five days of log files; once files are successfully uploaded to a configured S3 repository, DSM removes them from the local filesystem after five days. Each log entry captures structured fields including Component, Event Type, Event Details, Event Time (UTC), Status, and Source. The Source field records the email identifier of the user who initiated the operation, or "System" for events initiated by DSM without user intervention. The System Audit Events view, accessible through the Provider interface, is the designated location for reviewing non-database-related platform operations. Access to the Provider interface is scoped to the administrative role, restricting which users can read or interact with the system-level audit record.

DSM supports offloading audit logs to external storage as the primary mechanism for durable protection. When a default S3 provider log repository is configured, DSM periodically archives gateway audit log files to an S3 subpath named "gateway audit." DSM does not delete audit logs stored in the S3 repository, which means the archived log record persists beyond the five-day local retention window. Externalizing audit logs to S3 separates the log record from the Provider VM that generated it, reducing the risk that a compromise or failure of the Provider VM affects the integrity or availability of the audit trail. Organizations apply bucket-level access controls and retention policies on the S3 repository to restrict who can read, modify, or delete the archived logs.

DSM supports log forwarding, allowing DSM logs to be sent to a centralized log management or security information and event management (SIEM) platform via the System Logs capability. Forwarding logs to an external system provides a second copy of the audit record under access controls and integrity protections that are independent of the DSM platform itself.

For SQL Server databases provisioned through DSM, the SQL Server data service uses server-level DDL triggers to restrict the file paths available for audit logs, limiting where audit log files can be written. DSM supports enabling audit logging for SQL Server with configurable levels of auditing for system logins and a configurable log retention period. DSM can automatically create a simple audit for login events based on the Login Auditing option selected during cluster creation. For custom audit requirements, the standard T-SQL `CREATE AUDIT` and `CREATE AUDIT SPECIFICATION` DDL statements are available.

DSM can generate and download log bundles that aggregate relevant logs from database VMs, supporting diagnosis and out-of-band preservation of the operational log record.

Audit events can be exported from the System Audit Events view in CSV or XLSX format using the ACTIONS menu. Exports include all events visible to the authenticated user regardless of pagination, supporting external archival and out-of-band preservation of the audit record.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) contributes to enterprise-wide monitoring through application-delivery-layer mechanisms built into the Avi Controller and Service Engines.

The Avi Controller monitors Service Engine metrics and sends alarms and notifications to administrators when resource utilization data exceeds defined thresholds. Administrators configure custom thresholds on Service Engine groups through the Resource Events tab in the Avi UI. The Alert feature processes system events and metrics against user-defined rules and generates alerts that trigger configured actions, including sending an email, a syslog message, or an SNMP trap. Alert notifications can be forwarded to remote syslog servers for integration with centralized log management and monitoring platforms.

ControlScripts extend this event-response capability: a ControlScript can alter Avi configuration or communicate to external systems, including through webhook integrations with external monitoring tools, in response to defined system events. This supports dynamic responses including resource scaling or automated notifications based on health scores from monitoring data.

The Avi Controller and Service Engines track health score changes and SSL certificate expiration events. Avi integrates with external monitoring tools such as Prometheus for metrics collection and analysis. User-Defined Metrics allow administrators to define and extract customized telemetry data for specific compliance or reporting needs through the API. Real-time metrics are available via API but deactivate by default after 30 minutes to conserve resources and must be reactivated when sustained real-time visibility is required.

At the data plane, Avi health monitors track the status of backend servers and Service Engines continuously. Service Engine health monitoring records detailed server operational status, including health monitor name, type, last transition timestamps, rise count, fall count, total checks, and total failed checks. Each health monitor can be assigned its own threshold and timeout period for server health validation. Monitors support HTTP, HTTPS, TCP, and UDP health-check protocols with configurable success and failure thresholds, send intervals, and receive timeouts.

In Kubernetes environments managed by the Avi Kubernetes Operator (AKO), the HealthMonitor custom resource definition (CRD) allows users to define custom health monitoring configurations for backend services with fine-grained control over health check parameters. The Avi Multi-Cluster Kubernetes Operator (AMKO) GlobalDeploymentPolicy supports health monitor references for consistent monitoring across multi-cluster deployments. Within VCF Automation, a HealthMonitor custom resource can create monitors for tracking backend pool member status using TCP, PING, and HTTP check types.

Control 6.5A

Intrusion Detection: Detect and contain anomalous network activity into the local or remote SWIFT environment.

SCF Controls: END-07, MON-01, MON-01.1, NET-08

Aggregate Coverage: Meets

VCF (Contributes)

VCF provides networking infrastructure through NSX that supports the deployment of intrusion detection and prevention capabilities across virtualized environments. The VCF stack includes IDS/IPS and distributed malware prevention through vDefend, a separately licensed product that extends NSX with security functions, and these capabilities can be configured on discovered host clusters using the NSX UI or API. vDefend Distributed IDS/IPS is also available for consumption under NSX Projects, allowing IDS/IPS policies to be scoped to specific tenants or workload groups within the platform.

The IDS/IPS functionality in the VCF stack is delivered through VMware vDefend with Advanced Threat Prevention (ATP). ATP combines multiple detection technologies, including an Intrusion Detection/Prevention System, network sandboxing, and Network Traffic Analysis (NTA), with aggregation, correlation, and context engines from Network Detection and Response (NDR). vDefend with ATP is a software-defined Layer 2-7 firewall purpose-built to secure virtualized workloads in a private cloud, providing stateful firewalling with threat prevention capabilities. The NSX Application Platform hosts the features that support these advanced capabilities, including Security Intelligence, vDefend Network Detection and Response, and Malware Prevention for vDefend.

Administrators configure IDS/IPS rules through the Security > IDS/IPS & Anti-malware page in NSX Manager. vDefend distributed firewall rules can be created with an IDPS security profile applied in either Detect Only or Detect and Prevent mode, allowing organizations to start with visibility before moving to active blocking. vDefend signature-based identification and enforcement provides visibility into, or restriction of, protocols that have known vulnerabilities across all deployed applications and their east-west flows within the datacenter. The NSX Distributed Load Balancer can apply vDefend IDPS and Anti-malware Prevention features for traffic traversing load-balanced services.

To supplement signature-based detection, vDefend supports a Malicious IP Feed that downloads a list of known malicious IP addresses from the NTICS cloud service. Administrators can create groups that include these downloaded IPs and configure vDefend firewall rules to block access to them, providing a threat-intelligence-driven layer of protection. NSX App IDs further support traffic inspection by enabling network traffic classification and control based on application identity rather than port or protocol alone, helping reduce both north-south and east-west attack vectors.

The vDefend distributed firewall can be configured on vSphere Distributed Switches in data centers and workloads where segmentation, visibility, or advanced security capabilities are desired. This distributed architecture places IDS/IPS inspection at each host rather than relying solely on chokepoint-based appliances, providing coverage for east-west traffic that traditional perimeter IDS/IPS solutions do not inspect. The packet interception mechanism underlying this distributed inspection is DVFilters, which operate at the VMware ESX kernel level to intercept packets at each virtual machine's virtual NIC. When deploying IDS/IPS in environments where vSphere vMotion is in use, administrators should verify that IDS and firewall rules permit the ports used for vMotion on ESX hosts. VCF's networking layer, NSX, is the foundation on which vDefend positions its detection and prevention sensors across the environment, providing the traffic routing and distributed switch architecture that the vDefend sensors attach to.

Organizations deploying VCF should note that while the platform provides the technical IDS/IPS capabilities described above, effective intrusion detection and prevention also requires ongoing operational processes: signature and feed updates, alert triage and tuning, incident escalation workflows, and integration with a security operations center or SIEM for centralized monitoring. The vDefend components that deliver IDS/IPS are licensed separately from the base VCF platform.

VMware vDefend (Meets)

VMware vDefend provides network intrusion detection and prevention capabilities that directly address this control. vDefend with Advanced Threat Prevention combines multiple detection technologies, including Intrusion Detection/Prevention System (IDS/IPS), Network Detection and Response (NDR), and Network Traffic Analysis (NTA), with aggregation, correlation, and context engines to detect and prevent network intrusions.

vDefend Distributed IDS/IPS operates at the hypervisor level, inspecting both north-south and east-west traffic. Administrators configure and manage intrusion detection and prevention policies through the NSX Manager interface, where they create IDS/IPS profiles, organize signature-based detection policies, and apply them through distributed firewall rules. The distributed architecture places IDS/IPS inspection at the vNIC level on every protected workload, providing visibility into lateral traffic between VMs that traditional perimeter-based NIDS/NIPS cannot see. IDS/IPS can be deployed in Detect Only mode or in Detect and Prevent mode, giving administrators control over enforcement posture.

Signature management is automated. vDefend IDS/IPS downloads the latest intrusion detection signatures automatically, either directly from the Internet or through a proxy server. Signatures are bundled with custom detection logic that can be updated without recompiling or modifying the IDS engine itself, allowing signature updates to take effect immediately. System Signatures are managed through the Local Manager interface under Security > IDS/IPS & Malware Prevention > Signature Management > System Signatures. When building IDS/IPS profiles, administrators filter included signatures by Intrusion Severities, Attack Types, CVSS scores, Attack Targets, and Products Affected, allowing precise tuning of the detection scope. Administrators can also configure thresholds for individual signatures to control how frequently a signature generates an IPS event, and rate filters that dynamically adjust a rule's action when specific traffic conditions are met. Profiles can also enable packet capture for later analysis of matched traffic.

Beyond automatic signature bundles, administrators can create custom signatures to detect malicious traffic specific to custom applications or to address zero-day vulnerabilities. Custom signatures support specific alert conditions, content matching, thresholds, and metadata, and can be included in IDS/IPS profiles applied to both the Distributed Firewall and Gateway Firewall. In multi-site environments, custom signatures can be managed from Global Manager. Network Detection and Response also consumes IDPS detections generated from custom IDS signatures, surfacing them alongside other detection events within the NDR interface.

NDR extends detection beyond signature matching. Network Detection and Response detects IDS events through signature matches against network traffic in the protected network and integrates with Distributed IDS/IPS to display IDS event details within the NDR interface. NDR Sensor IDS monitors network traffic for suspicious activities or known threat signatures, alerting on potential security breaches. NDR Sensor IDS Packet Capture records raw network packets associated with detected intrusion events, supporting forensic analysis and incident response.

Security Intelligence provides operational visibility into intrusion activity. Intrusion history can be filtered by action, attacker IP, attacker port, PCAP UUID, profile, rule, target IP, target port, and detection location. The IDS/IPS monitoring dashboard allows filtering of intrusion events by multiple criteria to support security event triage and analysis. Per-workload visibility includes impact scoring, signature details, and detection status for each protected VM. Each intrusion event is tagged with a Signature ID and associated protocol information, supporting precise identification and correlation during incident analysis.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides monitoring capabilities specific to the disaster recovery domain and integrates with the broader VCF monitoring ecosystem through dedicated Protection and Recovery dashboards in VCF Operations. VCF Operations collects configuration, component health, and usage information from protection and recovery servers and site pairs, presenting this through an overview dashboard that displays all site pairs, configurations, health scores, and protection and recoverability status for sites and virtual machines. PNR provides default health alerts for protection groups, recovery plans, cloud file systems, recovery SDDCs, and protected sites through VCF Operations, and the dashboards surface alerts informing administrators about configurations and deployments that require attention. Separate dashboard views cover vSAN Snapshots and Replication monitoring, and an Inventory view provides health status, metrics, alerts, and network topology for all monitored objects.

Within its own domain, PNR provides event logging and configurable alarms for replication and recovery operations. Administrators can create alarms that trigger on specified event conditions, with support for email notifications, SNMP traps, or script execution in response. PNR monitors connections between sites by sending periodic ping requests, logs connection check events, and generates alarms when broken connections are detected. The alarm system generates warning-level alerts for expired snapshot schedules, replication errors such as missing VMs, and connectivity issues with protected and target sites. PNR also monitors resource consumption on the Protection and Recovery Server host and raises alarms when configurable resource thresholds are reached.

PNR includes a health monitoring service that checks each health finding every five minutes and records a timestamp at each check. Health findings are tracked with status history that can be reviewed over configurable time periods, defaulting to a 24-hour window. The Protection and Recovery Appliance supports syslog forwarding to a remote syslog server for log analysis and centralized monitoring, allowing appliance-level events to flow into existing log management infrastructure.

The Clean Room Orchestrator, part of PNR's Cyber Recovery capabilities, supports monitoring of clean room events, tasks, and alarms for recovery operations. Clean Room Orchestrator can forward events to VCF Operations, Microsoft Sentinel, or Splunk Cloud for centralized monitoring, supporting organizations that require DR event data to flow into enterprise SIEM and log management platforms as part of a broader monitoring strategy. The Clean Room Orchestrator integrates with endpoint detection and response tools, including CrowdStrike and Carbon Black sensor appliances, for threat detection within isolated recovery environments.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to enterprise-wide monitoring controls through a layered set of observability capabilities covering database health, infrastructure compliance, and event-driven alerting.

DSM provides a built-in monitoring framework that tracks database instance health across multiple dimensions. From the Monitoring tab in the DSM UI or the vSphere Client, administrators and authorized users can view real-time and historical metrics for database VMs, including CPU Health, Data Disk Health, System Disk Health, Max Connections, Active Connections, Write Throughput, Read Throughput, Thread Resource Utilization, Slow Queries per Second, InnoDB Buffer Usage, and InnoDB Reads and Writes. The Monitoring page defaults to the last three hours of aggregated metric data, with the time range adjustable through the Time Range Last dropdown. This visibility supports detection of resource contention, performance degradation, and connectivity anomalies at the database layer.

DSM's alert framework provides configurable thresholds for warning and critical conditions on key health indicators. Administrators and users can set separate warning and critical thresholds for CPU Health, Data Disk Health, System Disk Health, and Max Connections parameters. When thresholds are exceeded, DSM generates typed alerts such as Database Engine Health, Custom Config Health, and Backup Storage Health alerts. DSM monitors database replication status and raises an alert when a secondary database is not replicating data from the primary. DSM also raises an alert when metrics are no longer being received from a cluster, supporting detection of monitoring gaps. Alerts can be activated or deactivated per data service through the "Enable Alerts for DB Alert" setting, providing granular control over which databases are subject to active alerting. For each alert, DSM provides mitigation suggestions to help administrators resolve issues without disrupting database services.

In addition to database-level alerts, DSM generates global infrastructure alerts that surface vCenter integration and infrastructure policy issues. These include `INFRASTRUCTURE_POLICY_VC_ALARMS`, raised when vCenter resource alarms are active; `INFRASTRUCTURE_POLICY_CLUSTER_COMPLIANT` and `INVALID_SUPERVISOR_INFRASTRUCTURE_POLICY_STATUS`, which reflect cluster compliance state; `VCENTER_CONNECTIVITY`, raised when vCenter connectivity fails and triggering troubleshooting steps that include verifying connectivity and checking authentication logs; and `LicensingNotUpdated` and `vCenterBinding` API status alerts that surface license and API integration conditions. A Global Alerts page in the DSM UI provides a centralized view of these alerts during and after installation and ongoing operation.

In 9.1, DSM integrates with VCF Operations to extend observability beyond the DSM UI. When configured, VCF Operations automatically discovers and monitors PostgreSQL and MySQL clusters in the Ready state and displays a Data Services View

dashboard showing active alerts and inventory items. VCF Operations presents performance data across three levels: cluster-level for overall health, node-level for infrastructure resource use, and database-level for KPIs including Active Connections, Commits, Rollbacks, and Deadlocks. This integration requires configuring the connection between DSM and VCF Operations before use.

DSM also adds SQL Server as a supported database type, with dedicated monitoring through an integrated InfluxDB instance and Telegraf agents deployed across the provider appliance and SQL Server workload clusters. The monitoring framework supports metrics-based and status-condition-based alerts for SQL Server, covering database engine degradation, non-operational status, and automated or transaction log backup failure conditions.

DSM supports event notification to external systems through a webhook integration. Webhooks transmit alert notifications containing the triggered date, triggered time, triggered user email, task status, previous status, and task type. This allows DSM alerts to feed into centralized monitoring or incident management platforms maintained by the organization. DSM generates plug-in registration logs that administrators can review for vCenter connectivity errors, and DSM's troubleshooting guidance directs administrators to review active vCenter infrastructure alarms and resolve underlying issues identified through the alert system.

Enterprise-wide monitoring requires organizational decisions about monitoring architecture, log aggregation platforms, alerting policies, and operational response procedures that lie outside DSM's scope. DSM provides the data and integration points; the organization must determine how those signals are collected, correlated, and acted upon across the broader environment.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) contributes to network intrusion detection and prevention at the application delivery layer through IP Reputation-based threat classification, automated DDoS detection and response, bot management, and an Application Rules service.

The IP Reputation service classifies source IP addresses across a wide range of threat categories, including DoS and DDoS attack sources, malware-infected hosts, phishing sites, proxy services, network scanners, and botnets. When an IP address falls into a relevant threat category, administrators configure Network Security Policies on virtual services to identify and block connections from those addresses. Network Security Policy evaluates incoming client traffic based on network-level parameters and determines whether a connection should be accepted, discarded, or rate-limited, including dropping TCP SYN packets from flagged addresses. Shared IP groups allow a single blocklist to be referenced across multiple virtual service policies, so a flagged address can be blocked consistently across the application delivery tier.

For volumetric and protocol attacks, Avi Service Engines detect and mitigate DDoS attacks across Layer 4 through Layer 7, including DNS amplification attacks, DNS Reflection Ingress attacks, and NXDOMAIN attacks. Avi can also report or actively block attackers performing port scans as part of DDoS detection. DDoS attack mitigation mechanisms support IPv6 addresses, including mitigation for Neighbor Discovery Protocol (NDP) attacks. The Avi Controller monitors denial-of-service attack events with configurable alert levels and thresholds, tracking attack count metrics and generating alerts at configurable severity levels. When a SYN flood or other volumetric attack is detected, alert actions can automatically invoke ControlScripts that add the offending source IP address to a blocklist IP group attached to a network security policy, providing automated blocking in response to detected attack events. The Avi Security Manager creates network security rules and DNS rules for Service Engines to block the attacker's IP address, source port, and DNS record request types.

The Application Rules service, available through Avi Cloud Console, provides automatically updated rules specifically designed to block attacks on known application vulnerabilities, including those with published CVE identifiers. These rules extend the detection and prevention surface to application-layer attack patterns beyond IP reputation filtering.

The Bot Management capability identifies bot traffic intent, distinguishing benign bots from malicious actors such as scrapers, spam sources, click fraud engines, bot impersonators, and botnets. The IP Reputation service is also used as a source for bot detection and classification, combining IP-reputation detection, user-agent detection, and IP-location detection through the Bot Decision Component.

For Kubernetes environments, the Avi Kubernetes Operator (AKO) supports L4 Rule CRDs that express custom security policies applied to virtual service traffic, specifying configuration for DDoS attack detection and mitigation. These CRDs can also allow, deny, or rate-limit connections from individual or grouped IP addresses. HostRule CRDs can reference network security policy objects for consistent policy application across ingress resources.

These capabilities address intrusion detection and prevention at the application ingress path. Network-layer intrusion detection and prevention covering east-west and north-south traffic flows across the broader VCF environment is provided by VMware vDefend with IDS/IPS capabilities, which is a separate product and carries the Meets rating for this control. Full satisfaction of the control requires NIDS/NIPS deployment at multiple network layers.

Control 7.1

Cyber Incident Response Planning: Ensure a consistent and effective approach for the management of cyber incidents.

SCF Controls: IRO-01, IRO-02, IRO-02.4, IRO-04, IRO-06

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support an organization's incident response operations, though it does not govern organization-wide incident response processes or maintain incident response documentation. VCF Operations is the primary platform for detecting, tracking, and investigating infrastructure-level incidents across the VCF environment.

VCF Operations includes a dedicated incident management system that displays all incidents with their current status and key metadata. Each incident record tracks state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation. Operators can edit, share, and delete incidents directly from the incident list interface, and the system maintains an audit trail of who created each incident and when. This structured tracking provides the documentation trail that incident response processes require.

For incident investigation, VCF Operations provides root cause analysis tooling through its Troubleshooting Incident Page. This interface displays information about the affected entity, including traffic and flow data, any past incidents created for the same entity, and root cause metrics. Investigators can flag individual metrics and mark specific metrics as the root cause of an incident. The system also allows drill-down into related entities to view detailed metrics for problem investigation, supporting a methodical approach to identifying the source and scope of an issue. A summary view displays the count of in-progress incidents, entity counts, and top root causes, which supports situational awareness during active incident response and helps teams prioritize efforts across multiple concurrent issues.

For detection, VCF Operations performs event correlation across monitored systems, correlating a subset of published events and delivering them as faults. The platform maps events from target systems into the VCF Operations severity model, with event severity ranked from Info to Immediate. This automated correlation and severity classification helps operations teams identify incidents that require immediate response. Notification rules can be configured to trigger actions based on incident state changes, with configurable fields including incident state, resolution code, on-hold reason, impact, urgency, priority, assignment group, assigned-to person, severity, approval actions, related problems, and change cause. VCF Operations also supports defining fault symptoms and metric event symptoms based on thresholds and conditions reported by monitored systems, which can be combined into alert definitions that surface conditions requiring operator attention.

At the VMware vCenter level, alarms can execute scripts, send SNMP traps, or call APIs when infrastructure conditions match defined thresholds. The SNMP agent included with vCenter sends traps when alarms are triggered, and VCF PowerCLI provides programmatic access to alarm management through cmdlets that support creation of script-based and SNMP alarm actions. These capabilities provide automated event detection and alerting that feed into broader incident response processes.

To integrate with broader organizational incident response workflows, VCF Operations supports a ServiceNow Notifications plug-in that creates incidents directly in a ServiceNow ticketing system. The integration is configurable with fields including caller ID, incident category, sub-category, business service, contact type, and propagation settings for alert updates. This integration enables VCF-detected incidents to flow into an organization's established incident response and ticketing processes.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a physical machine failure. Proactive HA integrates with hardware vendor health monitoring to evacuate workloads before failures occur. vSphere cluster HA configuration supports multiple remediation modes, including quarantine mode, maintenance mode, and mixed mode. These recovery capabilities can be exercised ad hoc or incorporated into existing playbooks and runbooks.

VMware vDefend (a separate product that extends VCF's networking foundation) adds automated threat detection and containment through IDS/IPS and network detection features, including quarantine policies that isolate affected VMs while preserving forensic access.

This control requires organization-wide incident response governance, documented processes, and cross-functional coordination that go beyond what any infrastructure platform provides on its own. VCF delivers incident tracking, investigation tooling, event correlation, automated alerting, ITSM integration, and infrastructure recovery capabilities that form a technical foundation for incident response, but organizations must build their own incident response plans, escalation procedures, communication protocols, and training programs around these capabilities.

VMware vDefend (Contributes)

VMware vDefend contributes to incident response operations by providing integrated threat detection, investigation, correlation, and remediation capabilities within the network security layer of VCF. Security Services Platform defines a Security Operator role specifically for monitoring security systems and responding to security incidents, providing a built-in responsibility model for incident response activities at the network security layer.

Security teams can investigate individual threat events and correlated campaigns through the Security Services Platform interface to assess impact, identify root causes, and take appropriate mitigation actions. The Campaign Blueprint feature visualizes correlated security events and key actors within a campaign, simplifying triage and investigation to reduce mean time to detection. Campaign correlation surfaces multi-stage attack patterns: a drive-by infection event followed by a command-and-control event on the same workload is linked into a single campaign view. Security Intelligence categorizes detected suspicious traffic events by impact type (Critical, High, Medium, and Low) to help prioritize response actions.

Network Detection and Response (NDR) provides security analysts with capabilities to understand security events, triage them, and remediate by creating policies. NDR includes Suspicious Traffic detectors that collect and display suspicious traffic detections as events. Each detection event receives an impact score calculated from Confidence and Severity; informational events with scores from 1 to 24 indicate activity that is not essentially malicious and help teams focus attention on higher-priority events.

Security Services Platform generates Security Segmentation Reports and Blast Radius Reports that break down at-risk workloads, communication chains, and flows, helping teams assess the potential scope and lateral spread of an incident. The Rule Analysis feature generates downloadable CSV reports of anomaly analysis results, with separate files for each detected anomaly type. Security Services Platform provides metrics for Malware Prevention Service events, including malware family, non-benign indicators, process inspection events, and process state data, accessible through the API.

For remediation, the Response and Remediation feature in Security Services Platform performs automated policy creation based on user role and permissions. Intelligent Assist supports two remediation strategies, Targeted (surgical, with potentially lower breadth) and Comprehensive (broader scope), allowing teams to select the appropriate approach for each incident. Security Services Platform collects IDS policies, rules, and security profiles created by Intelligent Assist as part of remediation operations. Objects generated during NDR remediation that encounter errors require manual cleanup in Intelligent Assist.

These capabilities support detection, investigation, and remediation phases of an incident response lifecycle at the network security layer. vDefend does not govern organization-wide incident response processes, maintain incident response documentation, or manage incident tracking and status coordination functions. Those organizational and process governance functions fall outside the scope of a network security product.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation

and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER_HEALTH_DEGRADED, POOL_HEALTH_DEGRADED, and VS_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 7.2

Security Training and Awareness

SCF Controls: SAT-01, SAT-01.1, SAT-02, SAT-03, SAT-03.3, SAT-03.6

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 7.3A

Penetration Testing: Validate the operational security configuration and identify security gaps by performing penetration testing.

SCF Controls: IAO-01.1, TDA-09.5, VPM-07

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 7.4A

Scenario Risk Assessment: Evaluate the risk and readiness of the organisation based on plausible cyber-attack scenarios.

SCF Controls: RSK-01.1, RSK-01.3, RSK-01.4, RSK-01.5, RSK-03, RSK-03.1, RSK-04, RSK-04.2, THR-03, THR-09, THR-10

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

